République du Cameroun - Paix, Travail, Patrie

Chaire UNESCO d'Afrique Centrale Accès TIC

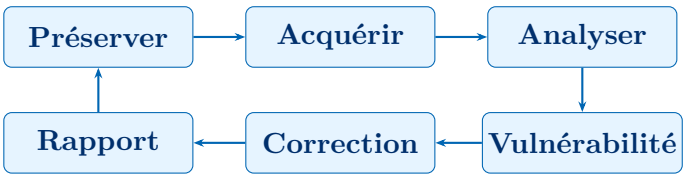
Sous la tutelle académique de l'École Nationale Supérieure Polytechnique de l'Université de Yaoundé I

Master Professionnel en Sécurité des Systèmes Numériques

Forensics et Analyse de Vulnérabilités

De la trace à la faille :
enquêter, prouver, corriger

FAV - UE MSN-2S3-SEC07



Chaque conclusion : oui / non / nek, la constatation séparée de l'analyse

MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | LIMSI | ENSPY

Chaire UNESCO d'Afrique Centrale Accès TIC

maletyon@proton.me

Année académique 2026–2027

Version 1.0 | Document pédagogique de l'UE MSN-2S3-SEC07

AVANT-PROPOS

Une microfinance de Bafoussam perd quarante-sept millions de francs CFA en une nuit. Trois mois plus tôt, l'éditeur de sa passerelle d'accès à distance avait publié un correctif pour la faille que les attaquants ont empruntée. L'enquête qui suit doit dire ce qui s'est passé, qui l'a fait si on peut le savoir, et par où ils sont entrés. La dernière question renvoie à une autre discipline, l'analyse de vulnérabilités, qui aurait pu éviter la première.

Ce cours réunit ces deux disciplines parce que, sur le terrain, elles se répondent. L'investigation numérique part d'une trace et remonte vers une cause ; la gestion des vulnérabilités part d'une faiblesse connue et cherche à la fermer avant qu'elle ne laisse une trace. L'une sans l'autre laisse un travail à moitié fait : une enquête qui ne débouche sur aucune correction prépare l'incident suivant, et un programme de correctifs qui ignore ce que les enquêtes révèlent corrige au hasard.

Il s'adresse aux étudiants du Master Professionnel en Sécurité des Systèmes Numériques de la Chaire UNESCO d'Afrique centrale, et aux praticiens qui exercent ou exerceront comme analystes forensiques, analystes en réponse à incident, analystes en gestion des vulnérabilités ou RSSI. Il suppose les bases de la sécurité des systèmes. Il laisse au cours d'Ethical Hacking et Pentesting (UE MSN-2S3-SEC03) l'exploitation des failles, et au cours de droit du numérique (UE MSN-2S3-JUR01) la protection des données personnelles.

Trois partis pris le traversent. Le premier est de tenir la preuve pour fragile : une copie mal faite, un horodatage mal lu ou un scellé mal tenu suffisent à faire écarter une constatation exacte. Le deuxième est de séparer, à chaque page, ce que l'on a constaté de ce que l'on en déduit, et de dire avec quelle confiance on le déduit. Le troisième est de coter ce que l'on ne sait pas : l'instrument OUI / NON / NEK du programme de recherche de l'auditologie sert ici à dire, pour chaque conclusion d'enquête, si elle est établie, réfutée, ou hors de portée des preuves disponibles.

Les deux organisations qui accompagnent le lecteur, NYANGA CRÉDIT et SOLI-TRANS LOGISTIQUE, sont fictives, comme leurs dirigeants, leurs prestataires, les dates, les adresses et les montants. La faille de la passerelle porte un identifiant fictif. Les mécanismes, les outils, les normes et les textes cités sont exacts. Les articles de loi sont cités dans leur texte officiel ; les normes sous licence sont paraphrasées.

Le livre est accompagné d'un livret des corrigés, qui explique et annote chaque exercice, et de NDAP SUKULU, où les fiches de questions et les dix laboratoires du cours permettent de pratiquer chaque chapitre.

© *MaletYon*

MINKA MI NGUIDJOÏ Thierry
Emmanuel
LIMSI, Yaoundé, novembre 2024

MODE D'EMPLOI DU COURS

Structure générale

Le cours compte un prologue et six parties, soit seize chapitres, pour 30 heures de cours magistral réparties en quinze séances de deux heures. Les travaux dirigés et les travaux pratiques se font à la maison, hors de ces 30 heures : pour les travaux dirigés, la fiche de questions de chaque chapitre et ses exercices de fin de chapitre (environ dix heures au total) ; pour les travaux pratiques, les dix laboratoires de NDAP SUKULU, d'une heure chacun. Les corrigés des exercices sont réunis dans un livret séparé.

Partie	Thème	Chap.	Niveau
0	Prologue : la nuit du 14 mars à Bafoussam	P	introductif
I	Fondements : enquêter sur des traces numériques	1–2	fondamental
II	Méthode : acquérir et analyser	3–7	fondamental à intermédiaire
III	Cadre normatif et juridique	8	fondamental
IV	Vulnérabilités : identifier, coter, corriger	9–12	intermédiaire
V	Défis avancés	13–15	intermédiaire à expert
VI	Recherche : mesurer l'incertitude d'une enquête	16	recherche

Les quinze séances

© *MaletYon*

Séance	Contenu	Travail à la maison
1	Prologue et Chap. 1 : l'incident, l'investigation numérique	Fiches P et 1
2	Chap. 2 : la preuve et la chaîne de possession	Fiche 2, lab 01
3	Chap. 3 : acquérir et préserver	Fiche 3, lab 02
4	Chap. 4 : l'analyse du disque	Fiche 4, lab 03
5	Chap. 5 : l'analyse de la mémoire	Fiche 5, lab 04
6	Chap. 6 : l'analyse du réseau	Fiche 6, lab 05
7	Chap. 7 : chronologie et corrélation	Fiche 7, lab 06
8	Chap. 8 : normes et droit de l'investigation	Fiche 8
9	Chap. 9 : qu'est-ce qu'une vulnérabilité	Fiche 9, lab 08
10	Chap. 10 : identifier sans exploiter	Fiche 10, lab 07
11	Chap. 11 : gérer les vulnérabilités	Fiche 11, lab 09
12	Chap. 12 : de l'artefact à la vulnérabilité	Fiche 12
13	Chap. 13 : anti-forensique, nuage et conteneurs	Fiche 13
14	Chap. 14 : l'enquête intégratrice	Fiche 14, lab 10
15	Chap. 15 et 16 : le rapport, l'incertitude d'une enquête	Fiches 15 et 16

Cette répartition est indicative ; l'enseignant l'adapte au calendrier et au rythme du groupe.

Le gabarit des chapitres

Chaque chapitre suit le même plan : une épigraphe, le niveau et les prérequis, les objectifs, une situation d'ouverture tirée de l'un des deux cas, des sections numérotées, ce qu'il faut retenir, des points de contrôle, trois à quatre exercices gradués, des lectures, et une transition.

Les encadrés

Encadré	Rôle
Objectifs	Ce que l'on doit savoir faire à la fin du chapitre
Définition	Les notions, en gras dans le texte et indexées
Violation typique	Une erreur fréquente, et la règle qui l'évite
Information	Un complément, un renvoi, une nuance
Opération (NYANGA, SOLITRANS)	Le cas : les constatations, puis l'analyse, avec un niveau de confiance
Artefact	Une trace décrite : source, emplacement, empreinte, ce qu'elle prouve et ce qu'elle ne prouve pas
Chaîne de possession	Ce que le dossier doit contenir pour qu'un autre puisse refaire l'examen
Lecture	Un décompte de cotes OUI / NON / NEK et sa lecture
Métier	Ce que la notion change pour chacun des métiers du cours
Texte juridique	Un article cité dans son texte officiel, et sa portée
Ce qu'il faut retenir	Les faits et les règles du chapitre
Exercice	Trois niveaux de difficulté : ★☆☆, ★★☆, ★★★

Les conventions

- Les cotes : OUI (établi par une preuve), NON (absent ou contredit par une preuve), NEK (connaissance insuffisante pour trancher). Une conclusion d'enquête reçoit l'une de ces trois cotes.
- Constatation et analyse sont toujours séparées ; l'analyse porte un niveau de confiance (faible, moyenne, élevée).
- Les heures sont données en heure locale du Cameroun (UTC+1), sauf mention UTC explicite.
- Les textes : seuls les articles lus dans leur version officielle sont cités entre guillemets ; les normes sous licence sont paraphrasées ; le degré de vérification figure à l'annexe D.
- Les adresses IP des cas appartiennent aux plages réservées à la documentation (RFC 5737), et l'identifiant de la faille de la passerelle, VULN-2024-4471, est fictif.
- Les cas sont fictifs : noms en majuscules, montants en francs CFA, villes réelles.

NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON



Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, *ndap sukulu* désigne la salle de classe et *malet yon* signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions et des pièces à examiner. Il est édité par MaletYon et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

Ce que l'on y trouve

- Une fiche de questions par chapitre. Chaque tentative tire vingt questions d'une banque de cent (QCM, vrai ou faux, textes à trous) et dure trente minutes.
- Dix laboratoires. Chaque lab place l'étudiant devant les pièces d'une affaire du cours (images, captures, journaux, tableurs de balayage) et se termine par des points de contrôle.
- Un espace enseignant, qui corrige les remises, établit la synthèse de la classe et publie les résultats.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

© *MaletYon*

Comment y accéder

1. En ligne, à l'adresse `https://maletyon.github.io/cours-fav/ndap-sukulu/`, dans un navigateur récent ; sur téléphone, ajouter `telephone/` à la fin de l'adresse.
2. Hors ligne, en téléchargeant l'archive de l'édition ordinateur depuis le dépôt `MaletYon/cours-fav`, dossier `ndap-sukulu`.
3. Se connecter avec le matricule et le mot de passe remis par l'enseignant. Pour essayer avant d'être inscrit, un compte de démonstration est ouvert à tous : matricule `ETU001`, mot de passe `eTU001` ; ses essais ne sont jamais transmis à l'enseignant.
4. Pour un lab, vérifier d'abord l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.tx` puis travailler sur une copie : on n'examine jamais l'original.

Note

Les fiches de questions sont aussi fournies au format texte dans le dossier `fiches` du dépôt du cours, prêtes à être distribuées. Leurs corrections figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

Les laboratoires du cours

Le cours compte dix laboratoires, disponibles sous le code MSN-2S3-SEC07. Les six premiers reprennent les pièces de l'enquête NYANGA, les trois suivants le programme de SOLITRANS, et le dernier conduit une enquête complète sur la compromission du portail de SOLITRANS en février 2026, de la première trace à la faille.

Lab	Sujet	Chapitre	Opération
FAV-LAB-01	Chaîne de possession et scellés	2	NYANGA
FAV-LAB-02	Duplication et hachage	3	NYANGA
FAV-LAB-03	Disque : système de fichiers et artefacts	4	NYANGA
FAV-LAB-04	Mémoire : processus et connexions	5	NYANGA
FAV-LAB-05	Réseau : l'exfiltration	6	NYANGA
FAV-LAB-06	Chronologie unifiée	7	NYANGA
FAV-LAB-07	Lire un résultat de balayage	10	SOLITRANS
FAV-LAB-08	Coter : CVSS v4.0, EPSS, KEV	9	SOLITRANS
FAV-LAB-09	Prioriser et suivre la remédiation	11	SOLITRANS
FAV-LAB-10	Enquête intégratrice	12, 14	SOLITRANS

Les laboratoires du cours dans NDAP SUKULU

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi du cours v

NDAP SUKULU, la salle de classe compagnon ix

Prologue Opérationnel 3

0 La Nuit du 14 Mars à Bafoussam 3

0.1 Ce que l'on sait à 9 heures . . . 4
0.2 Les gestes de la première heure . . . 5
0.3 L'enquête : ce qu'elle établira . . . 6
0.4 Deux disciplines, une même affaire . . . 7
0.5 Les questions du cours . . . 8
0.6 Les métiers de l'affaire . . . 9
0.7 Cinq réflexes . . . 9

I Fondements : Enquêter sur des Traces Numériques 13

1 L'Investigation Numérique 15

1.1 Trace, Preuve et Investigation . . . 16
1.1.1 Le principe d'échange . . . 16
1.1.2 Ce qui distingue la trace numérique . . . 17
1.2 Les Principes d'un Examen Acceptable . . . 17
1.3 Les Phases d'une Enquête . . . 18
1.3.1 Quatre phases selon le NIST . . . 18
1.3.2 Cinq classes de processus selon l'ISO/IEC 27043 . . . 18
1.4 Trois Cadres d'Enquête . . . 19
1.5 Raisonner par Hypothèses Concurrentes . . . 20
1.6 Les Biais de l'Enquêteur . . . 21
1.7 Ce que l'Investigation demande à chaque Métier . . . 22

2 La Preuve Numérique et la Chaîne de Possession 27

2.1 Recevable et Probante . . . 28
2.2 L'Empreinte Cryptographique . . . 29

© *MaletYon*

2.2.1 Quelle fonction choisir . . . 29
2.2.2 Ce que l'empreinte ne prouve pas . . . 29
2.3 La Chaîne de Possession . . . 30
2.3.1 Le scellé . . . 30
2.4 La Chaîne de NYANGA . . . 31
2.5 Les Ruptures et leurs Remèdes . . . 33
2.6 Ce que la Preuve demande à chaque Métier . . . 34

II Méthode : Acquérir et Analyser 37

3 Acquérir et Préserver 39

3.1 L'Ordre de Volatilité . . . 40
3.2 À Froid ou à Chaud . . . 40
3.3 Acquérir un Disque . . . 41
3.3.1 Le bloqueur d'écriture . . . 41
3.3.2 Les formats d'image . . . 42
3.3.3 Les pièges du stockage moderne . . . 42
3.4 Capturer la Mémoire . . . 43
3.5 Les Journaux et les Données des Tiers . . . 43
3.6 Les Acquisitions de NYANGA . . . 44
3.7 Ce que l'Acquisition demande à chaque Métier . . . 45

4 L'Analyse du Disque 49

4.1 Du Disque au Fichier . . . 50
4.2 NTFS : la Table MFT et les Dates . . . 50
4.2.1 Deux jeux de quatre dates . . . 50
4.2.2 Les journaux de NTFS . . . 51
4.3 Les Fichiers Supprimés . . . 51
4.4 Les Artefacts Windows . . . 51
4.5 Ce que dit le Disque de SRV-CPT01 . . . 52
4.6 Les Heures et leurs Pièges . . . 54
4.7 Ce que l'Analyse du Disque demande à chaque Métier . . . 54

5 L'Analyse de la Mémoire 59

5.1 Ce que la Mémoire Contient . . . 60
5.2 L'Outil et la Méthode . . . 60
5.2.1 Deux listes de processus . . . 61
5.2.2 Le processus normal . . . 61
5.3 Ce que la Mémoire de SRV-AD01 Révèle . . . 62
5.4 Le Vol d'Identifiants . . . 62
5.5 Les Limites de l'Analyse Mémoire . . . 64

5.6 Ce que l'Analyse Mémoire demande à chaque Métier . . . 64

6 L'Analyse du Réseau 67

6.1 Quatre Sources Réseau . . . 68
6.2 Lire une Capture . . . 68
6.3 Caractériser une Exfiltration . . . 69
6.3.1 Ce que le chiffrement laisse voir . . . 70
6.4 Reconnaître une Balise . . . 70
6.5 Ce que la Capture ne Voit pas . . . 70
6.6 Ce que l'Analyse Réseau demande à chaque Métier . . . 71

7 Chronologie et Corrélation 75

7.1 Normaliser les Heures . . . 76
7.2 Fusionner et Corréler . . . 76
7.3 La Chronologie de NYANGA . . . 77
7.4 Lire la Chronologie par Tactiques . . . 79
7.5 Ce que la Chronologie demande à chaque Métier . . . 80

III Cadre Normatif et Juridique 83

8 Normes et Droit de l'Investigation 85

8.1 Les Normes de l'Investigation . . . 86
8.2 Le Cadre Camerounais de l'Enquête . . . 87
8.3 Qualifier les Faits . . . 88
8.4 Les Obligations de l'Exploitant . . . 89
8.5 Trois Statuts, Trois Pouvoirs . . . 91
8.6 L'Entraide Internationale . . . 91
8.7 Ce que le Droit demande à chaque Métier . . . 92

IV Vulnérabilités : Identifier, Coter, Corriger 95

9 Qu'est-ce qu'une Vulnérabilité 97

9.1 Faiblesse, Vulnérabilité, Menace, Risque . . . 98
9.1.1 Le cycle de vie d'un identifiant CVE . . . 98
9.2 Le Score CVSS . . . 98
9.2.1 Quatre groupes de métriques . . . 99
9.2.2 Les métriques de base . . . 99
9.2.3 Les seuils de gravité . . . 100
9.3 EPSS : la Probabilité d'Exploitation . . . 100
9.4 KEV : ce qui est Exploité . . . 100
9.5 SSVC : Décider plutôt que Noter . . . 101

9.6 Quatre Failles chez SOLITRANS . . . 101
9.7 Ce que la Notion demande à chaque Métier . . . 102

10 Identifier les Vulnérabilités sans les Exploiter 105

10.1 L'Inventaire d'Abord . . . 106
10.2 Quatre Façons d'Identifier . . . 107
10.3 Faux Positifs, Faux Négatifs . . . 107
10.4 Encadrer un Balayage . . . 108
10.5 Mesurer la Couverture . . . 109
10.6 Ce que l'Identification demande à chaque Métier . . . 110

11 Gérer les Vulnérabilités 113

11.1 Le Cycle de Gestion . . . 114
11.2 La Politique de Priorité . . . 114
11.3 Corriger en Production . . . 115
11.4 Les Exceptions . . . 116
11.5 Mesurer le Programme . . . 117
11.6 Ce que la Gestion demande à chaque Métier . . . 118

12 De l'Artefact à la Vulnérabilité 121

12.1 Trois Explications pour une Session . . . 122
12.2 Examiner un Équipement de Bordure . . . 123
12.3 Cause Immédiate, Causes Contributives, Cause Profonde . . . 124
12.4 Chercher les Variantes . . . 125
12.5 Des Enseignements aux Règles . . . 126
12.6 Ce que la Remontée demande à chaque Métier . . . 126

V Défis Avancés 129

13 Anti-forensique, Nuage et Conteneurs 131

13.1 Les Techniques d'Anti-forensique . . . 132
13.2 Détecter une Falsification de Dates . . . 132
13.3 Un Journal Vidé . . . 133
13.4 L'Enquête dans le Nuage . . . 133
13.5 Les Conteneurs . . . 134
13.6 Ce que ces Défis demandent à chaque Métier . . . 135

14 L'Enquête Intégratrice 139

14.1 Une Méthode en Dix Étapes . . . 140
14.2 Trois Enquêtes, un Dossier . . . 140
14.3 Le Dossier NYANGA . . . 141

14.4 Le Coût d'un Incident . . . 142
14.5 L'Exercice Intégrateur : SOLITRANS, Février 2026 . . . 143
14.6 Ce que l'Enquête demande à chaque Métier . . . 143

15 Le Rapport et le Témoignage 147

15.1 Trois Destinataires, Trois Rapports . . . 148
15.2 Le Rapport d'Expertise . . . 148
15.2.1 Écrire une conclusion . . . 149
15.2.2 Dire les limites . . . 149
15.3 L'Indépendance et la Compétence . . . 149
15.4 Déposer à l'Audience . . . 150
15.5 Ce que le Rapport demande à chaque Métier . . . 151

VI Recherche : Mesurer l'Incertitude d'une Enquête 155

16 Mesurer l'Incertitude d'une Enquête 157

16.1 L'Instrument Trichotomique . . . 158
16.2 Les Douze Propositions de NYANGA . . . 158
16.3 Deux Sortes de NEK . . . 160
16.4 Questions Ouvertes pour la Recherche . . . 160
16.5 Ce que la Mesure demande à chaque Métier . . . 161

A Glossaire 165

B Référentiel des Outils 169

C Modèles de Documents 171

D Textes et Normes de Référence 175

E Bibliographie Commentée 179

F Contacts et Ressources 181

Références bibliographiques 183

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

LA NUIT DU 14 MARS À BAFOUSSAM

« Ce que l'on fait dans la première heure
décide de ce que l'on pourra prouver dans un an. »

Principe du cours

Niveau : *Introductif* • Aucun prérequis : ce prologue ouvre le cours et en pose les questions.

✦ Objectifs du chapitre

- ➢ Reconnaître, dans un incident réel, les questions qui relèvent de l'investigation numérique et celles qui relèvent de l'analyse de vulnérabilités.
- ➢ Distinguer les gestes qui préservent la preuve de ceux qui la détruisent pendant la première heure.
- ➢ Séparer, dans un récit d'incident, la constatation de l'analyse.
- ➢ Coter une conclusion d'enquête OUI, NON ou NEK.
- ➢ Situer les métiers qui interviennent, de l'alerte à la correction.

Avant de commencer : un vendredi matin

Bafoussam, vendredi 14 mars 2025, 7 h 30. Au service des paiements de NYANGA CRÉDIT[1], une agente de permanence ouvre le rapprochement de la nuit. Elle compte vingt-trois virements sortants passés entre 2 h 05 et 3 h 31, tous par l'interface qui relie l'établissement aux opérateurs de paiement mobile, tous vers onze portefeuilles que personne ne connaît. Le total atteint 47 300 000 francs CFA. Aucun agent n'était en poste à ces heures-là.

NYANGA CRÉDIT est un établissement de microfinance de deuxième catégorie, installé à Bafoussam, présent dans vingt-deux agences de l'Ouest et du Littoral, au service d'environ 210 000 clients. Son informatique tient dans une salle du siège : un contrôleur de domaine, un serveur comptable, un serveur de fichiers, l'interface de

[1] NYANGA CRÉDIT, SOLITRANS LOGISTIQUE, leurs dirigeants, leurs prestataires, les adresses, les dates et les montants sont fictifs ; l'identifiant VULN-2024-4471 est fictif. Les mécanismes techniques, les outils, les normes et les textes cités sont exacts.

© MaletYon

paiement mobile, et une passerelle d'accès à distance qui permet aux agences et aux techniciens de se connecter au siège.

À 8 h 15, le directeur des systèmes d'information, M. KAMGA, arrive. Le serveur de fichiers ralentit depuis la veille. Son premier réflexe est de le redémarrer, puis de restaurer la sauvegarde de la veille. La responsable de la sécurité, Mme NDOUMBE, l'arrête : elle fait débrancher le câble réseau du serveur, sans l'éteindre, et demande que personne ne touche plus aux machines du siège avant son retour. Elle revient vingt minutes plus tard avec une clé USB qui contient un outil de capture de la mémoire vive.

Ce prologue raconte les premières heures de l'incident et les questions qu'elles posent. Les seize chapitres qui suivent y répondent une à une.

★ Attention

Violation typique. Redémarrer, nettoyer ou restaurer une machine compromise avant d'avoir préservé ce qu'elle contient.

Règle : on isole avant d'agir, on préserve avant d'analyser, et on consigne chaque geste avec son heure et son auteur. Une machine redémarrée a perdu sa mémoire vive, ses connexions ouvertes et une partie de ses journaux ; une machine restaurée a perdu tout le reste.

0.1 Ce que l'on sait à 9 heures

À 9 h 10, le directeur général, M. TCHOUA, réunit une cellule de crise : M. KAMGA, Mme NDOUMBE et la juriste de l'établissement, Me ETOUNDI. Mme NDOUMBE pose sur la table ce qui est établi, et seulement cela.

Constatation	Source	Cote
23 virements entre 2 h 05 et 3 h 31, 47,3 M FCFA, 11 portefeuilles	Journal de l'interface de paiement	OUI
Les virements ont utilisé la clé d'accès de l'établissement à l'interface	Journal de l'interface de paiement	OUI
Aucun agent n'était connecté au siège entre 1 h et 5 h	Registre des présences, journal de la passerelle	OUI
Le serveur de fichiers a émis un volume sortant inhabituel dans la nuit	Supervision du lien Internet	OUI
Ce volume correspond à des fichiers de clients	Aucune pièce à ce stade	NEK
L'attaquant est entré par la passerelle d'accès à distance	Hypothèse du DSI	NEK
L'attaque vient d'un employé	Rumeur dans les couloirs	NEK

Tableau 0.1. Le point de 9 h 10

Trois lignes sont cotées NEK : aucune preuve ne permet encore de les établir ou de les écarter. Une hypothèse, même plausible, ne devient pas une constatation parce qu'un responsable la formule avec assurance. Mme NDOUMBE le dit à la cellule : « Nous savons ce qui est sorti du compte. Nous ne savons pas encore par où ils sont entrés. »

Définition

Constatation : fait vérifiable, rattaché à une source identifiée (un journal, une image, une capture), que toute personne compétente retrouverait en refaisant l'examen.

Analyse : interprétation d'une ou de plusieurs constatations ; elle porte un niveau de confiance (faible, moyenne, élevée) et peut être révisée par une constatation nouvelle.

Définition

Cote OUI, NON, NEK : réponse à une question d'enquête fermée. OUI : la proposition est établie par une preuve. NON : elle est contredite par une preuve. NEK (*not enough knowledge*) : les preuves disponibles ne permettent pas de trancher. L'instrument vient du programme de recherche de l'auditologie [36].

0.2 Les gestes de la première heure

Ce que Mme NDOUMBE fait entre 8 h 15 et 10 h 30 n'a rien d'improvisé : elle applique un ordre que l'on retrouve dans la RFC 3227 [4] et dans la norme ISO/IEC 27037 [19], celui de la volatilité. On recueille d'abord ce qui disparaît le plus vite.

Heure	Geste	Ce qu'il préserve	Ce qu'il évite
8 h 20	Débrancher le câble réseau du serveur de fichiers, sans l'éteindre	La mémoire vive, les processus, les connexions récentes	La poursuite de l'exfiltration, l'effacement à distance
8 h 25	Interdire toute connexion aux serveurs du siège	L'état des disques et des journaux	Les modifications par l'équipe elle-même
8 h 40	Désactiver la passerelle d'accès à distance	Les journaux de la passerelle, figés	Un nouvel accès
10 h 02	Capturer la mémoire du contrôleur de domaine (16 Go), calculer son empreinte	Les processus et les identifiants en mémoire	La perte au prochain redémarrage
10 h 30	Ouvrir un registre des actions : heure, auteur, geste, résultat	La traçabilité de chaque intervention	La contestation ultérieure

Tableau 0.2. Les gestes de la première heure

Chaque geste a un coût. Débrancher le serveur arrête aussi le partage de fichiers des agences ; désactiver la passerelle prive les techniciens d'accès à distance. Le DSI le fait remarquer. La réponse de Mme NDOUMBE tient en une phrase : une heure d'interruption se rattrape, une preuve détruite ne se reconstitue pas.

Artefact · Capture mémoire de SRV-AD01, 14 mars 2025, 10 h 02

Source : contrôleur de domaine SRV-AD01, salle serveurs du siège, Bafoussam.
Pièce : fichier `SRV-AD01_20250314_1002.raw`, 16 Go, copié sur un disque externe neuf, étiqueté et placé sous enveloppe.
Empreinte : SHA-256 calculée à 10 h 41 et inscrite au registre, contresignée par M. KAMGA.
Ce qu'elle peut prouver : les processus actifs à 10 h 02, les connexions réseau ouvertes, les traces d'outils exécutés en mémoire.
Ce qu'elle ne prouve pas : ce qui s'est passé avant le dernier redémarrage de la machine, ni l'identité d'une personne.

0.3 L'enquête : ce qu'elle établira

L'après-midi même, NYANGA CRÉDIT mandate le cabinet SANKOFA EXPERTISE, à Yaoundé, pour conduire la réponse à l'incident ; Mme MBARGA dirige la mission. Le lendemain, l'établissement dépose plainte au parquet de Bafoussam. Le 17 mars, le procureur de la République réquisitionne un expert indépendant, M. ABOUBAKAR, expert près la cour d'appel de l'Ouest. Deux enquêtes avancent désormais en parallèle : celle du cabinet, au service de l'établissement, et celle de l'expert, au service de la justice. Elles examinent les mêmes pièces et n'ont pas les mêmes obligations.

Trois semaines plus tard, les deux enquêtes établissent la même séquence.

Scénario Opérationnel · Opération NYANGA. Ce que l'enquête établit

Constatations.

- Le 2 mars à 23 h 48, le journal de la passerelle enregistre une première session du compte de service `svc_backup`, depuis l'adresse 203.0.113.18, sans échec d'authentification préalable.
- Le 9 mars à 1 h 37, un fichier `lsass.dmp`, copie de la mémoire du processus qui gère les authentifications Windows, est créé dans un dossier temporaire de SRV-AD01 ; la capture mémoire du 14 mars montre encore un outil d'accès à distance actif et une connexion vers 203.0.113.47.
- Le 12 mars, le journal de SRV-CPT01 montre la lecture du fichier de configuration qui contient la clé d'accès à l'interface de paiement.

- Le 14 mars, de 1 h 12 à 3 h 47, la capture réseau montre 3,2 Go envoyés de SRV-FIC01 vers 203.0.113.47.
- La passerelle fonctionnait avec une version de micrologiciel antérieure au correctif publié le 15 décembre 2024 pour la faille VULN-2024-4471, qui permet de contourner l'authentification.

Analyse (confiance élevée). L'attaquant est entré par la passerelle, en exploitant VULN-2024-4471 pour ouvrir une session sous un compte de service ; il a récupéré des identifiants d'administration en mémoire, lu la clé de l'interface de paiement, copié des fichiers, puis déclenché les virements.
Ce qui reste nek. L'identité des auteurs. Les adresses 203.0.113.18 et 203.0.113.47 désignent des machines, pas des personnes.

La dernière constatation change la nature de l'affaire. Le correctif était disponible depuis 89 jours le jour de l'attaque, et depuis 77 jours lors du premier accès ; le 19 décembre, la faille avait été inscrite au catalogue des vulnérabilités exploitées tenu par l'agence américaine CISA. L'enquête, partie d'un virement frauduleux, aboutit à une faiblesse connue, publiée et corrigeable. Pourquoi n'a-t-elle pas été corrigée ? Parce que la passerelle ne figurait pas dans l'inventaire de l'outil de balayage de vulnérabilités : personne ne l'a jamais analysée.

0.4 Deux disciplines, une même affaire

L'affaire NYANGA fait se rejoindre deux disciplines que l'on enseigne souvent séparément.

	Investigation numérique	Analyse de vulnérabilités
Point de départ	Une trace, un incident	Une faiblesse connue, un actif
Question	Que s'est-il passé, comment, depuis quand ?	Où sommes-nous exposés, et que corriger d'abord ?
Matière	Images de disque, mémoire, captures, journaux	Inventaires, résultats de balayage, bulletins, scores
Produit	Un rapport qui peut servir de preuve	Un plan de correction suivi
Temps	Après l'incident	Avant l'incident, en continu

Tableau 0.3. Deux disciplines

Elles se nourrissent l'une l'autre. L'enquête révèle les faiblesses que l'attaquant a réellement empruntées ; elle dit au programme de gestion des vulnérabilités ce qu'il a manqué. Le programme, en retour, réduit le nombre d'enquêtes à conduire et fournit aux enquêteurs l'inventaire et l'historique des versions qui leur permettent de dater une

exposition. À Douala, un autre acteur du cours, SOLITRANS LOGISTIQUE, montrera dans la partie IV comment on construit un tel programme sur 1 380 actifs.

Note

Ce que le cours ne traite pas. L'exploitation des failles relève de l'UE MSN-2S3-SEC03 (Ethical Hacking et Pentesting) : ce cours apprend à identifier, coter et faire corriger une vulnérabilité, pas à s'en servir. La protection des données personnelles exposées par l'exfiltration relève de l'UE MSN-2S3-JUR01. L'audit et la gestion du risque relèvent de l'UE MSN-2S3-SEC08.

0.5 Les questions du cours

Chaque chapitre répond à l'une des questions que la cellule de crise s'est posées, ou aurait dû se poser.

Question de la cellule	Chapitre
Qu'est-ce qu'enquêter sur des traces numériques ?	Chapitre 1
Comment faire pour que ce que l'on trouve serve de preuve ?	Chapitre 2
Comment copier un disque ou une mémoire sans les altérer ?	Chapitre 3
Que contient le disque du serveur comptable ?	Chapitre 4
Que révèle la mémoire du contrôleur de domaine ?	Chapitre 5
Qu'est-il sorti, et vers où ?	Chapitre 6
Dans quel ordre les choses se sont-elles passées ?	Chapitre 7
Qui a le droit de faire quoi, et selon quelles règles ?	Chapitre 8
Qu'est-ce qu'une vulnérabilité, et comment la coter ?	Chapitre 9
Comment les trouver sans attaquer ?	Chapitre 10
Comment décider de ce qu'on corrige d'abord ?	Chapitre 11
Comment remonter de la trace à la faille ?	Chapitre 12
Et si l'attaquant a effacé ses traces, ou travaille dans le nuage ?	Chapitre 13
Comment conduire l'enquête de bout en bout ?	Chapitre 14
Comment l'écrire, et la défendre devant un juge ?	Chapitre 15
Comment mesurer ce que l'enquête ne sait pas ?	Chapitre 16

Tableau 0.4. Les questions et les chapitres

0.6 Les métiers de l'affaire

Quatre métiers ont travaillé sur l'affaire NYANGA. Le cours les suit chapitre après chapitre.

Application RSSI

Mme NDOUMBE a préservé avant d'analyser, ouvert le registre des actions et refusé de coter une hypothèse comme un fait. Son rôle, dans les jours qui suivent, est d'arbitrer entre la reprise de l'activité et la conservation des preuves, et de faire corriger la faille.

Application Analyste en réponse à incident

Mme MBARGA et son équipe contiennent l'incident, recueillent les pièces, reconstituent la séquence et remettent à l'établissement un rapport qui sert à décider. Ils travaillent vite, mais chaque pièce qu'ils touchent peut finir devant un tribunal.

Application Application OPJ/Expert Judiciaire

L'adjudant-chef NANA, officier de police judiciaire, conduit l'enquête pénale ; M. ABOUBAKAR, réquisitionné par le procureur, examine les pièces pour la justice. L'expert ne répond qu'aux questions de sa mission, et chacune de ses conclusions doit pouvoir être refaite par un autre expert.

Application Analyste en gestion des vulnérabilités

Personne n'occupait ce rôle à NYANGA CRÉDIT. C'est la leçon de l'affaire : un actif hors de l'inventaire est un actif que personne ne corrige.

0.7 Cinq réflexes

1. Isoler sans éteindre, puis préserver dans l'ordre de la volatilité.
2. Consigner chaque geste : heure, auteur, action, résultat, empreinte.
3. Séparer la constatation de l'analyse, et coter NEK ce que les pièces ne permettent pas de trancher.
4. Remonter jusqu'à la faiblesse exploitée : une enquête qui s'arrête aux auteurs laisse la porte ouverte.
5. Vérifier que la correction est faite, sur la machine elle-même, et pas sur la foi d'un courriel.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Les gestes de la première heure décident des preuves disponibles : isoler, préserver dans l'ordre de la volatilité, consigner.
- Une constatation se rattache à une source ; une analyse porte un niveau de confiance. Une hypothèse reste NEK tant qu'aucune pièce ne la tranche.
- À NYANGA CRÉDIT, l'enquête remonte du virement frauduleux à une faille corrigeable depuis 89 jours, absente de l'inventaire.
- L'investigation numérique et l'analyse de vulnérabilités se répondent : l'une explique l'incident, l'autre empêche le suivant.

● Note

Points de contrôle. Vous avez compris ce prologue si vous savez :

- citer trois gestes qui préservent la preuve et deux qui la détruisent ;
- réécrire une phrase de rapport en séparant la constatation et l'analyse ;
- coter une conclusion OUI, NON ou NEK et justifier la cote par une source.

Exercices

✍ **Exercice 0.1. Préserver ou détruire ★☆☆**

Pour chacun des gestes suivants, dites s'il préserve ou s'il détruit de la preuve, et laquelle.

(a) Lancer un antivirus complet sur le serveur de fichiers.

(b) Photographier l'écran du serveur avant toute action.

(c) Redémarrer le contrôleur de domaine pour « couper l'attaquant ».

(d) Exporter les journaux de la passerelle sur un support neuf et en calculer l'empreinte.

(e) Changer immédiatement le mot de passe de `svc_backup` depuis le serveur compromis.

✍ **Exercice 0.2. Constatation ou analyse ★★☆**

Le premier compte rendu du DSI contient les phrases suivantes. Pour chacune, dites si c'est une constatation, une analyse ou une hypothèse, et proposez une cote OUI, NON ou NEK avec sa source.

(a) « Les virements ont été faits depuis l'interface de paiement avec notre clé. »

(b) « Un employé a forcément donné son mot de passe. »

(c) « Le serveur de fichiers a envoyé 3,2 Go vers l'extérieur. »

(d) « Les fichiers volés sont ceux des clients. »

(e) « L'attaque vient d'un groupe étranger. »

✍ Exercice 0.3. Le compte des jours ★★☆

(a) Vérifiez les deux durées données dans le chapitre : 77 jours entre le correctif et le premier accès, 89 jours entre le correctif et l'exfiltration.

(b) La faille a été inscrite au catalogue des vulnérabilités exploitées le 19 décembre 2024. Que change cette inscription pour un établissement qui suit ce catalogue ?

(c) Donnez deux raisons pour lesquelles un actif peut échapper à l'inventaire d'un outil de balayage.

✍ Exercice 0.4. Deux enquêtes, deux obligations ★★★

Le cabinet SANKOFA EXPERTISE et l'expert judiciaire M. ABOUBAKAR examinent les mêmes pièces.

(a) Pour chacun, dites à qui il rend compte et quelle question il doit trancher.

(b) Le directeur général demande au cabinet de ne pas mentionner le retard de correction dans son rapport. Que doit faire Mme MBARGA ? L'expert judiciaire serait-il tenu par la même demande ?

(c) Rédigez, pour la cellule de crise, une note de cinq lignes qui distingue ce qui est établi, ce qui est réfuté et ce qui reste NEK au soir du 14 mars.

● Note

Pour aller plus loin.

- ➢ La RFC 3227 [4], pour l'ordre de volatilité.
- ➢ Le NIST SP 800-86 [31], pour l'intégration de la forensique à la réponse aux incidents.
- ➢ Le catalogue KEV de la CISA [13].

● Note

Transition. Avant de toucher aux pièces de l'affaire, il faut savoir ce qu'est une enquête numérique : son objet, ses principes, ses étapes. C'est l'objet du Chapitre 1.

partie I

Fondements : Enquêter sur des Traces Numériques

© *MaletYon*

1

L'INVESTIGATION NUMÉRIQUE

« Une enquête ne cherche pas à confirmer une idée.
Elle cherche ce qui pourrait la réfuter. »

Principe du cours

Niveau : *Fondamental* • Lecture du Chapitre 0

✦ Objectifs du chapitre

- ➢ Définir l'investigation numérique, la trace et la preuve numériques.
- ➢ Énoncer les principes qui rendent un examen acceptable : traçabilité, répétabilité, reproductibilité, justification.
- ➢ Décrire les phases d'une enquête selon le NIST SP 800-86 et les classes de processus de l'ISO/IEC 27043.
- ➢ Distinguer enquête judiciaire, enquête interne et réponse à incident, et leurs exigences de preuve.
- ➢ Conduire un raisonnement par hypothèses concurrentes et coter chaque hypothèse.

Avant de commencer : quatre hypothèses sur la table

Bafoussam, samedi 15 mars 2025, 8 heures. Mme MBARGA, de SANKOFA EXPERTISE, ouvre la première réunion de la mission en demandant à chacun d'écrire, sur une feuille, comment il pense que l'attaquant est entré. Elle recueille quatre réponses.

- ➢ H1 : par la passerelle d'accès à distance, avec un compte volé ou une faille.
- ➢ H2 : par un poste d'agence infecté par un courriel piégé, puis par le réseau interne.
- ➢ H3 : par un employé du siège qui aurait agi de l'intérieur, depuis un poste du siège.
- ➢ H4 : par le prestataire de l'interface de paiement, dont la clé aurait fuité de son côté.

Le DSI tient pour H3, la rumeur du vendredi. Le directeur général tient pour H4, qui met l'établissement hors de cause. Mme MBARGA ne tient pour aucune : elle écrit les

© MaletYon

quatre au tableau et annonce que l'enquête consistera à chercher, pour chacune, la pièce qui la réfuterait.

★ Attention

Violation typique. Choisir l'hypothèse la plus probable dès le premier jour, puis ne chercher que les traces qui la confirment.

Règle : on garde ouvertes toutes les hypothèses compatibles avec les constatations, et l'on cherche en priorité la pièce capable d'en éliminer une. Une hypothèse survit parce qu'on n'a pas réussi à la réfuter, pas parce qu'on a trouvé des indices en sa faveur.

1.1 Trace, Preuve et Investigation

■ Définition

Trace numérique : toute donnée produite par un système d'information, conservée sur un support ou en transit, qui garde la marque d'une action ou d'un état passé : une ligne de journal, une date de modification, un fichier supprimé mais récupérable, une connexion en mémoire.

Preuve numérique : trace recueillie, préservée et examinée de façon à pouvoir être présentée à un décideur (un juge, une direction, un régulateur) et soutenir ou réfuter une proposition de fait.

Investigation numérique : démarche méthodique qui identifie, recueille, préserve, examine et analyse des traces numériques pour répondre à des questions de fait, et en rend compte de façon vérifiable. On parle aussi de *digital forensics*.

Toute trace n'est pas une preuve. Une trace devient preuve quand trois conditions sont réunies : on sait d'où elle vient, on peut montrer qu'elle n'a pas changé depuis son recueil, et on peut expliquer ce qu'elle signifie. Le Chapitre 2 traite des deux premières ; la troisième occupe toute la partie II.

1.1.1 Le principe d'échange

Edmond Locard, fondateur du laboratoire de police technique de Lyon, a formulé au début du XXe siècle l'idée que tout contact laisse une trace [33]. Le numérique la vérifie d'une manière particulière. Un attaquant qui ouvre une session laisse une entrée dans le journal de la passerelle ; qui exécute un programme laisse une trace dans la mémoire, dans les journaux du système et souvent dans des fichiers de préchargement ; qui copie des données laisse un volume sortant dans la capture du lien Internet. Mais l'échange joue aussi dans l'autre sens : l'enquêteur qui examine une machine allumée y laisse ses propres traces. Le principe d'échange oblige donc l'enquêteur autant que l'attaquant.

1.1.2 Ce qui distingue la trace numérique

Propriété	Conséquence pour l'enquête
Copiable à l'identique	On travaille sur une copie, et l'empreinte cryptographique prouve que la copie égale l'original
Modifiable sans marque visible	Une date ou un journal se changent sans rature ; seule la préservation prouve l'intégrité
Volatile	La mémoire vive et les connexions disparaissent à l'extinction ; l'ordre de recueil compte
Abondante	Un serveur contient des millions de traces ; il faut des questions précises pour savoir quoi chercher
Dépendante de son contexte	Une heure n'a de sens qu'avec son fuseau et la dérive de l'horloge qui l'a produite

Tableau 1.1. Propriétés de la trace numérique

1.2 Les Principes d'un Examen Acceptable

La norme ISO/IEC 27037 [19] fixe des lignes directrices pour identifier, recueillir, acquérir et préserver la preuve numérique. Elle retient quatre principes, que l'on paraphrase ici.

Principe	Sens	Comment le prouver
Traçabilité (*auditability*)	Un tiers peut reconstituer chaque geste de l'enquêteur	Registre des actions, notes horodatées
Répétabilité	La même personne, avec les mêmes outils sur la même pièce, obtient le même résultat	Empreintes identiques, versions d'outils notées
Reproductibilité	Une autre personne, avec d'autres outils, obtient un résultat compatible	Méthode décrite, pièces conservées
Justification	Chaque choix de méthode ou d'outil peut être expliqué	Raisons écrites dans le dossier

Tableau 1.2. Quatre principes (d'après l'ISO/IEC 27037)

À ces quatre principes s'ajoutent deux règles de conduite que l'on retrouve dans les guides de bonnes pratiques policiers, comme celui de l'ACPO britannique [2]. La première est l'intervention minimale : on ne modifie pas une pièce, et si l'on y est contraint, par exemple pour capturer la mémoire d'une machine allumée, on le fait en personne compétente et l'on explique pourquoi. La seconde est la proportionnalité : on recueille ce qui répond aux questions de l'enquête, pas tout ce qui est techniquement accessible.

Note

Répétable, reproductible. La distinction n'est pas un détail. Un résultat répétable mais non reproductible dépend peut-être d'une particularité de l'outil. Quand deux outils indépendants donnent la même liste de fichiers supprimés, la conclusion gagne en confiance ; quand ils divergent, la divergence elle-même devient un objet d'examen.

1.3 Les Phases d'une Enquête

1.3.1 Quatre phases selon le NIST

Le guide NIST SP 800-86 [31] décrit l'intégration des techniques forensiques à la réponse aux incidents en quatre phases.

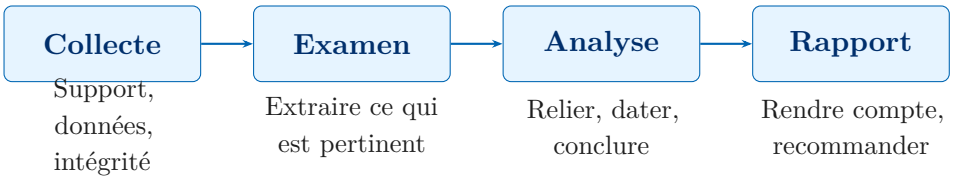


Figure 1.1. Les quatre phases du NIST SP 800-86

La collecte identifie et recueille les supports et les données en préservant leur intégrité. L'examen extrait, de la masse recueillie, les éléments pertinents : on décode un système de fichiers, on filtre des journaux. L'analyse relie ces éléments entre eux pour répondre aux questions posées. Le rapport en rend compte et formule des recommandations.

1.3.2 Cinq classes de processus selon l'ISO/IEC 27043

La norme ISO/IEC 27043 [22] propose un modèle plus large, qui commence avant l'incident. On en retient cinq classes de processus, paraphrasées.

Classe	Ce qu'elle couvre
Préparation (*readiness*)	Ce que l'organisation fait avant tout incident pour qu'une enquête soit possible : journaux conservés, horloges synchronisées, procédure de première intervention
Initialisation	Le déclenchement : détection, première évaluation, décision d'enquêter, mandat
Acquisition	L'identification, le recueil, l'acquisition, le transport et le stockage des pièces
Investigation	L'examen, l'analyse, l'interprétation, le rapport, la présentation et la clôture
Processus concurrents	Ce qui accompagne toute l'enquête : documentation, chaîne de possession, préservation, autorisations

Tableau 1.3. Classes de processus (d'après l'ISO/IEC 27043)

Scénario Opérationnel · Opération NYANGA. La préparation qui manquait

Constatations. La sonde réseau installée en 2024 conserve 48 heures de capture ; les journaux de la passerelle sont gardés 60 jours ; les horloges des serveurs sont synchronisées sur un serveur de temps interne ; l'établissement n'a aucune procédure écrite de première intervention, et aucun journal des postes d'agence n'est centralisé. **Analyse** (confiance élevée). La préparation existait pour le siège, pas pour les agences. Si l'attaquant était passé par un poste d'agence (H2), les traces auraient été dispersées sur vingt-deux sites et peut-être déjà écrasées. La réaction de Mme NDOUMBE a compensé l'absence de procédure ; un autre responsable, ce vendredi-là, aurait pu laisser le DSI redémarrer.

1.4 Trois Cadres d'Enquête

Les mêmes pièces peuvent servir trois enquêtes différentes, qui n'ont ni les mêmes questions, ni les mêmes exigences, ni les mêmes destinataires.

	Enquête judiciaire	Enquête interne	Réponse à incident
Qui la mandate	Le procureur, le juge, l'OPJ	La direction de l'organisation	L'organisation victime
Question	Une infraction a-t-elle été commise, par qui ?	Un salarié a-t-il manqué à ses obligations ?	Que s'est-il passé, comment arrêter et reprendre ?
Exigence de preuve	La plus haute : débat contradictoire	Celle du contentieux du travail	Suffisante pour décider vite
Priorité	La vérité judiciaire	La décision disciplinaire	La reprise de l'activité
Risque principal	Pièce écartée pour vice de forme	Atteinte à la vie privée du salarié	Preuve détruite par la remise en route

Tableau 1.4. Trois cadres d'enquête

La réponse à incident, décrite par le guide NIST SP 800-61 [9], a pour objet premier de contenir l'attaque et de rétablir le service. Elle entre en tension avec la préservation : remettre en route un serveur, c'est souvent effacer ce qu'il contenait. La règle pratique est de toujours travailler comme si l'enquête pouvait finir devant un juge. Un incident qui paraît interne au matin du vendredi peut devenir une affaire pénale la semaine suivante, comme à NYANGA CRÉDIT ; les pièces mal recueillies le vendredi ne seront pas recevables la semaine suivante.

Note

À NYANGA, les trois cadres coexistent. SANKOFA EXPERTISE conduit la réponse à incident pour l'établissement ; l'OPJ et l'expert réquisitionné conduisent l'enquête judiciaire ; si H3 avait survécu, la direction aurait dû ouvrir une enquête interne, avec les garanties dues au salarié mis en cause. Le Chapitre 8 précise ce que la loi permet à chacun.

1.5 Raisonner par Hypothèses Concurrentes

Richards Heuer, analyste du renseignement américain, a décrit une méthode simple pour résister à la tentation de confirmer sa première idée : l'analyse des hypothèses concurrentes [17]. On liste toutes les hypothèses plausibles, on liste les pièces, puis on remplit une matrice en notant, pour chaque couple, si la pièce est compatible ou incompatible avec l'hypothèse. On retient l'hypothèse qui a le moins d'incompatibilités, pas celle qui a le plus de compatibilités. Une pièce compatible avec toutes les hypothèses n'aide pas à choisir, quelle que soit son importance apparente.

Scénario Opérationnel · Opération NYANGA. La matrice du 29 mars

Pièce	H1	H2	H3	H4
Virements avec la clé de l'établissement	C	C	C	C
Session VPN `svc_backup` depuis 203.0.113.18, le 2 mars	C	I	I	I
Aucun échec d'authentification avant cette session	C	N	N	N
Aucun courriel piégé dans les boîtes des agences sur la période	C	I	C	C
Lecture du fichier de clé sur SRV-CPT01, le 12 mars, par `adm.kamga`	C	C	C	I
`adm.kamga` utilisé depuis le contrôleur de domaine, jamais depuis un poste du siège	C	I	I	N

C : compatible ; I : incompatible ; N : neutre (ne distingue pas).

Constatations. H1 n'a aucune incompatibilité ; H2 en a trois, H3 deux, H4 deux. La première ligne, la plus spectaculaire, est compatible avec tout et ne sert à rien pour choisir.

Analyse (confiance élevée). H1 est retenue ; H2, H3 et H4 sont incompatibles avec au moins deux pièces. Mais H3 n'est réfutée que telle qu'elle était formulée : un employé

du siège n'a pas agi depuis un poste du siège. Cela ne dit pas qu'aucun employé n'a participé : un employé aurait pu utiliser la passerelle depuis l'extérieur, comme l'attaquant. Cette question est distincte de celle du chemin d'entrée, et aucune pièce ne la tranche.

⚖ Lecture auditologique · Les quatre hypothèses au 29 mars

Hypothèse	Cote	Pièce décisive
H1, entrée par la passerelle	OUI	Session du 2 mars, puis usage de `adm.kamga` depuis le contrôleur de domaine
H2, poste d'agence infecté	NON	Aucune session interne, aucun courriel piégé
H3, employé agissant depuis le siège	NON	Aucune session de `adm.kamga` depuis un poste du siège
H4, fuite chez le prestataire	NON	Clé lue sur SRV-CPT01 avant les virements
Participation d'un employé, quel que soit le chemin	NEK	Aucune pièce ne l'établit ni ne l'exclut

Lecture. Une proposition établie, trois réfutées, une non tranchée. Le rapport intermédiaire ne doit pas dire « l'attaque vient de l'extérieur » sans réserve : il doit dire que l'entrée par la passerelle est établie, et que la participation d'un employé n'est ni établie ni exclue.

1.6 Les Biais de l'Enquêteur

L'enquêteur est un instrument de mesure, et cet instrument a des défauts connus.

Biais	Manifestation	Parade
Confirmation	On ne cherche que ce qui confirme l'hypothèse préférée	Matrice des hypothèses concurrentes
Ancrage	La première information reçue pèse trop	Noter l'hypothèse initiale et la réexaminer à chaque pièce
Autorité	L'avis du supérieur ou du client devient un fait	Exiger une source pour chaque constatation
Contexte	Savoir qui est suspect oriente la lecture des traces	Examiner les pièces avant de lire le dossier, quand c'est possible
Outil	Ce que l'outil n'affiche pas est tenu pour inexistant	Contrôler avec un second outil, noter les limites

Tableau 1.5. Biais et parades

Le biais d'outil mérite une attention particulière. Un logiciel d'analyse affiche ce qu'il sait décoder. Un format de journal qu'il ne connaît pas, un système de fichiers qu'il lit mal, une partition qu'il n'a pas montée n'apparaissent nulle part, et l'absence d'affichage passe pour une absence de trace. L'enquêteur qui écrit « aucune trace de connexion » doit pouvoir dire « dans quelles sources, lues avec quels outils ». Sinon, la bonne cote est NEK, pas NON.

1.7 Ce que l'Investigation demande à chaque Métier

Application Analyste en réponse à incident

Ouvrir une enquête

1. Écrire les questions de l'enquête avant de toucher aux pièces.
2. Lister toutes les hypothèses compatibles avec les premières constatations.
3. Identifier, pour chacune, la pièce qui la réfuterait.
4. Préserver ces pièces en priorité.
5. Tenir le registre des actions dès la première minute.

Application Application OPJ/Expert Judiciaire

L'expert ne choisit pas ses questions : elles figurent dans la réquisition ou l'ordonnance qui le désigne. S'il découvre un fait hors de sa mission, il le signale à l'autorité qui l'a désigné, sans l'instruire de lui-même.

Application RSSI

La préparation est son affaire : durée de conservation des journaux, synchronisation des horloges, procédure de première intervention connue de l'équipe de permanence. À NYANGA, il manquait la dernière.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Une trace devient preuve quand on sait d'où elle vient, qu'on peut montrer qu'elle n'a pas changé, et qu'on peut expliquer ce qu'elle signifie.
- Quatre principes rendent un examen acceptable : traçabilité, répétabilité, reproductibilité, justification.
- Le NIST décrit quatre phases (collecte, examen, analyse, rapport) ; l'ISO/IEC 27043 ajoute la préparation, avant l'incident.
- Enquête judiciaire, enquête interne et réponse à incident n'ont ni les mêmes questions ni les mêmes exigences ; on travaille toujours comme si l'affaire pouvait aller devant un juge.
- À NYANGA, la matrice du 29 mars établit H1, réfute H2, H3 et H4, et laisse NEK la participation éventuelle d'un employé.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- expliquer la différence entre répétabilité et reproductibilité ;
- placer une action d'enquête dans l'une des phases du NIST ;
- remplir une matrice d'hypothèses concurrentes et en tirer une cote pour chaque hypothèse.

Exercices

✍ Exercice 1.1. Trace ou preuve ★☆☆

Dites, pour chaque élément, s'il s'agit d'une simple trace ou d'une preuve au sens du chapitre, et ce qui lui manque le cas échéant.

(a) Une capture d'écran du journal de la passerelle, envoyée par WhatsApp par un technicien.

(b) L'export du même journal, sur support neuf, avec son empreinte SHA-256

inscrite au registre.

(c) Un fichier `lsass.dmp` trouvé sur SRV-AD01, dont personne n'a noté ni l'heure ni l'emplacement exacts.

(d) La capture mémoire de SRV-AD01 décrite au Chapitre 0.

✍ Exercice 1.2. Les phases et les classes ★☆☆

Rattachez chaque action à une phase du NIST SP 800-86 et à une classe de processus de l'ISO/IEC 27043 : (a) synchroniser les horloges des serveurs en 2024 ; (b) débrancher le serveur de fichiers le 14 mars ; (c) extraire du journal de la passerelle les sessions de `svc_backup` ; (d) relier ces sessions aux connexions de `adm.kamga` ; (e) remettre le rapport à la direction.

✍ Exercice 1.3. Une pièce qui change tout ★★☆

On découvre le 2 avril que `adm.kamga` a ouvert, le 11 mars, une session depuis un poste du siège, à 14 h 20, pendant les heures de bureau.

(a) Ajoutez cette pièce à la matrice du 29 mars.

(b) Les cotes des hypothèses changent-elles ? Justifiez.

(c) Quelle vérification feriez-vous avant de modifier une cote ?

✍ Exercice 1.4. Trois cadres pour une affaire ★★★

Six mois après l'incident, NYANGA CRÉDIT découvre qu'un agent comptable a consulté, sans raison de service, des dossiers de clients figurant parmi les fichiers exfiltrés.

(a) Quels cadres d'enquête peuvent s'ouvrir ? Qui mandate chacun ?

(b) Pour chacun, formulez la question de fait et l'exigence de preuve.

(c) Quelles précautions prendre pour que les pièces recueillies dans l'enquête interne restent utilisables dans une enquête judiciaire ?

● Note

Pour aller plus loin.

➢ E. Casey, *Digital Evidence and Computer Crime* [7], pour les fondements.

➢ Le NIST SP 800-86 [31] et l'ISO/IEC 27043 [22].

➢ R. Heuer, *Psychology of Intelligence Analysis* [17], chapitre sur les hypothèses concurrentes.

Note

Transition. Une hypothèse se tranche avec des pièces, et une pièce ne vaut que si l'on peut prouver qu'elle n'a pas changé. C'est l'objet du Chapitre 2 : la preuve numérique et la chaîne de possession.

2

LA PREUVE NUMÉRIQUE ET LA CHAÎNE DE POSSESSION

« Une pièce dont on ne peut pas dire où elle était
ne vaut pas mieux qu'une pièce perdue. »

Principe du cours

Niveau : *Fondamental* • Maîtrise du Chapitre 1

✦ Objectifs du chapitre

- ➢ Distinguer la recevabilité d'une preuve et sa force probante.
- ➢ Expliquer ce qu'une empreinte cryptographique prouve, et ce qu'elle ne prouve pas.
- ➢ Choisir une fonction de hachage adaptée et justifier ce choix.
- ➢ Tenir une chaîne de possession complète, du recueil à la restitution.
- ➢ Identifier une rupture de la chaîne et en mesurer les conséquences.
- ➢ Appliquer les articles 53 et 54 de la loi n° 2010/012 à une perquisition portant sur des données.

Avant de commencer : un disque sur un bureau

Bafoussam, samedi 15 mars 2025, 9 h 30. Mme MBARGA demande où se trouve le disque externe qui contient la capture mémoire du contrôleur de domaine. Il est sur le bureau de M. KAMGA, dans une enveloppe kraft fermée par un ruban adhésif. Personne ne l'a mis sous clé pendant la nuit. La porte du bureau du DSI ne ferme pas, et l'équipe de ménage passe le vendredi soir.

L'empreinte de la capture avait été calculée la veille à 10 h 41 et inscrite au registre. Mme MBARGA la recalcule devant M. KAMGA et Mme NDOUMBE : elle est identique. Le contenu n'a donc pas changé. Mais l'avocat de la défense, dans dix-huit mois, posera une autre question : pendant ces dix-sept heures, qui pouvait toucher ce disque ?

© MaletYon

★ Attention

Violation typique. Croire qu'une empreinte identique suffit à défendre une pièce, et négliger la trace écrite de ceux qui l'ont détenue.

Règle : l'empreinte prouve que le contenu n'a pas changé entre deux calculs ; la chaîne de possession prouve qui détenait la pièce, où, et dans quelles conditions. Les deux se complètent et aucune ne remplace l'autre.

2.1 Recevable et Probante

Deux questions se posent devant toute pièce, et elles ne se confondent pas.

■ Définition

Recevabilité : aptitude d'une pièce à être versée au débat. Une pièce obtenue en violation de la loi, par exemple par un accès non autorisé à un système, peut être écartée.

Force probante : poids que le décideur accorde à une pièce recevable. Elle dépend de la fiabilité de la source, de l'intégrité de la pièce, de la qualité de la méthode et de la clarté de son interprétation.

En matière pénale, le droit camerounais, comme la plupart des droits issus de la tradition civiliste, admet en principe la preuve par tout moyen et laisse le juge apprécier librement la valeur des pièces [disposition du Code de procédure pénale à vérifier par le lecteur sur le texte officiel]. Ce principe ouvre la porte à la preuve numérique, mais il ne la rend pas automatiquement convaincante. Une pièce numérique contestée sur son intégrité ou sur sa provenance sera recevable et peu probante : le juge la lira, puis lui accordera peu de poids. L'enquêteur travaille donc moins pour la recevabilité, que la loi accorde largement, que pour la force probante, qu'il doit construire.

Ce qui fonde la force probante	Ce que l'enquêteur doit pouvoir montrer
Provenance	De quel système, de quel emplacement, à quelle heure la pièce a été tirée
Intégrité	Que le contenu examiné est celui qui a été recueilli
Continuité	Qui a détenu la pièce, à chaque instant, et dans quelles conditions
Méthode	Comment la pièce a été acquise et examinée, avec quels outils et quelles versions
Interprétation	Ce que la pièce signifie, et les autres explications possibles

Tableau 2.1. Les fondements de la force probante

2.2 L'Empreinte Cryptographique

Définition

Fonction de hachage cryptographique : fonction qui associe à une donnée de taille quelconque une valeur de taille fixe, l'**empreinte** (*hash*), de sorte qu'il soit pratiquement impossible de trouver deux données différentes de même empreinte (résistance aux collisions), ou de construire une donnée qui ait une empreinte donnée (résistance aux préimages).

Si l'on modifie un seul bit d'une image disque de 500 Go, son empreinte SHA-256 change entièrement. Recalculer l'empreinte à chaque étape et constater qu'elle n'a pas varié démontre donc que le contenu est resté le même, sans avoir à comparer les deux copies octet par octet.

2.2.1 Quelle fonction choisir

Fonction	Taille	État	Usage en enquête
MD5	128 bits	Collisions calculables depuis 2004 ; on fabrique deux fichiers distincts de même empreinte	Complément pour comparer à d'anciennes bases, jamais seule
SHA-1	160 bits	Collision pratique publiée en 2017	Complément seulement
SHA-256	256 bits	Aucune attaque pratique connue	Empreinte de référence
SHA-512, SHA-3	512 bits et plus	Aucune attaque pratique connue	Possibles, moins répandues dans les outils

Tableau 2.2. Fonctions de hachage et usage en enquête

La faiblesse de MD5 porte sur les collisions, pas directement sur les préimages : un attaquant peut fabriquer deux fichiers de même empreinte, il ne peut pas, à ce jour, fabriquer un fichier qui ait l'empreinte d'un fichier donné. Une image acquise avec sa seule empreinte MD5 reste donc défendable en pratique, mais elle offre à la partie adverse un argument qu'une empreinte SHA-256 lui refuse. On calcule aujourd'hui SHA-256, et l'on ajoute MD5 quand un outil ou une base de référence l'exige.

2.2.2 Ce que l'empreinte ne prouve pas

- Elle ne prouve pas que la copie est complète : une acquisition qui a sauté des secteurs illisibles a une empreinte stable et un contenu lacunaire. Le journal de l'outil d'acquisition le dit.
- Elle ne prouve pas que la pièce vient du système annoncé : c'est le rôle de la provenance, consignée au recueil.

➢ Elle ne prouve rien sur la période qui précède son premier calcul : une capture modifiée avant d'être hachée garde, ensuite, une empreinte parfaitement stable.

La troisième limite explique pourquoi on calcule l'empreinte le plus tôt possible, idéalement pendant l'acquisition, et pourquoi on la fait constater par une seconde personne.

2.3 La Chaîne de Possession

Définition

Chaîne de possession (*chain of custody*) : documentation continue qui retrace, pour chaque pièce, chaque personne qui l'a détenue, chaque transfert, chaque lieu de conservation et chaque opération réalisée, depuis le recueil jusqu'à la restitution ou la destruction.

L'ISO/IEC 27037 [19] demande que cette documentation permette de répondre, pour chaque pièce, à des questions simples : qui l'a recueillie, quand, où, comment et pourquoi ; qui l'a détenue ensuite et à quel moment elle a changé de mains ; quelles opérations ont été faites sur elle. On paraphrase ici ces exigences sous la forme d'un formulaire.

Chaîne de possession

Le formulaire de chaîne de possession d'une pièce

1. Identifiant unique de la pièce et numéro de scellé.
2. Description : nature, marque, modèle, numéro de série, capacité.
3. Provenance : système, emplacement physique, propriétaire.
4. Recueil : date, heure, lieu, personne, méthode, outil et version.
5. Empreintes : algorithme, valeur, heure du calcul, témoin.
6. Conditionnement : enveloppe, sac antistatique, scellé, photo.
7. Pour chaque transfert : remettant, destinataire, date, heure, motif, état du scellé, signatures.
8. Pour chaque examen : personne, date, opération, copie utilisée.
9. Conservation : lieu, conditions (local fermé, armoire forte).
10. Sort final : restitution, destruction, archivage, avec autorisation.

2.3.1 Le scellé

Un scellé est un conditionnement qui ne s'ouvre pas sans laisser de marque : sac numéroté à fermeture inviolable, enveloppe signée sur les rabats et recouverte d'un adhésif transparent. Le numéro du scellé figure dans le formulaire. À chaque ouverture, on note qui l'a ouvert, pourquoi, et le numéro du nouveau scellé. Dans la procédure

pénale, la mise sous scellé relève de l'officier de police judiciaire, comme le rappelle l'article 53 de la loi n° 2010/012.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 53 [34] : *« (1) Les perquisitions en matière de cybercriminalité sont susceptibles de porter sur des données qui peuvent être des supports physiques ou des copies réalisées en présence des personnes qui assistent à la perquisition. (2) Lorsqu'une copie des données saisies a été faite, celle-ci peut être détruite sur instruction du Procureur de la République pour des raisons de sécurité. (3) Sur accord du Procureur de la République, seuls seront gardés sous scellé par l'Officier de Police Judiciaire, les objets, documents et données utilisées à la manifestation de la vérité. (4) Les personnes présentes lors de la perquisition peuvent être réquisitionnées de fournir les renseignements sur les objets, documents et données saisis. »*

Loi n° 2010/012, article 54 [34] : *« Les perquisitions et les saisies sont effectuées conformément aux dispositions du Code de Procédure Pénale en tenant compte du dépérissement des preuves. »*

Portée (analyse). L'article 53 admet que la saisie porte sur une copie des données, réalisée devant les personnes présentes : c'est la base légale de l'acquisition sur place, sans emporter le serveur. L'article 54 fait du dépérissement des preuves un critère de la conduite des saisies, ce qui justifie de capturer d'abord ce qui disparaît le plus vite.

2.4 La Chaîne de NYANGA

Scénario Opérationnel · Opération NYANGA. Le parcours du scellé NC-01

Date et heure	Détenteur	Lieu	Opération
14/03, 10 h 02	Mme NDOUMBE	Salle serveurs	Capture mémoire de SRV-AD01
14/03, 10 h 41	Mme NDOUMBE	Salle serveurs	Empreinte SHA-256, contresignée par M. KAMGA
14/03, 15 h 50	M. KAMGA	Bureau du DSI	Enveloppe kraft, ruban adhésif, sans numéro
15/03, 9 h 30	Mme MBARGA	Bureau du DSI	Empreinte recalculée, identique ; mise sous scellé NC-01
15/03, 11 h 00	Mme MBARGA	Salle de crise	Copie de travail, empreinte vérifiée
16/03, 10 h 15	Adjudant-chef NANA	Brigade de recherches	Remise sur réquisition, scellé intact, procès-verbal
17/03, 14 h 00	M. ABOUBAKAR	Laboratoire de l'expert	Ouverture du scellé, copie, nouveau scellé NC-01-E1

Constatations. La pièce a été détenue par cinq personnes successives. Entre le 14 mars à 15 h 50 et le 15 mars à 9 h 30, soit 17 h 40, elle est restée dans un bureau ouvert, sans scellé numéroté et sans consignation. Les empreintes calculées le 14 à 10 h 41 et le 15 à 9 h 30 sont identiques.

Analyse (confiance élevée sur l'intégrité, moyenne sur la continuité). Le contenu n'a pas changé : l'égalité des empreintes l'établit. La continuité, elle, présente un trou. Il n'affaiblit pas l'intégrité, mais il affaiblit la réponse à une autre objection : la substitution d'un disque par un autre de même contenu est sans effet, mais la manipulation du disque pendant la nuit, par exemple pour en copier le contenu, ne peut être exclue. Le rapport doit mentionner ce trou, et non le taire.

Lecture auditologique · Les six scellés de l'affaire au 17 mars

Scellé	Pièce	Intégrité	Continuité	Provenance
NC-01	Capture mémoire de SRV-AD01	OUI	NEK	OUI
NC-02	Journaux de la passerelle (export)	OUI	OUI	OUI
NC-03	Image disque de SRV-CPT01	OUI	OUI	OUI
NC-04	Capture réseau de la sonde	OUI	OUI	OUI
NC-05	Journaux de l'interface de paiement	OUI	OUI	NEK
NC-06	Capture d'écran WhatsApp d'un technicien	NEK	NON	NEK

Lecture. Sur dix-huit cotes, treize OUI, une NON et quatre NEK. NC-05 a été envoyé par le prestataire de l'interface sous forme de fichier joint à un courriel : son intégrité depuis l'envoi est établie, mais rien ne dit comment le prestataire l'a extrait. NC-06 ne sert qu'à orienter l'enquête ; on ne fonde aucune conclusion sur elle. NC-01 reste utilisable, avec la réserve sur la nuit du 14 au 15.

2.5 Les Ruptures et leurs Remèdes

Rupture	Conséquence	Remède
Empreinte calculée tard	Rien ne prouve l'état d'avant	L'écrire, et dater l'acquisition par d'autres sources (journal de l'outil)
Trou dans la détention	Une manipulation ne peut être exclue	Le dire dans le rapport, recueillir les témoignages, vérifier les journaux d'accès au local
Original examiné	L'original a pu changer	Recalculer l'empreinte, documenter l'opération, travailler ensuite sur copie
Pièce transmise par courriel	Provenance invérifiable avant l'envoi	Demander l'extraction en présence d'un témoin ou par procès-verbal
Scellé ouvert sans trace	La continuité est rompue	Nouveau scellé, procès-verbal d'ouverture, signatures

Tableau 2.3. Ruptures de chaîne et remèdes

Une rupture ne rend pas la pièce inutilisable. Elle en réduit la force probante, d'autant

plus que la pièce est seule à soutenir une conclusion. Quand plusieurs pièces indépendantes convergent, la faiblesse de l'une est compensée par les autres : à NYANGA, l'outil d'accès à distance vu dans la capture mémoire (NC-01) est aussi visible dans la capture réseau (NC-04), par ses connexions vers 203.0.113.47. La conclusion ne repose pas sur NC-01 seule.

2.6 Ce que la Preuve demande à chaque Métier

Application Application OPJ/Expert Judiciaire

Recevoir un scellé

1. Vérifier le numéro et l'état du scellé avant toute ouverture.
2. Ouvrir en présence d'un témoin, photographier, consigner.
3. Recalculer l'empreinte et la comparer à celle du formulaire.
4. Travailler sur une copie, et resceller l'original.
5. Signaler dans le rapport toute rupture constatée dans la chaîne reçue.

Application Analyste en réponse à incident

Le formulaire de chaîne de possession s'ouvre dès le recueil, même quand personne ne parle encore de plainte. Le coût est de quelques minutes par pièce ; une chaîne reconstituée après coup ne convainc personne.

Application RSSI

Prévoir, avant l'incident, le matériel de conditionnement (sacs numérotés, étiquettes, disques neufs) et un lieu de conservation fermé. À NYANGA, il n'y avait ni l'un ni l'autre, d'où l'enveloppe kraft sur le bureau du DSI.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- La recevabilité dit si une pièce entre au débat ; la force probante dit ce qu'elle pèse. L'enquêteur construit la seconde.
- L'empreinte SHA-256 prouve que le contenu n'a pas changé entre deux calculs ; elle ne prouve ni la complétude, ni la provenance, ni l'état d'avant le premier calcul.
- La chaîne de possession retrace chaque détenteur, chaque transfert, chaque opération ; un trou se dit, il ne se cache pas.

- Les articles 53 et 54 de la loi n° 2010/012 admettent la saisie par copie et imposent de tenir compte du dépérissement des preuves.
- À NYANGA, NC-01 a une intégrité établie et une continuité NEK sur 17 h 40 ; la conclusion qu'elle soutient est confirmée par NC-04.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- expliquer pourquoi MD5 seul ne suffit plus, et ce qui reste vrai à son sujet ;
- remplir un formulaire de chaîne de possession ;
- coter l'intégrité, la continuité et la provenance d'une pièce.

Exercices

Exercice 2.1. Ce que dit l'empreinte ★☆☆

Vrai ou faux ? Justifiez.

(a) Deux empreintes SHA-256 identiques prouvent que deux fichiers sont identiques.

(b) Une empreinte identique prouve que l'image disque est complète.

(c) Une image hachée en MD5 seulement est irrecevable.

(d) Il suffit de calculer l'empreinte au moment du rapport.

Exercice 2.2. Remplir le formulaire ★★☆

Le 15 mars à 16 h 00, SANKOFA EXPERTISE acquiert l'image du disque de SRV-CPT01 (scellé NC-03). Rédigez le formulaire de chaîne de possession de cette pièce jusqu'à sa remise à l'OPJ le 16 mars, en inventant de façon cohérente les éléments manquants (outil, version, empreintes, témoins).

Exercice 2.3. La nuit du 14 au 15 ★★☆

(a) Rédigez le paragraphe du rapport qui mentionne le trou de la chaîne de NC-01, en séparant constatation et analyse.

(b) Quelles vérifications complémentaires proposez-vous pour réduire l'incertitude sur cette nuit ?

(c) Le trou change-t-il une conclusion de l'enquête ? Justifiez à l'aide de NC-04.

✍ Exercice 2.4. NC-05 et le prestataire ★★★

Le prestataire de l'interface de paiement a envoyé ses journaux en pièce jointe d'un courriel. L'avocat de la défense soutiendra qu'ils ont pu être modifiés chez le prestataire.

(a) Quelles cotes donnez-vous à cette pièce, et pourquoi ?

(b) Comment l'OPJ aurait-il dû obtenir ces journaux ? Appuyez-vous sur les articles 53 et 54.

(c) Quelles pièces indépendantes permettent de corroborer les heures des virements ?

● Note

Pour aller plus loin.

➢ L'ISO/IEC 27037 [19], sur l'identification, le recueil et la préservation.

➢ Le guide de l'ACPO [2], pour ses quatre principes de conduite.

● Note

Transition. La chaîne de possession garde la pièce ; encore faut-il l'avoir acquise sans l'altérer. Copier un disque, capturer une mémoire, figer un journal : c'est l'objet du Chapitre 3.

partie II

Méthode : Acquérir et Analyser

© MaletYon

3

ACQUÉRIR ET PRÉSERVER

« On n'examine jamais l'original.
On examine une copie dont on peut prouver qu'elle lui est égale. »

Principe du cours

Niveau : *Fondamental* • Maîtrise du Chapitre 2

✦ Objectifs du chapitre

- ➢ Appliquer l'ordre de volatilité à une situation concrète.
- ➢ Choisir entre acquisition à froid et acquisition à chaud, et justifier ce choix.
- ➢ Acquérir un disque avec un bloqueur d'écriture, dans un format adapté, et vérifier l'acquisition.
- ➢ Capturer la mémoire vive en connaissant l'empreinte que laisse l'outil.
- ➢ Préserver des journaux avant leur rotation et des données détenues par des tiers.
- ➢ Documenter une acquisition de façon qu'un autre puisse la contrôler.

Avant de commencer : un serveur chiffré

Bafoussam, mardi 18 mars 2025. Mme MBARGA veut l'image du serveur de fichiers SRV-FIC01, celui qui a envoyé 3,2 Go vers l'extérieur. Le serveur est toujours allumé, débranché du réseau depuis le vendredi. M. KAMGA rappelle un détail : son disque de données est chiffré par BitLocker, et la clé de récupération est conservée chez le prestataire qui a installé la machine, à Douala. Si l'on éteint le serveur pour en extraire le disque, on obtiendra une copie parfaite d'un volume chiffré, illisible tant que la clé n'arrive pas. Si on le laisse allumé, le volume est déverrouillé et lisible, mais toute copie faite à chaud modifie un peu la machine.

© MaletYon

★ Attention

Violation typique. Appliquer mécaniquement la règle « on éteint puis on copie le disque » à une machine dont le chiffrement rendra le disque illisible une fois éteinte.

Règle : on choisit la méthode d'acquisition d'après ce que l'on perdrait avec chacune, et l'on écrit la raison du choix. La meilleure méthode est celle qui conserve le plus de preuve utile au prix de la plus petite altération documentée.

3.1 L'Ordre de Volatilité

La RFC 3227 [4] recommande de recueillir les traces de la plus volatile à la moins volatile. On en tire l'ordre suivant pour un serveur.

Rang	Trace	Durée de vie	Moyen d'acquisition
1	Registres, cache du processeur	Nanosecondes	Hors de portée en pratique
2	Mémoire vive : processus, connexions, tables de routage et ARP, clés en mémoire	Jusqu'à l'extinction	Capture de la mémoire
3	Fichiers temporaires, fichier d'échange	Heures à jours	Image du disque
4	Disques	Mois à années	Image du disque
5	Journaux distants, données de supervision	Selon la rotation	Export, réquisition
6	Configuration physique, topologie	Stable	Photographies, schéma
7	Supports d'archive	Années	Copie

Tableau 3.1. L'ordre de volatilité (d'après la RFC 3227)

Le rang 5 surprend souvent : un journal distant paraît durable, alors que sa rotation peut l'effacer en quelques jours. Les journaux de la passerelle de NYANGA CRÉDIT ne gardent que 60 jours : le premier accès du 2 mars disparaîtrait le 1er mai. Leur export, le 14 mars, était une urgence au même titre que la capture mémoire.

3.2 À Froid ou à Chaud

■ Définition

Acquisition à froid (*dead acquisition*) : copie d'un support après extinction de la machine, à l'aide d'un bloqueur d'écriture. Elle ne modifie pas le support et perd tout ce qui était en mémoire.

Acquisition à chaud (*live acquisition*) : recueil sur une machine allumée (mémoire, volume déverrouillé, état du système). Elle conserve le volatil et laisse une empreinte de l'outil sur la machine, qu'il faut documenter.

Situation	Méthode	Raison
Serveur allumé, attaque possiblement en cours	À chaud d'abord (mémoire), puis à froid	Processus et connexions perdus à l'extinction
Volume chiffré, clé indisponible	À chaud (copie logique du volume déverrouillé)	Volume illisible une fois éteint
Poste éteint à l'arrivée	À froid	Rien de volatil à préserver
Machine virtuelle	Instantané de l'hyperviseur, puis copie des fichiers de disque	Mémoire et disque figés ensemble, sans outil dans la machine
Service en nuage	Export par l'interface du fournisseur, réquisition	Aucun accès au matériel
Serveur critique qui ne peut s'arrêter	À chaud, copie logique ciblée	Arrêt impossible ; périmètre écrit et justifié

Tableau 3.2. Choisir la méthode d'acquisition

3.3 Acquérir un Disque

3.3.1 Le bloqueur d'écriture

Un système d'exploitation écrit sur tout support qu'on lui présente : il met à jour des dates d'accès, monte des volumes, écrit des journaux. Le **bloqueur d'écriture** s'interpose entre le support et la station d'acquisition et laisse passer les lectures en refusant les écritures. Le bloqueur matériel est un boîtier placé sur le câble ; le bloqueur logiciel est un réglage du système de la station. Le premier est préféré en enquête judiciaire, parce que son comportement se teste et se documente indépendamment du système. On vérifie un bloqueur avant usage, sur un support de test, et l'on note la vérification.

3.3.2 Les formats d'image

Format	Caractéristiques	Usage
Brut (`dd`, `.raw`)	Copie secteur par secteur, sans métadonnées ni compression	Universel, lisible par tout outil ; empreinte et notes dans des fichiers séparés
E01 (EWF)	Métadonnées intégrées (enquêteur, numéro de pièce, notes), compression, contrôle par blocs, empreinte stockée	Format courant des outils d'enquête ; bon compromis
AFF4	Format ouvert, métadonnées riches, adapté aux très gros volumes et à la mémoire	Moins répandu, utile pour les acquisitions volumineuses

Tableau 3.3. Formats d'image

3.3.3 Les pièges du stockage moderne

Les disques à mémoire flash (SSD) gèrent eux-mêmes l'effacement des blocs libérés : la commande TRIM permet au contrôleur d'effacer réellement des données supprimées, parfois quelques minutes après la suppression. Deux acquisitions successives d'un SSD allumé peuvent donc différer, sans que personne ait écrit dessus, et la récupération de fichiers supprimés y est moins fructueuse que sur un disque magnétique. Les secteurs défectueux d'un disque magnétique usé, eux, produisent des lectures incomplètes : l'outil d'acquisition les journalise et l'enquêteur reporte leur nombre dans son rapport.

Chaîne de possession

Acquérir un disque à froid

1. Photographier la machine, ses câbles et ses étiquettes ; noter le numéro de série du disque.
2. Vérifier le bloqueur d'écriture sur un support de test, et le consigner.
3. Relier le disque au bloqueur, puis à la station d'acquisition.
4. Choisir le format (E01 par défaut), saisir les métadonnées : numéro de pièce, enquêteur, description.
5. Acquérir, en calculant SHA-256 (et MD5 si une base l'exige).
6. Lire le journal de l'outil : secteurs illisibles, erreurs, durée.
7. Vérifier l'image : recalculer l'empreinte de l'image et la comparer à celle du support.
8. Faire une copie de travail, vérifier son empreinte, et sceller l'image de référence.

3.4 Capturer la Mémoire

La mémoire vive contient ce qu'aucun disque ne garde : la liste des processus actifs, les connexions réseau ouvertes, les commandes saisies, les clés de chiffrement des volumes ouverts, et parfois des programmes qui n'existent qu'en mémoire. On la capture avec un outil exécuté sur la machine elle-même : WinPmem ou DumpIt sous Windows, LiME ou AVML sous Linux. Ces outils sont libres ou gratuits et largement documentés.

Note

Une acquisition qui ne se répète pas. La mémoire change pendant la capture : les processus continuent de tourner, et l'outil lui-même occupe de la mémoire. On ne pourra jamais recalculer l'empreinte de la source pour la comparer à celle de la capture. L'empreinte de la mémoire capturée prouve seulement que la capture n'a pas changé depuis. C'est pourquoi l'on documente avec soin l'heure, l'outil, sa version, le support utilisé et ce qui tournait sur la machine.

Précaution	Raison
Lancer l'outil depuis un support externe	Ne pas écrire l'outil sur le disque à examiner
Écrire la capture sur un support externe	Ne pas écraser l'espace libre du disque, où dorment des fichiers supprimés
Ne rien installer	Une installation modifie le registre et le disque
Noter l'heure système et l'heure réelle	Mesurer la dérive de l'horloge
Consigner chaque commande	L'empreinte de l'enquêteur doit pouvoir être distinguée de celle de l'attaquant

Tableau 3.4. Précautions de la capture mémoire

3.5 Les Journaux et les Données des Tiers

Les journaux sont souvent la seule trace d'un événement ancien. On les préserve par un export complet, avec son empreinte, plutôt que par une recherche filtrée : un filtre écrit le 14 mars sur les mots « svc_backup » aurait laissé de côté les autres comptes, alors qu'on ne savait pas encore lesquels l'attaquant avait utilisés.

Les données détenues par des tiers (opérateur de paiement mobile, fournisseur d'accès, hébergeur, éditeur d'un service en nuage) ne se copient pas : on les demande, et en matière pénale on les requiert. Le Chapitre 8 précise les fondements de ces demandes. Deux réflexes valent dans tous les cas : demander très tôt la conservation des données, avant même leur communication, et demander comment elles ont été extraites.

3.6 Les Acquisitions de NYANGA

Scénario Opérationnel · Opération NYANGA. Trois serveurs, trois méthodes

Constatations.

- SRV-AD01 : capture mémoire à chaud le 14 mars (NC-01) ; le serveur, indispensable à toutes les connexions, est ensuite remplacé par un contrôleur de secours, puis acquis à froid le 16 mars.
- SRV-CPT01 : non chiffré ; arrêt contrôlé le 15 mars à 15 h 55, acquisition à froid par bloqueur matériel de 16 h 00 à 19 h 25, au format E01 (NC-03) ; aucun secteur illisible.
- SRV-FIC01 : volume de données chiffré par BitLocker, clé chez le prestataire ; capture mémoire puis copie logique du volume déverrouillé, à chaud, le 18 mars (NC-07) ; la clé de récupération arrive le 22 mars et permet une acquisition à froid complémentaire.

Analyse (confiance élevée). Les trois choix sont justifiés par ce que chaque méthode aurait fait perdre. L'acquisition à chaud de SRV-FIC01 a modifié la machine (outil exécuté, fichiers temporaires) ; ces modifications sont consignées heure par heure, ce qui permet de les écarter de l'analyse. L'acquisition complémentaire du 22 mars confirme que la copie logique du 18 contenait bien tous les fichiers du volume.

Artefact · Image du disque de SRV-CPT01, 15 mars 2025

Source : serveur SRV-CPT01, disque système de 500 Go.
Pièce : image E01, scellé NC-03, copie de travail séparée.
Méthode : arrêt contrôlé, bloqueur matériel vérifié le matin même, acquisition de 16 h 00 à 19 h 25 ; empreinte SHA-256 de la source et de l'image identiques.
Ce qu'elle peut prouver : les fichiers présents et supprimés, leurs dates, les journaux Windows, les traces d'exécution de programmes.
Ce qu'elle ne prouve pas : ce qui était en mémoire avant l'arrêt du 15 mars, ni ce qui s'est passé sur d'autres serveurs.

Lecture auditologique · Les acquisitions de NYANGA au 22 mars

Question	SRV-AD01	SRV-CPT01	SRV-FIC01
Mémoire capturée avant arrêt	OUI	NON	OUI
Disque acquis sans altération	OUI	OUI	OUI
Altérations éventuelles documentées	OUI	OUI	OUI
Complétude de l'image vérifiée	OUI	OUI	OUI

Lecture. Une seule cote NON : la mémoire de SRV-CPT01 n'a pas été capturée avant son arrêt. L'enquête ne pourra donc pas savoir si un programme de l'attaquant y tournait encore le 15 mars. C'est une limite, et le rapport la mentionne.

3.7 Ce que l'Acquisition demande à chaque Métier

Application Analyste en réponse à incident

Avoir, avant l'incident, une trousse prête : bloqueur matériel vérifié, disques neufs, outils de capture mémoire sur un support en lecture seule, formulaires imprimés. On n'improvise pas une acquisition à trois heures du matin.

Application Application OPJ/Expert Judiciaire

Quand l'acquisition a été faite par d'autres, l'expert ne la refait pas nécessairement ; il la contrôle : journal de l'outil, empreintes, bloqueur, méthode. S'il refait une acquisition, il explique pourquoi.

Application RSSI

Conserver, hors des machines, les clés de récupération des volumes chiffrés, dans un coffre accessible à l'équipe de crise. À NYANGA, quatre jours ont été perdus à attendre une clé détenue par un prestataire.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

➢ On recueille de la trace la plus volatile à la moins volatile ; les journaux soumis

à rotation sont plus fragiles qu'ils ne paraissent.

- ➢ Le choix entre froid et chaud se décide d'après ce que l'on perdrait, et se justifie par écrit.
- ➢ Un disque s'acquiert derrière un bloqueur d'écriture vérifié, dans un format qui garde les métadonnées, et l'acquisition se vérifie.
- ➢ Une capture mémoire ne se répète pas : on documente l'outil, l'heure et l'empreinte laissée sur la machine.
- ➢ À NYANGA, trois serveurs ont reçu trois méthodes différentes, chacune justifiée ; la mémoire de SRV-CPT01 manque.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- ➢ classer des traces selon leur volatilité ;
- ➢ choisir et justifier une méthode d'acquisition ;
- ➢ lire le journal d'un outil d'acquisition et y repérer ce qui compte.

Exercices

✍ Exercice 3.1. Classer par volatilité ★☆☆

Classez de la plus volatile à la moins volatile : (a) le journal de la passerelle, conservé 60 jours ; (b) la table ARP du contrôleur de domaine ; (c) le fichier d'échange de SRV-CPT01 ; (d) les sauvegardes sur bande de février ; (e) les connexions réseau ouvertes de SRV-FIC01 ; (f) la capture de la sonde, conservée 48 heures.

✍ Exercice 3.2. Choisir la méthode ★★☆

Pour chaque situation, proposez une méthode d'acquisition et justifiez-la par ce que l'on perdrait avec l'autre :

(a) un portable d'agent, éteint, saisi dans un sac ;

(b) le serveur de l'interface de paiement, qui ne peut pas s'arrêter plus de dix minutes ;

(c) une machine virtuelle hébergée sur l'hyperviseur du siège ;

(d) la messagerie de l'établissement, hébergée par un fournisseur en nuage.

✍ Exercice 3.3. Lire un journal d'acquisition ★★☆

Le journal d'une acquisition indique : « Source : 500 107 862 016 octets. Secteurs lus avec erreur : 384. Remplacés par des zéros. Empreinte SHA-256 de l'image : 9f3c… Vérification : empreinte de l'image identique à l'empreinte calculée pendant l'acquisition. »

(a) L'image est-elle intègre ? Est-elle complète ?

(b) Quelle taille de données est perdue, si les secteurs font 512 octets ?

(c) Comment le rapport doit-il présenter ce fait ?

✍ Exercice 3.4. SRV-FIC01 à chaud ★★★

(a) Rédigez la justification écrite du choix d'une acquisition à chaud de SRV-FIC01 le 18 mars.

(b) Listez les traces que l'acquisition à chaud a pu laisser sur la machine, et dites comment les distinguer de celles de l'attaquant.

(c) La clé BitLocker arrive le 22 mars. Que permet l'acquisition à froid complémentaire, et quelle comparaison faites-vous entre les deux copies ?

Note

Pour aller plus loin.

- La RFC 3227 [4] et l'ISO/IEC 27037 [19].
- B. Carrier, *File System Forensic Analysis* [5], chapitre sur l'acquisition.

Note

Transition. L'image du disque de SRV-CPT01 est sous scellé, sa copie de travail est prête. Que contient-elle ? Le Chapitre 4 apprend à lire un système de fichiers et ses artefacts.

4

L'ANALYSE DU DISQUE

« Supprimer un fichier, pour un système de fichiers,
c'est d'abord oublier où il se trouvait. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise du Chapitre 3

✦ Objectifs du chapitre

- ➢ Lire la structure d'un disque : table de partitions, volumes, système de fichiers.
- ➢ Expliquer comment NTFS enregistre un fichier, ses dates et sa suppression.
- ➢ Récupérer un fichier supprimé par ses métadonnées ou par ses signatures.
- ➢ Exploiter les artefacts Windows qui prouvent une connexion, une exécution ou l'ouverture d'un fichier.
- ➢ Interpréter un horodatage avec son fuseau et ses limites.

Avant de commencer : la question posée au disque

Yaoundé, laboratoire de SANKOFA EXPERTISE, 19 mars 2025. La copie de travail de l'image de SRV-CPT01 est montée en lecture seule. Le disque compte un peu plus de 300 000 fichiers. Mme MBARGA n'ouvre pas l'outil d'analyse au hasard : elle écrit d'abord trois questions. L'attaquant s'est-il connecté à ce serveur, et quand ? A-t-il ouvert le fichier qui contient la clé de l'interface de paiement ? A-t-il copié quelque chose et effacé ses traces ?

★ Attention

Violation typique. Parcourir l'arborescence d'une image en espérant « tomber sur quelque chose », puis présenter ce que l'on a trouvé comme le résultat d'un examen complet.

Règle : on examine un disque pour répondre à des questions écrites d'avance, en choisissant les artefacts capables d'y répondre, et l'on dit pour chaque question quelles sources ont été lues.

4.1 Du Disque au Fichier

Un disque se lit par couches. La **table de partitions** (MBR sur les anciens systèmes, GPT sur les récents) découpe le disque en volumes. Chaque volume porte un **système de fichiers**, qui organise les données en fichiers et en répertoires : NTFS sous Windows, ext4 sous la plupart des Linux, APFS sous macOS. L'espace d'un volume se répartit entre les données allouées, les métadonnées du système de fichiers, et l'espace non alloué, qui contient souvent les restes de fichiers supprimés.

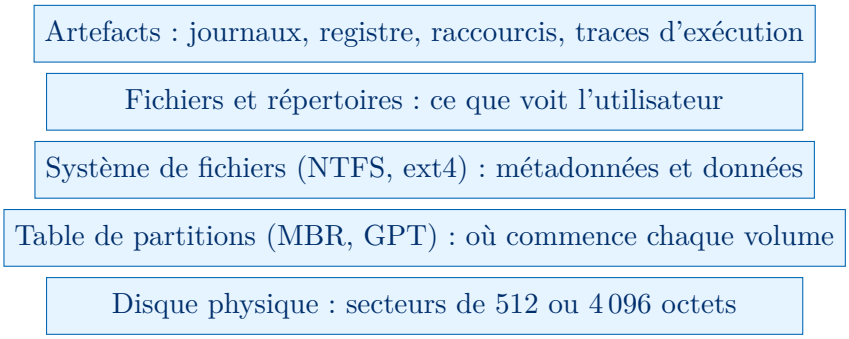


Figure 4.1. Les couches de lecture d'un disque

4.2 NTFS : la Table MFT et les Dates

NTFS décrit chaque fichier dans un enregistrement de la **table MFT** (*Master File Table*). Un enregistrement contient des attributs : le nom, les dates, la taille et l'emplacement des données sur le disque. Les petits fichiers, de quelques centaines d'octets, tiennent même entièrement dans leur enregistrement.

4.2.1 Deux jeux de quatre dates

Chaque fichier porte quatre dates : modification du contenu (M), dernier accès (A), modification de l'enregistrement MFT (C), et création (B). On les note MACB. NTFS les enregistre deux fois : dans l'attribut `$STANDARD_INFORMATION`, que les programmes modifient librement, et dans l'attribut `$FILE_NAME`, que seul le système met à jour lors de certaines opérations (création, renommage, déplacement). Un écart incohérent entre les deux jeux est l'un des signes d'une falsification des dates, étudiée au Chapitre 13.

Note

La date d'accès ne vaut pas grand-chose. Les versions récentes de Windows ne mettent pas toujours à jour la date de dernier accès, pour des raisons de performance, et un antivirus qui lit un fichier la modifie. On ne fonde jamais une conclusion « l'attaquant a ouvert ce fichier » sur la seule date d'accès.

4.2.2 Les journaux de NTFS

Le journal `$UsnJrnl` enregistre les changements des fichiers (création, renommage, suppression), avec leur heure, tant que sa taille le permet. Il permet de savoir qu'un fichier a existé, sous quel nom, et quand il a été supprimé, même si son enregistrement MFT a été réutilisé.

4.3 Les Fichiers Supprimés

Supprimer un fichier, sous NTFS, revient à marquer son enregistrement MFT et ses blocs comme libres. Les données restent sur le disque jusqu'à ce qu'un autre fichier les écrase. Deux méthodes permettent de les retrouver.

Méthode	Principe	Limite
Par les métadonnées	L'enregistrement MFT libre indique encore le nom, les dates et l'emplacement des données	Échoue si l'enregistrement a été réutilisé
Par les signatures (*carving*)	On cherche dans l'espace non alloué les octets qui marquent le début d'un format (`PK` pour une archive ZIP, `7z` pour une archive 7-Zip, `%PDF` pour un PDF)	Ni nom ni date ; fichiers fragmentés mal reconstitués

Tableau 4.1. Deux façons de récupérer un fichier

Sur un disque SSD, la commande TRIM réduit fortement les chances de récupération (Chapitre 3). Sur un serveur virtualisé, le comportement dépend de l'hyperviseur.

4.4 Les Artefacts Windows

Un **artefact** est une trace qu'un système laisse en fonctionnant normalement, sans qu'on lui demande de garder une preuve : une entrée de journal, une clé de registre, un raccourci. L'enquêteur les choisit d'après la question.

Question	Artefact	Ce qu'il dit
Qui s'est connecté, quand, comment ?	Journal de sécurité : événements 4624 (ouverture réussie), 4625 (échec), type d'ouverture 10 pour le bureau à distance	Compte, heure, adresse d'origine
Quel programme a été exécuté ?	Événement 4688 si l'audit est activé ; Amcache ; Prefetch sur les postes de travail	Nom, chemin, heure, parfois empreinte
Quel service a été installé ?	Événement 7045 du journal système	Nom du service, binaire, compte
Quel fichier a été ouvert ?	Raccourcis `.lnk` du dossier `Recent`, listes de raccourcis, clés `RecentDocs` du registre de l'utilisateur	Chemin du fichier, heure d'ouverture
Le journal a-t-il été effacé ?	Événement 1102	Effacement du journal de sécurité, compte qui l'a fait
Un compte a-t-il été créé ?	Événement 4720	Nom du compte, créateur

Tableau 4.2. Questions et artefacts Windows

Deux précautions accompagnent ce tableau. Les artefacts dépendent de la configuration : le Prefetch, utile sur un poste de travail, est désactivé par défaut sur les versions serveur de Windows, et l'événement 4688 n'existe que si l'audit de la création de processus a été activé. Et chaque artefact dit moins qu'il ne paraît : une entrée Amcache prouve qu'un programme était présent et a été vu par le système, pas toujours qu'il a été exécuté à l'heure indiquée. On croise donc les artefacts entre eux.

4.5 Ce que dit le Disque de SRV-CPT01

Scénario Opérationnel · Opération NYANGA. Trois questions, trois réponses

Question 1 : connexion. Le journal de sécurité contient, le 12 mars 2025 à 22 h 39, un événement 4624 de type 10 pour le compte `adm.kamga`, depuis l'adresse interne de SRV-AD01. Aucune ouverture de ce compte sur SRV-CPT01 n'existe dans les trente jours précédents.

Question 2 : ouverture du fichier de clé. Le dossier `Recent` du profil `adm.kamga` contient un raccourci `api.ini.lnk`, créé le 12 mars à 22 h 44, qui pointe vers `C:\PaySuite\conf\api.ini`. La clé `RecentDocs` du registre de l'utilisateur cite le même fichier.

Question 3 : copie et effacement. Le journal `$UsnJrnl` enregistre la création,

à 22 h 52, d'un fichier `cpt.7z` dans le dossier temporaire de l'utilisateur, puis sa suppression à 23 h 06. L'enregistrement MFT est libre mais intact : l'archive est récupérée, 41 Mo, protégée par un mot de passe. Sa liste de fichiers, lisible sans le mot de passe, comprend `api.ini` et le dossier des exports comptables de février.

Analyse (confiance élevée). Le compte `adm.kamga` a été utilisé depuis le contrôleur de domaine pour ouvrir le fichier de clé, puis pour l'archiver avec des exports comptables, avant d'effacer l'archive. Le journal de sécurité ne montre aucun effacement (pas d'événement 1102) : l'attaquant a supprimé son archive, pas les journaux.

Artefact · Raccourci api.ini.lnk, profil adm.kamga, SRV-CPT01

Source : image NC-03, volume système, `Users\adm.kamga\AppData\Roaming\Microsoft\Windows`
Contenu : chemin de la cible, taille et dates de la cible au moment de l'ouverture, nom et numéro de série du volume, dates propres du raccourci (création le 12/03/2025 à 22 h 44).
Ce qu'il prouve : qu'une session du profil `adm.kamga` a ouvert `api.ini` à cette heure, par l'interface de Windows.
Ce qu'il ne prouve pas : qui était assis devant l'écran ; il ne dit pas non plus que la clé a été lue en entier ni recopiée.

Lecture auditologique · Les trois questions au disque de SRV-CPT01

Proposition	Cote	Sources
Le compte `adm.kamga` s'est connecté le 12 mars à 22 h 39	OUI	4624 type 10
La connexion venait de SRV-AD01	OUI	4624 (adresse source)
Le fichier `api.ini` a été ouvert dans cette session	OUI	`.lnk`, `RecentDocs`
La clé a été copiée hors du serveur	NEK	Archive créée, aucune trace de transfert sur ce disque
Les journaux de SRV-CPT01 ont été effacés	NON	Pas de 1102, journal continu
M. KAMGA lui-même était aux commandes	NEK	Aucune pièce sur la personne

Lecture. Trois OUI, un NON, deux NEK. Le disque répond aux questions de connexion et d'ouverture ; il ne répond pas à celle du transfert, qui relève de l'analyse

du réseau (Chapitre 6).

4.6 Les Heures et leurs Pièges

NTFS enregistre ses dates en temps universel (UTC). L'outil d'analyse les affiche souvent dans le fuseau de la station d'examen, et les journaux Windows dans celui que l'on choisit. Le Cameroun est à UTC+1, sans heure d'été. Une heure lue sans son fuseau peut donc être fausse d'une heure, et une chronologie qui mélange les deux devient incohérente.

Piège	Parade
Fuseau implicite	Noter le fuseau de chaque source, convertir tout en UTC dans les notes de travail
Horloge déréglée	Mesurer la dérive (heure système contre heure de référence) au moment de l'acquisition
Date modifiée par l'attaquant	Comparer `$STANDARD_INFORMATION` et `$FILE_NAME`, recouper avec `$UsnJrnl` et les journaux
Résolution différente	Les journaux à la seconde, NTFS à la centaine de nanosecondes : on compare à la précision la plus faible

Tableau 4.3. Les pièges de l'heure

À NYANGA CRÉDIT, les serveurs se synchronisaient sur un serveur de temps interne, lui-même calé sur une source publique ; la dérive mesurée le 15 mars sur SRV-CPT01 était de 2 secondes. Les heures du chapitre sont données en heure locale (UTC+1), comme partout dans le livre.

4.7 Ce que l'Analyse du Disque demande à chaque Métier

Application Analyste en réponse à incident

Examiner un disque

1. Écrire les questions avant d'ouvrir l'image.
2. Pour chaque question, choisir les artefacts et vérifier qu'ils existent dans cette configuration.
3. Croiser au moins deux artefacts indépendants pour chaque conclusion.
4. Noter le fuseau de chaque heure.
5. Dire, pour chaque question, ce qui a été lu et ce qui ne l'a pas été.

Application Application OPJ/Expert Judiciaire

L'expert sépare ce que le disque établit sur un compte de ce qu'il ne dit pas sur une personne. « Le compte `adm.kamga` a ouvert le fichier » est une constatation ; « M. KAMGA a ouvert le fichier » n'en est pas une.

Application RSSI

Activer, avant tout incident, l'audit de la création de processus et dimensionner les journaux pour qu'ils couvrent au moins trois mois. Sans l'événement 4688, l'enquête de NYANGA a dû se contenter d'Amcache pour dater les exécutions.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Un disque se lit par couches : partitions, système de fichiers, fichiers, artefacts.
- NTFS garde deux jeux de dates (`$STANDARD_INFORMATION` et `$FILE_NAME`) ; la date d'accès est peu fiable.
- Un fichier supprimé se récupère par ses métadonnées tant que l'enregistrement n'est pas réutilisé, sinon par ses signatures.
- Les artefacts Windows répondent à des questions précises ; ils dépendent de la configuration et se croisent.
- À NYANGA, le disque établit la connexion de `adm.kamga` depuis SRV-AD01 et l'ouverture du fichier de clé ; le transfert reste NEK sur ce seul disque.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- citer l'artefact qui répond à une question donnée ;
- expliquer pourquoi un fichier supprimé est souvent récupérable ;
- convertir une heure entre UTC et l'heure du Cameroun, et dire pourquoi c'est nécessaire.

Exercices

✍ Exercice 4.1. Quel artefact ? ★☆☆

Pour chaque question, citez l'artefact Windows qui y répond le mieux : (a) un compte a-t-il été créé le 9 mars sur SRV-AD01 ? (b) quelqu'un s'est-il connecté par le bureau à distance ? (c) un service inconnu a-t-il été installé ? (d) le journal de sécurité a-t-il été vidé ? (e) quel document Word l'utilisateur a-t-il ouvert en dernier ?

✍ Exercice 4.2. Récupérer cpt.7z ★★☆

(a) Expliquez pourquoi l'archive `cpt.7z` a pu être récupérée avec son nom et ses dates.

(b) Si l'enregistrement MFT avait été réutilisé, quelle méthode resterait-il, et qu'aurait-on perdu ?

(c) L'archive est chiffrée. Que peut-on en tirer sans le mot de passe, et que faire pour l'obtenir ?

✍ Exercice 4.3. Deux heures pour un fichier ★★☆

L'outil d'analyse affiche, pour `api.ini.lnk`, une création à « 21:44:07 », sans indication de fuseau. Le journal de sécurité, exporté en heure locale, donne l'ouverture de session à 22:39:12.

(a) Le raccourci a-t-il été créé avant l'ouverture de session ?

(b) Comment lever le doute ?

(c) Réécrivez les deux heures en UTC et en heure du Cameroun.

✍ Exercice 4.4. Du compte à la personne ★★★

Le directeur général lit l'encadré « Les trois questions au disque de SRV-CPT01 » et demande : « Donc M. KAMGA est coupable ? »

(a) Répondez-lui en séparant constatation et analyse.

(b) Quelles pièces, sur ce disque ou ailleurs, pourraient faire passer la dernière ligne de NEK à OUI ou à NON ?

(c) Quelle pièce du Chapitre 1 rend déjà peu probable une action de M. KAMGA depuis le siège ?

● Note

Pour aller plus loin.

➢ B. Carrier, *File System Forensic Analysis* [5], pour NTFS et ext.

➢ The Sleuth Kit et Autopsy [6], outils libres d'analyse de disque.

Note

Transition. La session de `adm.kamga` venait du contrôleur de domaine. Comment l'attaquant y a-t-il obtenu ces identifiants ? La réponse est dans la mémoire de SRV-AD01 : Chapitre 5.

5

L'ANALYSE DE LA MÉMOIRE

« Un programme peut effacer son fichier.
Il ne peut pas tourner sans être en mémoire. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise des Chapitres 3 et 4

✦ Objectifs du chapitre

- Expliquer ce que la mémoire vive contient et que le disque ne garde pas.
- Identifier le profil d'une capture et en vérifier la cohérence.
- Lister les processus par deux méthodes et interpréter leurs écarts.
- Repérer un processus anormal par son parent, son chemin et sa ligne de commande.
- Relier un processus à ses connexions réseau et à sa persistance.
- Reconnaître les traces d'un vol d'identifiants, sans en reproduire la technique.

Avant de commencer : un svchost de trop

Yaoundé, 22 mars 2025. M. ABOUBAKAR, l'expert réquisitionné par le procureur, a reçu le scellé NC-01, l'a ouvert devant témoin, a vérifié son empreinte et travaille sur sa copie : 16 Go de mémoire du contrôleur de domaine, capturés le 14 mars à 10 h 02. Il compte, dans la liste des processus, quatorze `svchost.exe`. Treize sont lancés depuis `C:\Windows\System32`. Le quatorzième tourne depuis `C:\ProgramData`, et il est le seul à entretenir une connexion vers l'extérieur.

★ Attention

Violation typique. Conclure qu'un processus est légitime parce que son nom est celui d'un programme du système.

Règle : un processus se juge sur son chemin, son parent, sa ligne de commande, son heure de démarrage et son comportement réseau, comparés à ce qu'on attend de ce programme. Le nom est le premier attribut qu'un attaquant imite.

5.1 Ce que la Mémoire Contient

La mémoire vive d'un serveur Windows contient, à l'instant de la capture, l'état complet du système : les processus et leurs fils d'exécution, les bibliothèques chargées, les connexions réseau, les objets ouverts (fichiers, clés de registre), le cache des fichiers, une partie du registre, et les données que les programmes manipulent, y compris des mots de passe, des clés de chiffrement et des commandes saisies. Certains programmes malveillants n'existent qu'en mémoire : ils sont chargés depuis le réseau, ou injectés dans un processus légitime, sans jamais être écrits sur le disque.

Question	Mémoire	Disque
Quels programmes tournaient ?	Oui, avec leurs parents	Indirectement (Amcache, journaux)
Quelles connexions étaient ouvertes ?	Oui, avec le processus	Non
Quelle ligne de commande ?	Oui	Seulement si l'audit l'enregistre
Code injecté dans un processus ?	Oui	Rarement
Ce qui s'est passé il y a un mois ?	Non	Oui, par les journaux et les dates

Tableau 5.1. Mémoire et disque : deux sources complémentaires

5.2 L'Outil et la Méthode

L'outil de référence, libre, est Volatility, dans sa version 3 [48]. Il reconstruit les structures du système d'exploitation à partir de la capture brute, grâce à des tables de symboles propres à chaque version du noyau. On l'emploie greffon par greffon, chacun répondant à une question.

Greffon	Question
`windows.info`	La capture est-elle lisible, de quelle version de Windows, à quelle heure système ?
`windows.pslist`	Quels processus figurent dans la liste tenue par le noyau ?
`windows.psscan`	Quelles structures de processus trouve-t-on en balayant toute la mémoire, y compris des processus terminés ou cachés ?
`windows.pstree`	Qui a lancé qui ?
`windows.cmdline`	Avec quelle ligne de commande ?
`windows.netscan`	Quelles connexions et quels ports, rattachés à quel processus ?
`windows.malfind`	Quelles zones de mémoire exécutables et modifiables, sans fichier associé, suggèrent une injection de code ?
`windows.svcscan`	Quels services sont enregistrés, avec quel binaire ?

Tableau 5.2. Les greffons de base de Volatility 3

5.2.1 Deux listes de processus

Windows tient la liste des processus actifs dans une liste chaînée de structures `EPROCESS`. Le greffon `pslist` suit cette liste. Le greffon `psscan`, lui, cherche ces structures partout dans la capture, par leur forme. La comparaison des deux est instructive : un processus présent dans `psscan` et absent de `pslist` est soit terminé (sa structure traîne encore en mémoire, avec une heure de fin), soit caché par un programme qui l'a retiré de la liste. Le premier cas est banal ; le second est un signe fort de compromission.

5.2.2 Le processus normal

Pour juger un processus, on compare ses attributs à ce que l'on sait des processus du système. Quelques repères suffisent pour les plus imités.

Nom	Chemin attendu	Parent attendu	Nombre
`lsass.exe`	`System32`	`wininit.exe`	Un seul
`services.exe`	`System32`	`wininit.exe`	Un seul
`svchost.exe`	`System32`	`services.exe`	Plusieurs
`explorer.exe`	`Windows`	Variable (lancé à la session)	Un par session

Tableau 5.3. Quelques processus et leurs attributs attendus

5.3 Ce que la Mémoire de SRV-AD01 Révèle

Scénario Opérationnel · Opération NYANGA. Le processus 4412

Constatations (copie de NC-01, Volatility 3).

- `windows.info` : Windows Server 2019, heure système de la capture 14/03/2025 09:02:11 UTC, soit 10:02:11 heure locale, cohérente avec le registre des actions.
- `pslist` et `psscan` : quatorze processus `svchost.exe` ; le PID 4412 a pour chemin `C:\ProgramData\WinUpd\svchost.exe`, pour parent `services.exe`, et a démarré le 09/03 à 1 h 35.
- `svcscan` : un service `WinUpdSvc`, en démarrage automatique, a pour binaire ce même fichier.
- `netscan` : le PID 4412 maintient une connexion établie vers 203.0.113.47, port 443.
- `malfind` : aucune zone suspecte dans `lsass.exe` ; deux zones exécutables sans fichier associé dans le PID 4412.

Analyse (confiance élevée). Le PID 4412 est un programme étranger au système, déguisé sous le nom `svchost.exe`, installé comme service pour redémarrer avec la machine, et en communication avec l'adresse vers laquelle sont partis les 3,2 Go. C'est l'outil d'accès à distance de l'attaquant sur le contrôleur de domaine.

Le parent `services.exe` ne disculpe pas le processus : un service est toujours lancé par `services.exe`, y compris un service créé par un attaquant. C'est le chemin qui trahit le PID 4412, et le service qui explique son parent.

Artefact · Processus 4412, capture mémoire de SRV-AD01

Source : scellé NC-01, copie de travail, Volatility 3.
Attributs : nom `svchost.exe` ; chemin `C:\ProgramData\WinUpd` ; parent `services.exe` ; démarrage 09/03/2025 1 h 35 ; service `WinUpdSvc` ; connexion vers 203.0.113.47:443.
Ce qu'il prouve : la présence, le 14 mars, d'un programme persistant étranger au système, en communication avec l'adresse de l'exfiltration.
Ce qu'il ne prouve pas : comment le programme est arrivé sur la machine, ni qui le pilotait.

5.4 Le Vol d'Identifiants

Sous Windows, le processus `lsass.exe` gère les authentifications et garde en mémoire des éléments d'identification des sessions ouvertes. Un attaquant qui obtient les droits d'administration sur une machine peut copier la mémoire de ce processus dans un fichier, puis l'emporter et l'analyser chez lui pour en extraire des identifiants. Le cours ne décrit pas la technique d'extraction : elle relève de l'UE MSN-2S3-SEC03. Il apprend à en

reconnaître les traces.

Trace	Où la chercher
Fichier de vidage (`.dmp`) de `lsass.exe`	Disque : `$UsnJrnl`, MFT, dossiers temporaires
Ligne de commande d'un outil de vidage	Mémoire (`cmdline`) si le processus tourne encore ; événement 4688 si l'audit est actif
Accès au processus `lsass.exe` par un autre processus	Journaux de surveillance avancée, s'ils existent
Réutilisation des identifiants	Ouvertures de session du compte volé depuis des machines inhabituelles (4624)

Tableau 5.4. Les traces d'un vol d'identifiants

Scénario Opérationnel · Opération NYANGA. Le fichier du 9 mars

Constatations. Sur l'image du disque de SRV-AD01 (acquise le 16 mars), le `$UsnJrnl` enregistre la création, le 9 mars à 1 h 37, d'un fichier `lsass.dmp` de 54 Mo dans `C:\Windows\Temp`, et sa suppression à 1 h 49. Le journal système enregistre, à 1 h 35, la création du service `WinUpdSvc` (événement 7045) par le compte `svc_backup`. À partir du 10 mars, le compte `adm.kamga` ouvre des sessions depuis SRV-AD01 vers les autres serveurs.

Analyse (confiance élevée). L'attaquant, entré sous `svc_backup`, a installé son outil le 9 mars, copié la mémoire de `lsass.exe` deux minutes plus tard, puis utilisé les identifiants de `adm.kamga`, présents en mémoire parce que l'administrateur s'était connecté au contrôleur de domaine dans les jours précédents. Cette séquence explique l'usage du compte sans la participation de son titulaire ; elle ne l'exclut pas.

Lecture auditologique · La mémoire de SRV-AD01 et le disque associé

Proposition	Cote
Un programme étranger tournait sur SRV-AD01 le 14 mars	OUI
Il communiquait avec 203.0.113.47	OUI
Il était installé comme service depuis le 9 mars	OUI
La mémoire de `lsass.exe` a été copiée le 9 mars	OUI
Les identifiants de `adm.kamga` ont été extraits de cette copie	NEK
Du code a été injecté dans `lsass.exe`	NON

Lecture. Quatre OUI, un NON, un NEK. L'extraction des identifiants depuis la copie reste NEK : elle a eu lieu hors du système, chez l'attaquant, et aucune pièce ne peut la montrer. On l'infère de la séquence, avec une confiance élevée, mais on ne la constate pas.

5.5 Les Limites de l'Analyse Mémoire

- Une capture est un instantané : elle ne dit rien de ce qui a tourné puis s'est terminé, sauf traces résiduelles.
- Les tables de symboles doivent correspondre exactement à la version du noyau ; une version inconnue de l'outil donne des résultats faux ou vides.
- La capture elle-même peut être incohérente, parce que la mémoire a changé pendant qu'on la lisait : des structures à moitié copiées apparaissent.
- Les zones signalées par `malfind` ne sont pas toutes malveillantes : certains programmes légitimes (machines virtuelles Java, navigateurs) génèrent du code en mémoire.

5.6 Ce que l'Analyse Mémoire demande à chaque Métier

Application Analyste en réponse à incident

Examiner une capture mémoire

1. Vérifier le profil et l'heure système avec `windows.info`.
2. Comparer `pslist` et `psscan`.
3. Examiner l'arbre des processus, les chemins et les lignes de commande.
4. Rattacher chaque connexion à son processus.
5. Chercher la persistance (services, tâches) du processus suspect.
6. Confirmer chaque découverte par une autre source (disque, réseau).

Application Application OPJ/Expert Judiciaire

L'expert indique la version de l'outil et des tables de symboles, la liste des greffons et leur ordre, et conserve leurs sorties brutes en annexe : un autre expert doit pouvoir refaire l'examen sur la même copie et obtenir les mêmes listes.

Application RSSI

Limiter les connexions des comptes d'administration du domaine aux seules machines d'administration : un identifiant qui ne se trouve pas en mémoire d'un serveur ne peut pas y être volé.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- La mémoire montre ce qui tournait, avec quels parents, quelles commandes et quelles connexions ; le disque montre l'histoire.
- Volatility s'emploie greffon par greffon, chacun répondant à une question ; `pslist` et `psscan` se comparent.
- Un processus se juge sur son chemin, son parent, sa commande, son heure et son réseau, jamais sur son nom.
- Le vol d'identifiants se reconnaît à ses traces (fichier de vidage, réutilisation du compte) ; l'extraction elle-même reste souvent NEK.
- À NYANGA, le PID 4412, faux `svchost.exe` installé comme service le 9 mars, communique avec 203.0.113.47.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- interpréter un écart entre `pslist` et `psscan` ;
- dire pourquoi un processus est suspect à partir de ses attributs ;
- distinguer ce qui est constaté de ce qui est inféré dans un vol d'identifiants.

Exercices

✍ Exercice 5.1. Normal ou suspect ★☆☆

Pour chaque processus, dites s'il est normal ou suspect, et pourquoi : (a) `lsass.exe`, `System32`, parent `wininit.exe` ; (b) `lsass.exe`, `System32`, parent `explorer.exe` ; (c) `svchost.exe`, `System32`, parent `services.exe` ; (d) `svchost.exe`, `Users\Public`, parent `cmd.exe` ; (e) deux processus `lsass.exe`.

✍ Exercice 5.2. pslist et psscan ★★☆

`psscan` trouve trois processus absents de `pslist` : un `rundll32.exe` terminé le 9 mars à 1 h 38 ; un `cmd.exe` terminé le 13 mars ; un `svch0st.exe` sans heure de fin.

(a) Interprétez chacun.

(b) Lequel demande une vérification immédiate, et laquelle ?

(c) Que pourrait apporter la ligne de commande du `rundll32.exe`, si elle est encore

lisible ?

✍ Exercice 5.3. Relier les sources ★★☆

Construisez un tableau qui relie, pour le PID 4412, chaque attribut constaté en mémoire à une confirmation sur le disque de SRV-AD01 ou dans la capture réseau. Indiquez pour chaque ligne si la confirmation existe, manque, ou reste à chercher.

✍ Exercice 5.4. Ce qu'on ne peut pas montrer ★★★

L'avocat de M. KAMGA soutient que la copie de la mémoire de `lsass.exe` « ne prouve pas » le vol de ses identifiants.

(a) A-t-il raison sur le plan de la constatation ? Sur celui de l'analyse ?

(b) Rédigez le passage du rapport d'expertise qui traite ce point.

(c) Quelle mesure, en place avant l'incident, aurait permis de constater l'usage des identifiants volés plutôt que de l'inférer ?

Note

Pour aller plus loin.

- M. H. Ligh et al., *The Art of Memory Forensics* [32].
- La documentation de Volatility 3 [48].

Note

Transition. Le PID 4412 parle à 203.0.113.47. Qu'a-t-il envoyé, et quand ? La capture de la sonde réseau le dit : Chapitre 6.

6

L'ANALYSE DU RÉSEAU

« Le chiffrement cache le contenu.
Il ne cache ni la taille, ni l'heure, ni la destination. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise des Chapitres 3 et 5

✦ Objectifs du chapitre

- Distinguer les sources réseau : capture complète, flux, journaux d'équipements, alertes de sonde.
- Lire une capture avec un analyseur de paquets et en extraire les conversations utiles.
- Caractériser une exfiltration par le volume, la durée, le débit et la destination.
- Reconnaître une balise de commande par sa régularité.
- Tirer d'un flux chiffré tout ce qu'il dit sans être déchiffré.
- Dire ce que l'absence d'un flux dans une capture établit, et ce qu'elle n'établit pas.

Avant de commencer : 48 heures de trafic

Yaoundé, 24 mars 2025. La capture de la sonde de NYANGA CRÉDIT (scellé NC-04) couvre le lien Internet du siège du 13 mars à 8 h au 14 mars à 8 h : 37 Go de paquets. M. FOTSO, analyste de SANKOFA EXPERTISE, a trois questions de Mme MBARGA : qu'est-ce qui est sorti, vers où, et à quel moment ; le programme du contrôleur de domaine parlait-il à la même adresse ; les virements de la nuit sont-ils passés par ce lien ?

★ Attention

Violation typique. Conclure qu'un échange n'a pas eu lieu parce qu'on ne le trouve pas dans la capture.

© MaletYon

Règle : une capture ne voit que ce qui passe par le point où elle est placée, pendant la période qu'elle couvre. Avant d'écrire « aucun flux vers telle adresse », on dit où était la sonde, ce qu'elle voyait, et si le flux pouvait emprunter un autre chemin.

6.1 Quatre Sources Réseau

Source	Contenu	Durée typique	Limite
Capture complète (PCAP)	Tous les paquets, en-têtes et contenu	Heures à jours (volume)	Coût de stockage ; contenu souvent chiffré
Flux (NetFlow, IPFIX)	Qui a parlé à qui, quand, combien d'octets	Mois	Pas de contenu
Journaux d'équipements	Pare-feu, proxy, DNS : décisions et requêtes	Semaines à mois	Ce que l'équipement a jugé utile de noter
Alertes de sonde	Événements jugés suspects par des règles	Mois	Ne voit que ce que les règles décrivent

Tableau 6.1. Les sources de l'analyse réseau

R. Bejtlich, dans son ouvrage sur la supervision de la sécurité réseau [3], montre que ces sources se complètent : les flux et les journaux couvrent une longue période sans contenu, la capture complète couvre une période courte avec tout le détail. Une enquête commence souvent par les flux, pour repérer la fenêtre utile, puis descend dans la capture.

6.2 Lire une Capture

L'analyseur de paquets Wireshark, et sa version en ligne de commande tshark, décodent les protocoles et regroupent les paquets en **conversations** (une paire d'adresses et de ports). Les outils de supervision comme Zeek transforment une capture en journaux par protocole : connexions, requêtes DNS, échanges TLS, transferts HTTP. On travaille dans cet ordre.

1. Les statistiques de conversations : quelles paires ont échangé le plus d'octets, dans quel sens.
2. Les requêtes DNS : quels noms ont été résolus, vers quelles adresses.

3. Les échanges TLS : nom de serveur annoncé (SNI), certificat présenté, versions.
4. Le détail des paquets, seulement pour les conversations retenues.

Note

Toujours sur une copie, toujours avec un filtre écrit. On ouvre la copie de travail de la capture, jamais le scellé, et l'on consigne chaque filtre appliqué (par exemple `ip.addr == 203.0.113.47`). Le filtre fait partie de la méthode : un autre analyste doit pouvoir le rejouer.

6.3 Caractériser une Exfiltration

Une exfiltration se reconnaît moins à son contenu, souvent chiffré, qu'à sa forme : un volume sortant important, un rapport entre octets envoyés et reçus très déséquilibré, une destination inhabituelle, un horaire anormal, un débit soutenu.

Scénario Opérationnel · Opération NYANGA. La conversation de 1 h 12

Constatations (copie de NC-04).

- Le 14 mars, de 1 h 12 à 3 h 47, une conversation TLS relie SRV-FIC01 (10.20.1.20) à 203.0.113.47, port 443.
- Octets envoyés par SRV-FIC01 : 3,2 Go ; octets reçus : 11 Mo.
- Le client annonce le nom `cdn-update.example.net` ; le serveur présente un certificat auto-signé émis le 1er mars 2025.
- Aucune autre conversation de SRV-FIC01 vers Internet sur les 24 heures de la capture.

Calcul. Durée : 2 h 35, soit 9 300 s. Débit moyen : $3{,}2 \times 10^9 / 9\,300 \approx 344\,000$ octets par seconde, soit environ 2,75 Mbit/s, sur un lien de 20 Mbit/s. Rapport envoyé sur reçu : environ 290.
Analyse (confiance élevée). Un serveur de fichiers n'envoie pas 3,2 Go en pleine nuit vers un serveur au certificat auto-signé récent qui se fait passer pour un service de mise à jour. La forme du flux est celle d'une exfiltration. Le débit, limité à un septième du lien, est compatible avec un outil réglé pour ne pas saturer la ligne et passer inaperçu.

6.3.1 Ce que le chiffrement laisse voir

Élément visible	Ce qu'il apprend
Adresses, ports, heures	Qui, vers où, quand
Volumes dans chaque sens	Envoi ou réception, ordre de grandeur des données
Nom annoncé (SNI)	Le service que le client prétend joindre
Certificat du serveur	Émetteur, date de création, auto-signature
Rythme des paquets	Transfert continu, balise régulière, session interactive

Tableau 6.2. Ce que laisse voir un flux chiffré

Le contenu, lui, reste inaccessible sans les clés. Pour savoir quels fichiers sont partis, il faut une autre source. À NYANGA, elle se trouve sur SRV-FIC01 lui-même : l'outil de copie utilisé par l'attaquant a laissé un journal dans le dossier de l'utilisateur, retrouvé dans l'acquisition du 18 mars (NC-07). Il liste 18 412 fichiers du dossier `Clients`, pour un total de 3,19 Go, avec des heures de début et de fin qui encadrent la conversation réseau.

6.4 Reconnaître une Balise

Définition

Balise (*beacon*) : connexion qu'un programme malveillant établit à intervalles réguliers vers son serveur de commande, pour signaler sa présence et recevoir des ordres. Sa régularité la trahit, même quand le contenu est chiffré et le volume faible.

Scénario Opérationnel · Opération NYANGA. Toutes les soixante secondes

Constatations. Sur les 24 heures de la capture, SRV-AD01 (10.20.1.10) ouvre 1 431 connexions courtes vers 203.0.113.47:443. L'intervalle entre deux connexions est compris entre 54 et 66 secondes ; chaque échange fait entre 1,2 et 2,8 Ko, sauf onze échanges de 40 à 900 Ko, tous situés entre 0 h 50 et 3 h 50 le 14 mars.
Calcul. 24 heures font 1 440 minutes : 1 431 connexions correspondent à une connexion par minute, à neuf près.
Analyse (confiance élevée). C'est la balise du PID 4412 vu en mémoire (Chapitre 5), réglée sur 60 secondes avec une variation de 10 %. Les onze échanges plus volumineux, pendant la nuit, correspondent à des ordres plus lourds : ils précèdent et accompagnent l'exfiltration depuis SRV-FIC01.

6.5 Ce que la Capture ne Voit pas

La troisième question de Mme MBARGA reçoit une réponse inattendue. La capture ne contient aucun échange avec l'interface de paiement pendant la nuit. Les journaux de

l'interface (NC-05) indiquent que les vingt-trois virements ont été émis depuis l'adresse 203.0.113.62, qui n'appartient pas à NYANGA CRÉDIT. L'interface est hébergée par le prestataire, sur Internet : l'attaquant a utilisé la clé volée depuis sa propre machine, sans passer par le réseau du siège.

Lecture auditologique · Les trois questions au réseau

Proposition	Cote	Sources
3,2 Go sont sortis de SRV-FIC01 vers 203.0.113.47 la nuit du 14 mars	OUI	NC-04
Les fichiers sortis sont ceux du dossier `Clients`	OUI	Journal de l'outil (NC-07)
Le programme de SRV-AD01 communiquait avec la même adresse	OUI	NC-04, NC-01
Les virements sont passés par le lien du siège	NON	NC-04, NC-05
Aucune autre donnée n'est sortie par un autre chemin	NEK	La sonde ne voit que le lien Internet du siège

Lecture. Trois OUI, un NON, un NEK. Le NON sur les virements est solide parce que les deux sources se recoupent : absence dans la capture, et adresse d'émission externe dans les journaux de l'interface. Le NEK rappelle que les agences ont leur propre accès Internet, hors de la vue de la sonde.

6.6 Ce que l'Analyse Réseau demande à chaque Métier

Application Analyste en réponse à incident

Analyser une capture

1. Situer la sonde : lien observé, période, pertes éventuelles.
2. Partir des statistiques de conversations, pas des paquets.
3. Pour chaque conversation suspecte : volumes, durée, débit, rythme, nom annoncé, certificat.
4. Rattacher chaque flux à un processus (mémoire) et à des fichiers (disque).
5. Écrire les filtres utilisés.

Application RSSI

Placer la sonde là où passent les flux qui comptent, et savoir ce qu'elle ne voit pas. À NYANGA, les vingt-deux agences sortent sur Internet par leurs propres accès :

elles sont hors du champ de la sonde.

Application Application OPJ/Expert Judiciaire

L'adresse 203.0.113.47 désigne une machine à un instant donné. Pour aller vers une personne, l'enquête doit obtenir, par réquisition ou par entraide internationale, les données du fournisseur qui l'exploitait : le Chapitre 8 en donne les fondements.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Capture complète, flux, journaux et alertes se complètent ; on part du large pour descendre vers le détail.
- Une exfiltration se caractérise par son volume, son déséquilibre, son débit, son horaire et sa destination ; une balise par sa régularité.
- Un flux chiffré laisse voir les adresses, les volumes, le nom annoncé, le certificat et le rythme ; son contenu se cherche ailleurs.
- L'absence d'un flux dans une capture ne vaut NON que si l'on sait que le flux devait passer par la sonde.
- À NYANGA, 3,2 Go du dossier `Clients` sont partis de SRV-FIC01 ; les virements, eux, ont été émis de l'extérieur.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- calculer le débit moyen d'une conversation ;
- reconnaître une balise dans une liste de connexions ;
- dire pourquoi l'absence d'un flux ne prouve pas toujours son inexistence.

Exercices

Exercice 6.1. Quelle source ? ★☆☆

Pour chaque question, dites quelle source réseau y répond le mieux : (a) SRV-FIC01 a-t-il parlé à 203.0.113.47 il y a trois mois ? (b) quel nom de domaine le contrôleur de domaine a-t-il résolu avant sa première balise ? (c) que contenait la requête HTTP non chiffrée d'un poste vers un site inconnu ? (d) la sonde a-t-elle signalé quelque chose cette nuit-là ?

✍ Exercice 6.2. Le calcul du débit ★★☆

Une seconde conversation, découverte dans les flux d'une agence, montre 900 Mo envoyés en 1 h 15.

(a) Calculez le débit moyen en octets par seconde et en Mbit/s.

(b) L'agence dispose d'un lien de 4 Mbit/s. Qu'en déduisez-vous sur le réglage de l'outil ?

(c) Cette conversation change-t-elle une cote de l'encadré « Les trois questions au réseau » ?

✍ Exercice 6.3. Une balise ou pas ★★☆

Voici les heures de connexion d'un poste vers une même adresse : 10:00:03, 10:05:01, 10:10:04, 10:15:02, 10:20:03, puis 11:47:30, 12:13:05.

(a) Lesquelles évoquent une balise, et de quelle période ?

(b) Proposez une explication légitime de ce rythme.

(c) Quelles vérifications feriez-vous avant de conclure ?

✍ Exercice 6.4. Le NON des virements ★★★

(a) Expliquez pourquoi la seule absence des virements dans la capture ne suffirait pas à coter NON la proposition « les virements sont passés par le lien du siège ».

(b) Quelle pièce indépendante permet ce NON ? Quelle est sa propre faiblesse (Chapitre 2) ?

(c) Proposez une démarche pour renforcer la cote, en vous plaçant du côté de l'enquête judiciaire.

● Note

Pour aller plus loin.

➢ R. Bejtlich, *The Practice of Network Security Monitoring* [3].

➢ C. Sanders, *Practical Packet Analysis* [41].

● Note

Transition. Le disque, la mémoire et le réseau ont chacun parlé, chacun avec ses heures. Il reste à les mettre dans un même ordre, sur une même échelle de temps : Chapitre 7.

7

CHRONOLOGIE ET CORRÉLATION

« Une chronologie n'est pas une liste d'événements.
C'est une liste d'événements dont on a vérifié les horloges. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise des Chapitres 4 à 6

✦ Objectifs du chapitre

- ➢ Construire une chronologie unifiée à partir de sources aux horloges et aux formats différents.
- ➢ Normaliser les heures et corriger une dérive mesurée.
- ➢ Corréler des événements par des pivots : adresse, compte, empreinte, heure.
- ➢ Repérer les trous d'une chronologie et les coter.
- ➢ Calculer un temps de présence et le rattacher aux tactiques d'une attaque.

Avant de commencer : quarante-sept secondes

Yaoundé, 26 mars 2025. M. FOTSO assemble les événements établis par le disque, la mémoire et le réseau. Une incohérence apparaît aussitôt. Selon le journal de la passerelle, la session de `svc_backup` qui précède l'installation du service sur SRV-AD01, le 9 mars, s'ouvre à 1 h 35 min 41 s. Selon le journal système de SRV-AD01, le service est créé à 1 h 35 min 09 s. L'attaquant aurait installé son outil trente-deux secondes avant d'ouvrir sa session.

Mme MBARGA ne conclut pas à une falsification. Elle demande la dérive de chaque horloge. Les serveurs du siège se synchronisaient sur le serveur de temps interne ; la passerelle, installée par un prestataire, ne le faisait pas. Mesurée le 14 mars, son horloge avançait de 47 secondes.

★ Attention

Violation typique. Fusionner les heures de plusieurs sources sans vérifier leurs fuseaux ni leurs dérives, puis tirer des conclusions de l'ordre obtenu.

© MaletYon

Règle : chaque source reçoit, avant toute fusion, son fuseau, sa dérive mesurée et sa précision. La chronologie se construit en UTC corrigé ; un ordre entre deux événements plus proches que l'incertitude des horloges n'est pas établi.

7.1 Normaliser les Heures

Source	Fuseau	Dérive	Précision	Synchronisée
Passerelle d'accès	UTC+1	+47 s	1 s	Non
SRV-AD01 (journaux)	UTC+1	+2 s	1 s	Oui
SRV-CPT01 (journaux, NTFS)	UTC+1, UTC	+2 s	1 s, 100 ns	Oui
Sonde réseau	UTC	0 s	1 µs	Oui (source publique)
Interface de paiement	UTC	Inconnue	1 s	NEK

Tableau 7.1. Les horloges de l'affaire NYANGA

La dérive se mesure au moment de l'acquisition, en comparant l'heure de la machine à une référence, et se suppose constante sur la période, ce qui est une hypothèse à écrire. Corrigée de 47 secondes, l'ouverture de session sur la passerelle passe à 1 h 34 min 54 s, quinze secondes avant la création du service : l'ordre redevient cohérent.

Note

Préparer une source avant fusion

1. Identifier le fuseau dans lequel la source écrit ses heures.
2. Mesurer ou rechercher la dérive de son horloge.
3. Noter sa précision (seconde, milliseconde).
4. Convertir en UTC et corriger la dérive, en gardant l'heure d'origine à côté.
5. Noter les hypothèses (dérive constante, fuseau supposé).

7.2 Fusionner et Corréler

Des outils de super-chronologie, comme log2timeline et Plaso, extraient automatiquement les horodatages de centaines de formats (journaux, registre, système de fichiers, navigateurs) et les fusionnent dans une seule liste. Une telle liste compte vite des millions de lignes. La corrélation consiste à y relier des événements par un élément commun, appelé **pivot**.

Pivot	Exemple à NYANGA	Ce qu'il relie
Adresse IP	203.0.113.47	Balise de SRV-AD01, exfiltration de SRV-FIC01
Compte	`adm.kamga`	Sessions sur SRV-CPT01 et SRV-FIC01 depuis SRV-AD01
Empreinte de fichier	Binaire `WinUpd\svchost.exe`	Même fichier sur SRV-AD01 et SRV-FIC01
Heure	14 mars, 1 h 12	Début de l'exfiltration, échanges volumineux de la balise
Nom	`cdn-update.example.net`	Requêtes DNS, échanges TLS

Tableau 7.2. Les pivots de corrélation

Un pivot relie, il ne prouve pas à lui seul un lien de cause. Deux machines qui parlent à la même adresse peuvent obéir au même attaquant, ou utiliser le même service légitime. Le lien se confirme par une seconde coïncidence indépendante : même adresse *et* même binaire, même compte *et* même origine.

7.3 La Chronologie de NYANGA

Scénario Opérationnel · Opération NYANGA. Du correctif au virement

Date et heure	Événement	Source	Cote
12/12/2024	Bulletin de l'éditeur sur VULN-2024-4471	Éditeur	OUI
15/12/2024	Correctif publié	Éditeur	OUI
19/12/2024	Inscription au catalogue KEV	CISA	OUI
02/03/2025, 23 h 48	Première session `svc_backup` depuis 203.0.113.18	Passerelle (corrigée)	OUI
03 au 08/03	Activité de l'attaquant	Aucune	NEK
09/03, 1 h 34	Session `svc_backup` vers SRV-AD01	Passerelle, SRV-AD01	OUI
09/03, 1 h 35	Service `WinUpdSvc` installé	SRV-AD01 (7045)	OUI
09/03, 1 h 37	`lsass.dmp` créé	SRV-AD01 ($UsnJrnl)	OUI
10/03 et suivants	Sessions `adm.kamga` depuis SRV-AD01	Serveurs (4624)	OUI
12/03, 22 h 39 à 23 h 06	Ouverture de `api.ini`, archive, suppression	SRV-CPT01	OUI
14/03, 1 h 12 à 3 h 47	3,2 Go de SRV-FIC01 vers 203.0.113.47	Sonde, NC-07	OUI
14/03, 2 h 05 à 3 h 31	23 virements depuis 203.0.113.62	Interface	OUI
14/03, 7 h 30	Détection par le service des paiements	Témoignage	OUI
14/03, 10 h 02	Capture mémoire de SRV-AD01	Registre des actions	OUI

Constatations. Entre la première session et la détection s'écoulent 11 jours, 7 heures et 42 minutes. Aucune source ne couvre l'activité de l'attaquant du 3 au 8 mars : la passerelle n'enregistre aucune session de `svc_backup`, et aucun serveur du siège ne garde trace de lui.

Analyse (confiance moyenne). Le trou peut signifier que l'attaquant a attendu, ou qu'il a agi par un autre chemin que les sources ne voient pas (une agence, un autre compte). La seconde explication ne peut être écartée.

Définition

Temps de présence (*dwell time*) : durée entre la première action établie de l'attaquant dans le système et la détection de l'incident. C'est une borne inférieure : une action plus ancienne, non détectée, l'allongerait.

7.4 Lire la Chronologie par Tactiques

La chaîne d'intrusion décrite par Lockheed Martin [18] et la matrice ATT&CK de MITRE [47] rangent les actions d'un attaquant en étapes, ou tactiques. Placer chaque événement de la chronologie dans une tactique permet de voir ce qui manque.

Tactique (ATT&CK)	Événement de NYANGA	Cote
Accès initial	Session du 2 mars par la passerelle	OUI
Persistance	Service `WinUpdSvc`	OUI
Accès aux identifiants	Copie de la mémoire de `lsass.exe`	OUI
Mouvement latéral	Sessions `adm.kamga` depuis SRV-AD01	OUI
Collecte	Archive `cpt.7z`, dossier `Clients`	OUI
Commande et contrôle	Balise de 60 secondes vers 203.0.113.47	OUI
Exfiltration	3,2 Go le 14 mars	OUI
Impact	23 virements frauduleux	OUI
Découverte (reconnaissance interne)	Aucun événement retrouvé	NEK

Tableau 7.3. La chronologie de NYANGA par tactiques

La dernière ligne est instructive. Un attaquant qui trouve le fichier de clé d'une application de paiement a forcément exploré le réseau avant. Aucune trace de cette exploration n'a été trouvée : elle s'est probablement déroulée pendant le trou du 3 au 8 mars, avec des moyens que les sources du siège n'enregistrent pas. La tactique est presque certaine, l'événement reste NEK.

⚖ Lecture auditologique · La chronologie au 26 mars

Décompte. Sur les quatorze lignes de la chronologie, treize sont cotées OUI et une NEK ; sur les neuf tactiques, huit OUI et une NEK.

Lecture. La chronologie est solide sur ce qu'elle montre, et ses deux NEK portent sur la même période : du 3 au 8 mars. C'est là que l'enquête doit chercher, en élargissant ses sources aux agences et aux autres comptes, avant de conclure que le temps de présence est de onze jours.

7.5 Ce que la Chronologie demande à chaque Métier

Application Analyste en réponse à incident

Construire une chronologie

1. Dresser le tableau des horloges : fuseau, dérive, précision.
2. Normaliser en UTC corrigé, en gardant l'heure d'origine.
3. Fusionner, puis filtrer par pivots.
4. Confirmer chaque lien par deux coïncidences indépendantes.
5. Coter chaque ligne et nommer les trous.

Application Application OPJ/Expert Judiciaire

Devant un tribunal, une chronologie se présente avec ses incertitudes : on écrit « entre 1 h 34 et 1 h 35, à une minute près » plutôt qu'une seconde précise qu'aucune horloge ne garantit.

Application RSSI

Synchroniser toutes les horloges, y compris celles des équipements installés par des prestataires. La passerelle de NYANGA, seule hors synchronisation, était aussi le point d'entrée.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Avant toute fusion, chaque source reçoit son fuseau, sa dérive et sa précision ; la chronologie se construit en UTC corrigé.
- Un pivot relie des événements ; un lien de cause demande deux coïncidences indépendantes.
- Le temps de présence est une borne inférieure.
- Ranger la chronologie par tactiques montre ce qui manque.
- À NYANGA, le temps de présence établi est de 11 jours, 7 heures et 42 minutes ; la période du 3 au 8 mars reste NEK.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- corriger une heure d'une dérive mesurée ;

- ➢ calculer un temps de présence ;
- ➢ ranger des événements par tactiques et repérer une tactique sans événement.

Exercices

✍ Exercice 7.1. Corriger une heure ★☆☆

La passerelle avance de 47 secondes. Corrigez et convertissez en UTC les heures suivantes, lues dans son journal en heure locale : (a) 02/03/2025 23:48:35 ; (b) 09/03/2025 01:35:41 ; (c) 14/03/2025 00:58:12.

✍ Exercice 7.2. Le temps de présence ★★☆

(a) Vérifiez le calcul du temps de présence de NYANGA.

(b) On découvre dans les journaux d'une agence une connexion de `svc_backup` le 24 février à 21 h 10. Que devient le temps de présence ? Quelle vérification faites-vous d'abord ?

(c) Pourquoi parle-t-on de borne inférieure ?

✍ Exercice 7.3. Un pivot trompeur ★★☆

Un poste de la direction a parlé à 203.0.113.47 le 11 mars, à 9 h 00, pendant quatre secondes.

(a) Ce poste est-il compromis ?

(b) Quelles secondes coïncidences chercheriez-vous ?

(c) Comment cotez-vous la proposition « le poste de la direction est compromis » avant et après ces vérifications ?

✍ Exercice 7.4. Combler le trou ★★★

Proposez un plan d'investigation pour la période du 3 au 8 mars : sources à recueillir, questions, pivots, et cotes attendues selon ce que l'on trouvera. Indiquez ce qui ferait passer la tactique « découverte » de NEK à OUI, et ce qui ne permettra jamais de la passer à NON.

● Note

Pour aller plus loin.

- ➢ La matrice MITRE ATT&CK [47].
- ➢ E. Hutchins, M. Cloppert, R. Amin, sur la chaîne d'intrusion [18].

Note

Transition. La partie II a montré comment acquérir et analyser. Mais qui a le droit de le faire, selon quelles normes, et sous quelles règles de droit ? C'est l'objet du Chapitre 8.

partie III

Cadre Normatif et Juridique

© MaletYon

8

NORMES ET DROIT DE L'INVESTIGATION

« La compétence technique dit ce que l'on peut faire.
Le droit dit ce que l'on a le droit de faire. »

Principe du cours

Niveau : *Fondamental* • Lecture des Chapitres 1 et 2

✦ Objectifs du chapitre

- ➢ Situer les normes de l'investigation numérique (famille ISO/IEC 27037 à 27043, ISO/IEC 27035, ISO/IEC 17025, NIST) et dire ce que chacune encadre.
- ➢ Citer les articles de la loi n° 2010/012 qui organisent l'enquête (articles 52 à 58).
- ➢ Qualifier des faits au regard des infractions de la loi n° 2010/012.
- ➢ Identifier les obligations de l'exploitant d'un système d'information qui pèsent sur la préparation d'une enquête.
- ➢ Distinguer les pouvoirs de l'OPJ, de l'expert requis et de l'enquêteur privé.
- ➢ Décrire la voie de l'entraide judiciaire internationale.

Avant de commencer : soixante jours au lieu de dix ans

Bafoussam, 30 mars 2025. Me ETOUNDI, la juriste de NYANGA CRÉDIT, relit avec Mme NDOUMBE la loi n° 2010/012 relative à la cybersécurité et à la cybercriminalité au Cameroun. Elle cherche les infractions que la plainte peut viser. Elle trouve aussi un article qu'elle n'attendait pas : la loi oblige les exploitants de systèmes d'information à conserver les données de connexion et de trafic pendant dix ans. Les journaux de la passerelle de l'établissement n'en gardaient que soixante jours.

★ Attention

Violation typique. Traiter le droit comme une question qui ne se pose qu'au moment de porter plainte.

© MaletYon

Règle : le droit encadre l'enquête du premier geste au dernier : qui peut recueillir quoi, comment saisir, comment requérir un tiers, et ce que l'organisation devait avoir préparé. L'enquêteur qui l'ignore produit des pièces fragiles et expose son client.

8.1 Les Normes de l'Investigation

Les normes ne disent pas le droit ; elles décrivent l'état de l'art. Un juge ou un expert adverse qui conteste une méthode demandera si elle suit une pratique reconnue. Les normes fournissent cette référence.

Texte	Objet (paraphrasé)	Chapitres du cours
ISO/IEC 27037	Identification, recueil, acquisition et préservation de la preuve numérique	2, 3
ISO/IEC 27041	Assurance que les méthodes d'examen sont adaptées et validées	4 à 6
ISO/IEC 27042	Analyse et interprétation de la preuve numérique	4 à 7
ISO/IEC 27043	Principes et processus de l'investigation, de la préparation à la clôture	1
ISO/IEC 27035	Gestion des incidents de sécurité de l'information	1, 14
ISO/IEC 17025	Compétence des laboratoires d'essais et d'étalonnage, base de l'accréditation des laboratoires forensiques	15
NIST SP 800-86	Intégration de la forensique à la réponse aux incidents	1
NIST SP 800-61	Gestion des incidents de sécurité	1

Tableau 8.1. Les normes de l'investigation numérique

Note

ISO/IEC 27041 et la validation des outils. La norme ISO/IEC 27041 [20] demande que l'enquêteur puisse montrer qu'une méthode fait ce qu'il prétend. En pratique, on teste un outil sur une image de référence dont le contenu est connu, et l'on garde la trace du test. Un outil non validé n'est pas interdit, mais son résultat porte une confiance moindre, et l'enquêteur doit le dire.

8.2 Le Cadre Camerounais de l'Enquête

La loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité [34] contient un chapitre consacré à la procédure. Ses articles 52 à 58 organisent l'enquête.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 52 [34] : *« (1) En cas d'infraction cybernétique, les Officiers de Police Judiciaire à compétence générale et les agents habilités de l'Agence, procèdent aux enquêtes conformément aux dispositions du Code de Procédure Pénale. [...] (3) Les Officiers de Police Judiciaire et les agents habilités de l'Agence peuvent, lors des investigations, accéder aux moyens de transport, à tout local à usage professionnel, à l'exclusion des domiciles privés, en vue de rechercher, de constater les infractions, de demander la communication de tous les documents professionnels et en prendre copie, recueillir, sur convocation ou sur place, les renseignements et justifications. »*

Portée (analyse). L'enquête pénale appartient aux OPJ et aux agents habilités de l'Agence nationale des technologies de l'information et de la communication (ANTIC). Leurs pouvoirs d'accès s'arrêtent au domicile privé, qui relève des règles générales de la perquisition.

Article	Objet
52	Enquêteurs compétents (OPJ, agents habilités de l'ANTIC) et pouvoirs d'accès
53	Perquisition portant sur des données, copie en présence des personnes, scellés (Chapitre 2)
54	Perquisitions et saisies selon le Code de procédure pénale, en tenant compte du dépérissement des preuves
55	Réquisition d'une personne qualifiée pour obtenir la version en clair de données transformées ; remise de la convention de déchiffrement
56	Réquisition à expert, selon les règles de la commission d'expert
57	Commissions rogatoires nationales et internationales
58	Obligations des prestataires de cryptographie envers les enquêteurs

Tableau 8.2. Les articles de procédure de la loi n° 2010/012

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 55 [34] : *« (1) Lorsqu'il apparaît que les données saisies ou obtenues au cours de l'enquête ou de l'instruction ont fait l'objet d'opérations de*

transformation empêchant d'accéder en clair ou sont de nature à compromettre les informations qu'elles contiennent, le Procureur de la République, le Juge d'Instruction ou la juridiction de jugement peuvent réquisitionner toute personne physique ou morale qualifiée, en vue d'effectuer les opérations techniques permettant d'obtenir la version en clair desdites données. (2) Lorsqu'un moyen de cryptographie a été utilisé, les autorités judiciaires peuvent exiger la convention secrète de déchiffrement du cryptogramme. »

Loi n° 2010/012, article 56 [34] : *« La réquisition prévue à l'article 50 ci-dessus peut être faite à tout expert. Dans ce cas, son exécution est faite conformément aux dispositions du Code de procédure pénale relatives à la commission d'expert. »*

Portée (analyse). L'article 55 fonde la réquisition qui permettrait d'ouvrir l'archive chiffrée `cpt.7z` (Chapitre 4). L'article 56 fonde la désignation de M. ABOUBAKAR : l'expert requis agit selon les règles de l'expertise du Code de procédure pénale [dispositions à vérifier par le lecteur sur le texte officiel], et non selon un mandat de l'établissement.

8.3 Qualifier les Faits

L'enquête technique établit des faits ; la qualification les rattache à des infractions. Elle appartient au procureur et au juge, mais l'enquêteur doit savoir quels faits chaque infraction exige, pour ne pas oublier d'établir l'un d'eux.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 65, alinéa 2 [34] : *« Est puni des peines prévues à l'alinéa 1 ci-dessus, tout accès non autorisé, à l'ensemble ou à une partie d'un réseau de communications électroniques ou d'un système d'information ou d'un équipement terminal. »*

Loi n° 2010/012, article 72 [34] : *« Est puni des peines prévues par l'article 66 ci-dessus celui qui, de quelque manière que ce soit, sans droit, introduit, altère, efface, ou supprime, afin d'obtenir un bénéfice économique, les données électroniques, de manière à causer un préjudice patrimonial à autrui. »*

Scénario Opérationnel · Opération NYANGA. Les faits et les textes

Fait établi	Texte possible	Élément que l'enquête doit établir
Session du 2 mars sur la passerelle, par contournement de l'authentification	Art. 65 al. 2, art. 69	Accès sans droit ; violation des mesures de sécurité (art. 69)
Copie du dossier `Clients`	Art. 69	Accès « afin d'obtenir des informations ou des données »
Installation d'un service, copie de la mémoire de `lsass.exe`	Art. 71	Introduction de données en vue de modifier celles du système
23 virements avec la clé volée	Art. 72	Introduction de données sans droit, bénéfice économique, préjudice patrimonial

Analyse (confiance moyenne, qualification réservée au parquet). Les faits établis aux Chapitres 4 à 7 couvrent les éléments matériels de ces infractions. L'identité des auteurs, NEK, conditionne les poursuites, pas la qualification des faits.

Jurisprudence & Droit applicable

Loi n° 2010/012, article 69 [34] : *« Est puni d'un emprisonnement de cinq (05) à dix (10) ans et d'une amende de 10.000.000 (dix millions) à 100.000.000 (cent millions) F CFA ou de l'une de ces deux peines seulement, celui qui accède sans droit, et en violation des mesures de sécurité, à l'ensemble ou à une partie d'un réseau de communications électroniques, d'un système d'information ou d'un équipement terminal, afin d'obtenir des informations ou des données, en relation avec un système d'information connecté à un autre système d'information. »*

Portée (analyse). L'article 69 exige une violation des mesures de sécurité. Le contournement de l'authentification de la passerelle en est une ; l'enquête doit l'établir techniquement, ce que fera le Chapitre 12. Le même article interdit à l'enquêteur privé d'entrer sans autorisation dans un système, fût-ce pour suivre l'attaquant : remonter jusqu'au serveur 203.0.113.47 et s'y connecter serait un accès sans droit.

8.4 Les Obligations de l'Exploitant

La loi pèse aussi sur la victime, au titre de ses obligations d'exploitant de système d'information. Trois dispositions intéressent directement la préparation d'une enquête.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 29 [34] : *« (1) Les exploitants des systèmes d'information ont l'obligation de conserver les données de connexion et de trafic de leurs systèmes d'information pendant une période de dix (10) ans. (2) Les exploitants des systèmes d'information sont tenus d'installer des mécanismes de surveillance de contrôle d'accès aux données de leurs systèmes d'information. Les données conservées peuvent être accessibles lors des investigations judiciaires. (3) Les installations des exploitants des systèmes d'information peuvent faire l'objet de perquisition ou de saisie sur ordre d'une autorité judiciaire dans les conditions prévues par les lois et règlements en vigueur. »*

Loi n° 2010/012, article 26, alinéa 4 [34] : *« Les plates-formes des systèmes d'information font l'objet de protection contre d'éventuels rayonnements et des intrusions qui pourraient compromettre l'intégrité des données transmises et contre toute autre attaque externe notamment par un système de détection d'intrusions. »*

Loi n° 2010/012, article 30, alinéa 1 [34] : *« Les exploitants des systèmes d'information évaluent, révisent leurs systèmes de sécurité et introduisent en cas de nécessité les modifications appropriées dans leurs pratiques, mesures et techniques de sécurité en fonction de l'évolution des technologies. »*

⚖ Lecture auditologique · NYANGA CRÉDIT face à ses obligations d'exploitant

Obligation	Cote	Pièce
Conserver dix ans les données de connexion et de trafic (art. 29 al. 1)	NON	Passerelle : 60 jours
Surveiller le contrôle d'accès aux données (art. 29 al. 2)	OUI	Journaux d'authentification du domaine
Disposer d'un système de détection d'intrusions (art. 26 al. 4)	OUI	Sonde installée en 2024
Réviser les mesures selon l'évolution des technologies (art. 30 al. 1)	NON	Correctif non appliqué en 89 jours
Les mécanismes ont reçu le visa de l'Agence (art. 26 al. 3)	NEK	Aucun document produit

Lecture (analyse, confiance moyenne). Deux OUI, deux NON, un NEK. Les deux NON pèsent sur la victime : la durée de conservation a failli effacer le premier accès, et l'absence de correction a ouvert la porte. Un avocat de la défense, ou un client lésé par la fuite, pourra s'en servir. Le rapport d'enquête ne les cache pas ; il les sépare des faits reprochés aux attaquants.

8.5 Trois Statuts, Trois Pouvoirs

	OPJ, agent de l'ANTIC	Expert requis	Enquêteur privé
Fondement	Art. 52	Art. 56, Code de procédure pénale	Contrat avec l'organisation
Mandant	Procureur, juge	L'autorité qui le requiert	Le client
Accès aux locaux	Locaux professionnels (art. 52 al. 3)	Selon sa mission	Ceux du client seulement
Saisie et scellés	Oui (art. 53)	Non, il reçoit des scellés	Non ; il conserve sous chaîne de possession
Requérir un tiers	Oui, par réquisition	Non	Non ; il demande, sans contrainte
Destinataire du rapport	Le parquet	L'autorité requérante	Le client

Tableau 8.3. Les pouvoirs selon le statut

L'enquêteur privé n'a aucun pouvoir de contrainte. Il travaille sur les systèmes que son client possède ou dont il peut autoriser l'examen, et il remet ses pièces à l'OPJ quand une plainte est déposée. C'est pourquoi la qualité de ses premières acquisitions compte autant : elles deviendront les pièces de l'enquête pénale.

8.6 L'Entraide Internationale

Les adresses 203.0.113.18, .47 et .62 de l'affaire, si elles étaient réelles, appartiendraient très probablement à des hébergeurs étrangers. Obtenir leurs données suppose l'entraide judiciaire internationale.

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012, article 91, alinéa 3 [34] : *« En cas d'urgence, les demandes d'entraide demandées par les autorités camerounaises ou étrangères peuvent être transmises directement aux autorités de l'Etat requis pour leur exécution. Le renvoi des pièces d'exécution aux autorités compétentes de l'Etat requérant est effectué selon les mêmes modalités. »*

Portée (analyse). La voie ordinaire passe par le ministère chargé des relations extérieures (alinéa 1) ; l'urgence autorise la transmission directe. Le dépérissement des données des hébergeurs justifie souvent l'urgence.

Deux conventions internationales structurent la coopération. La Convention du Conseil de l'Europe sur la cybercriminalité, dite de Budapest [10], organise la conservation rapide des données et l'entraide entre ses parties. La Convention de l'Union africaine sur la

cybersécurité et la protection des données à caractère personnel, dite de Malabo [11], entrée en vigueur en 2023, fixe un cadre africain. Le statut du Cameroun au regard de chacune [à vérifier par le lecteur sur les sites des deux organisations] commande la voie utilisable : sans convention applicable, l'entraide repose sur la réciprocité et les accords bilatéraux.

8.7 Ce que le Droit demande à chaque Métier

Application Analyste en réponse à incident

Ne jamais suivre l'attaquant hors des systèmes du client ; demander par écrit la conservation des données aux tiers dès le premier jour ; préparer ses pièces comme si elles devaient être remises à un OPJ, ce qui arrive souvent.

Application Application OPJ/Expert Judiciaire

L'OPJ requiert les tiers sans délai, en invoquant le dépérissement des preuves (art. 54). L'expert s'en tient aux questions de sa mission et signale à l'autorité tout fait découvert hors de celle-ci.

Application RSSI

Mettre la conservation des journaux en conformité avec l'article 29 : dix ans pour les données de connexion et de trafic. La mesure se chiffre en stockage, et elle conditionne toute enquête future.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Les normes ISO/IEC 27037 à 27043 décrivent l'état de l'art de l'investigation ; l'ISO/IEC 27041 exige des méthodes validées.
- La loi n° 2010/012 confie l'enquête aux OPJ et aux agents de l'ANTIC (art. 52), encadre la saisie de données (art. 53, 54), le déchiffrement (art. 55) et l'expertise (art. 56).
- Les faits de NYANGA relèvent notamment des articles 65 al. 2, 69, 71 et 72 ; la qualification appartient au parquet.
- L'exploitant doit conserver dix ans ses données de connexion et de trafic (art. 29 al. 1) : NYANGA ne les gardait que 60 jours.
- L'enquêteur privé n'a aucun pouvoir de contrainte ; l'entraide internationale passe par les autorités judiciaires.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- citer l'article qui fonde la saisie par copie de données ;
- rattacher un fait établi à une infraction et nommer l'élément à prouver ;
- dire ce qu'un enquêteur privé peut et ne peut pas faire.

Exercices

Exercice 8.1. Quel texte ? ★☆☆

Indiquez l'article de la loi n° 2010/012 qui répond à chaque question : (a) qui conduit l'enquête pénale en cas d'infraction cybernétique ? (b) peut-on saisir une copie des données plutôt que le serveur ? (c) comment obtenir la version en clair d'une archive chiffrée ? (d) combien de temps l'exploitant doit-il conserver ses données de trafic ? (e) comment désigner un expert ?

Exercice 8.2. Ce que l'enquêteur privé ne fait pas ★★☆

Mme MBARGA reçoit trois demandes de son client. Dites, pour chacune, si elle peut y répondre et pourquoi : (a) se connecter au serveur 203.0.113.47 avec les identifiants trouvés dans l'outil de l'attaquant ; (b) examiner le portable personnel de M. KAMGA, qu'il apporte de lui-même ; (c) obtenir de l'opérateur de paiement mobile l'identité des titulaires des onze portefeuilles.

Exercice 8.3. Qualifier ★★☆

Pour chacun des faits suivants, proposez un article de la loi n° 2010/012 et nommez l'élément que l'enquête doit établir : (a) la création du compte `svc_backup` par l'attaquant, s'il était établi ; (b) la balise de soixante secondes ; (c) l'effacement de l'archive `cpt.7z` ; (d) l'envoi de 3,2 Go vers l'extérieur.

Exercice 8.4. Les obligations de la victime ★★★

Un client dont le dossier figure parmi les fichiers exfiltrés assigne NYANGA CRÉDIT en réparation.

(a) Quels manquements aux articles 26, 29 et 30 peut-il invoquer, et sur quelles pièces de l'enquête ?

(b) NYANGA répond qu'elle est victime d'une infraction. Montrez que les deux positions ne s'excluent pas.

(c) Rédigez la recommandation du rapport d'enquête qui traite la conservation des journaux, en citant le texte.

Note

Pour aller plus loin.

- La loi n° 2010/012 [34], dans son texte officiel.
- Les normes ISO/IEC 27037 [19], 27041 [20], 27042 [21], 27043 [22].
- La Convention de Budapest [10] et la Convention de Malabo [11].

Note

Transition. L'enquête a montré par où l'attaquant est entré : une faille connue de la passerelle. La partie IV change de point de vue : qu'est-ce qu'une vulnérabilité, et comment la mesurer ? Chapitre 9.

partie IV

Vulnérabilités : Identifier, Coter, Corriger

© *MaletYon*

9

QU'EST-CE QU'UNE VULNÉRABILITÉ

« Un score dit la gravité d'une faille dans l'absolu.
Il ne dit pas qu'elle sera exploitée chez vous. »

Principe du cours

Niveau : *Fondamental* • Lecture du Chapitre 0

✦ Objectifs du chapitre

- ➢ Définir une vulnérabilité et la distinguer de la faiblesse, de la menace et du risque.
- ➢ Lire un identifiant CVE et le rattacher à une faiblesse CWE.
- ➢ Lire un vecteur CVSS v4.0 et en expliquer chaque métrique.
- ➢ Interpréter un score EPSS et une inscription au catalogue KEV.
- ➢ Expliquer pourquoi la gravité technique ne suffit pas à décider d'une priorité.

Avant de commencer : 412 critiques

Douala, mai 2025. SOLITRANS LOGISTIQUE[1], transitaire et logisticien du port, vient de réaliser son premier balayage complet de vulnérabilités sur ses 1 380 actifs. Le rapport de l'outil compte 3 812 constats, dont 412 qualifiés de « critiques » par leur score. Mme EBODE, responsable de la gestion des vulnérabilités depuis trois semaines, doit dire au comité de direction ce qu'on corrige d'abord. Le RSSI, M. NJIKE, a une réponse simple : « les 412 critiques, dans l'ordre du score ». Mme EBODE sait que l'équipe système corrige environ quarante failles par semaine. Il faudrait dix semaines pour les seules critiques.

★ Attention

Violation typique. Confondre la gravité technique d'une vulnérabilité, mesurée par un score, avec le risque qu'elle fait courir à l'organisation.

[1] SOLITRANS LOGISTIQUE, ses salariés, ses sites et ses chiffres sont fictifs ; les référentiels cités (CVE, CWE, CVSS, EPSS, KEV, SSVC) sont exacts.

© MaletYon

Règle : le score de base décrit la faille telle qu'elle est partout. La priorité de correction dépend aussi de ce que l'on sait de son exploitation et de la place de l'actif dans l'organisation.

9.1 Faiblesse, Vulnérabilité, Menace, Risque

Définition

Faiblesse : type d'erreur de conception ou de programmation susceptible de créer des vulnérabilités, par exemple une authentification mal vérifiée ou une entrée non contrôlée. Le catalogue CWE (*Common Weakness Enumeration*) les recense [46].

Vulnérabilité : défaut présent dans une version précise d'un produit, qui peut être exploité pour porter atteinte à la confidentialité, à l'intégrité ou à la disponibilité. Le programme CVE (*Common Vulnerabilities and Exposures*) lui attribue un identifiant unique [45].

Menace : source potentielle d'atteinte, par exemple un groupe qui exploite une famille de failles.

Risque : combinaison de la vraisemblance qu'une menace exploite une vulnérabilité et de la gravité de l'atteinte qui en résulte pour l'organisation.

La faille de la passerelle de NYANGA CRÉDIT illustre la chaîne. La faiblesse est un contrôle d'authentification incomplet (CWE-287, authentification incorrecte). La vulnérabilité est son instance dans le micrologiciel 7.2.1 de la passerelle, désignée dans ce livre par l'identifiant fictif VULN-2024-4471. La menace, ce sont les groupes qui l'exploitaient dès décembre 2024. Le risque, pour NYANGA, combinait une passerelle exposée sur Internet, non corrigée, et un accès direct au contrôleur de domaine.

9.1.1 Le cycle de vie d'un identifiant CVE

Un chercheur, un éditeur ou un utilisateur découvre une faille. Une **autorité de numérotation** (CNA), souvent l'éditeur lui-même, réserve un identifiant de la forme `CVE-AAAA-NNNNN`, puis le publie avec une description quand le correctif ou l'avis est prêt. La base nationale américaine NVD [39] enrichit ensuite l'enregistrement : produits et versions concernés, score, faiblesse CWE. Entre la publication et l'enrichissement, plusieurs jours peuvent passer ; l'analyste qui attend le score de la NVD perd ce temps.

9.2 Le Score CVSS

Le **CVSS** (*Common Vulnerability Scoring System*), tenu par le FIRST, mesure la gravité d'une vulnérabilité sur une échelle de 0 à 10. Sa version 4.0, publiée en 2023 [16], remplace progressivement la version 3.1 [14].

9.2.1 Quatre groupes de métriques

Groupe	Ce qu'il mesure	Qui le renseigne
Base	Les propriétés de la faille, identiques partout	L'éditeur, la NVD
Menace (*Threat*)	La maturité de l'exploitation connue	L'analyste, à partir du renseignement
Environnement	L'importance de l'actif et les mesures en place	L'organisation
Supplémentaire	Des informations sans effet sur le score (automatisable, effort de reprise)	L'éditeur, l'analyste

Tableau 9.1. Les groupes de métriques de CVSS v4.0

La version 4.0 exige que l'on dise quels groupes ont servi : CVSS-B pour la seule base, CVSS-BT avec la menace, CVSS-BE avec l'environnement, CVSS-BTE avec les trois. Un « 9,3 » sans cette mention est ambigu.

9.2.2 Les métriques de base

Code	Métrique	Valeurs
AV	Vecteur d'attaque	Réseau (N), adjacent (A), local (L), physique (P)
AC	Complexité de l'attaque	Faible (L), élevée (H)
AT	Conditions préalables (nouvelle en 4.0)	Aucune (N), présentes (P)
PR	Privilèges requis	Aucun (N), faibles (L), élevés (H)
UI	Interaction de l'utilisateur	Aucune (N), passive (P), active (A)
VC, VI, VA	Impact sur le système vulnérable (confidentialité, intégrité, disponibilité)	Élevé (H), faible (L), nul (N)
SC, SI, SA	Impact sur les systèmes suivants	Élevé (H), faible (L), nul (N)

Tableau 9.2. Les métriques de base de CVSS v4.0

La distinction entre système vulnérable et systèmes suivants remplace la notion de « portée » de la version 3.1. Elle permet de dire qu'une faille de la passerelle n'atteint pas seulement la passerelle, mais aussi les systèmes auxquels elle donne accès.

Artefact · Vecteur CVSS v4.0 de VULN-2024-4471

Vecteur publié par l'éditeur (fictif, construit pour le cours) : `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N`.

Score CVSS-B : 9,3, critique.
Lecture : exploitable depuis Internet, sans condition, sans compte, sans action d'un utilisateur, avec un impact élevé sur la passerelle elle-même.
Ce que l'éditeur ne pouvait pas savoir : qu'à NYANGA, la passerelle ouvrait un accès direct au contrôleur de domaine. L'analyste de NYANGA, en renseignant SC, SI et SA à « élevé » dans le groupe environnemental, aurait obtenu un score de 10,0 pour son propre contexte.

9.2.3 Les seuils de gravité

Score	Gravité
0,0	Aucune
0,1 à 3,9	Faible
4,0 à 6,9	Moyenne
7,0 à 8,9	Élevée
9,0 à 10,0	Critique

Tableau 9.3. Les seuils de gravité du CVSS

Note

Un score ne se calcule pas de tête. En version 4.0, le score se déduit du vecteur par une table de correspondance publiée par le FIRST, et non par une formule simple comme en version 3.1. On utilise le calculateur officiel, et l'on note toujours le vecteur à côté du score : c'est le vecteur qui permet de discuter le score.

9.3 EPSS : la Probabilité d'Exploitation

L'**EPSS** (*Exploit Prediction Scoring System*), lui aussi tenu par le FIRST [15], estime chaque jour, pour chaque CVE publiée, la probabilité qu'elle fasse l'objet de tentatives d'exploitation observées dans les trente jours suivants. Il s'appuie sur un modèle statistique alimenté par des données d'exploitation réelles. Il donne une probabilité, entre 0 et 1, et un centile, qui situe la CVE parmi toutes les autres.

Le CVSS et l'EPSS répondent à deux questions différentes. Le premier dit « si cette faille est exploitée, à quel point est-ce grave ? » ; le second dit « quelle est la chance qu'elle soit exploitée bientôt ? ». Les données publiées par le projet EPSS [15] montrent qu'une faible part des CVE publiées fait l'objet d'une exploitation observée : un score critique n'annonce donc pas une exploitation, et un score moyen ne l'exclut pas.

9.4 KEV : ce qui est Exploité

Le catalogue KEV (*Known Exploited Vulnerabilities*), tenu par l'agence américaine CISA [13], recense les vulnérabilités dont l'exploitation est constatée. Une inscription n'est pas une prévision : c'est un fait. Le catalogue fixe une échéance de correction pour

les agences fédérales américaines, mais toute organisation peut s'en servir comme d'une liste de failles à traiter sans attendre.

Indicateur	Question	Nature	Fréquence
CVSS-B	Quelle gravité si exploitée ?	Mesure technique	À la publication
EPSS	Quelle chance d'exploitation dans 30 jours ?	Probabilité estimée	Quotidienne
KEV	Est-elle déjà exploitée ?	Fait constaté	À l'inscription

Tableau 9.4. Trois indicateurs, trois questions

9.5 SSVC : Décider plutôt que Noter

La CISA propose aussi une méthode de décision, le SSVC (*Stakeholder-Specific Vulnerability Categorization*) [12]. Au lieu d'un score, elle conduit, par un arbre de questions, à l'une de quatre décisions : suivre (*Track*), suivre de près (*Track**), traiter rapidement (*Attend*), agir sans délai (*Act*). Les questions portent sur l'état de l'exploitation (aucune, preuve de concept, active), la possibilité d'automatiser l'attaque, l'impact technique, et l'importance de l'actif pour la mission.

Le SSVC rend explicite ce que le score cache : la décision dépend de l'organisation. La même faille peut appeler « agir » sur une passerelle exposée et « suivre » sur un serveur de test isolé.

9.6 Quatre Failles chez SOLITRANS

Scénario Opérationnel · Opération SOLITRANS. Quatre lignes du rapport de balayage

Réf.	Actif	CVSS-B	EPSS	KEV	Exposé
V-A	Serveur d'impression, réseau interne	9,8	0,002	Non	Non
V-B	Portail des transitaires, Internet	7,5	0,640	Oui	Oui
V-C	Base de suivi des conteneurs, interne	8,8	0,031	Non	Non
V-D	Pare-feu du site de Kribi, Internet	6,5	0,410	Oui	Oui

Valeurs fictives, construites pour l'exercice. EPSS : probabilité estimée d'exploitation dans les trente jours.

Constatations. Rangées par score de base, les failles donnent l'ordre V-A, V-C,

V-B, V-D. Rangées par exploitation constatée puis par probabilité, elles donnent V-B, V-D, V-C, V-A.

Analyse (confiance élevée). Les deux failles exploitées, sur des actifs exposés à Internet, passent avant les deux autres, malgré leurs scores inférieurs. V-A, la plus « grave » sur le papier, touche un serveur d'impression interne et n'est pas exploitée : elle reste à corriger, mais pas cette semaine.

Lecture auditologique · Que sait-on de chaque faille ?

Question	V-A	V-B	V-C	V-D
La faille est exploitée dans le monde	NEK	OUI	NEK	OUI
L'actif est joignable depuis Internet	NON	OUI	NON	OUI
La faille est présente (constat vérifié)	NEK	OUI	OUI	OUI

Lecture. Une absence d'inscription au catalogue KEV n'est pas une preuve de non-exploitation : V-A et V-C sont NEK, pas NON. Et V-A n'a pas encore été vérifiée : l'outil l'a déduite de la version annoncée par le service, ce qui peut produire un faux positif (Chapitre 10).

9.7 Ce que la Notion demande à chaque Métier

Application Analyste en gestion des vulnérabilités

Lire une vulnérabilité

1. Identifier la CVE, la faiblesse CWE et les versions touchées.
2. Lire le vecteur CVSS, pas seulement le score, et noter la version du CVSS.
3. Relever l'EPSS du jour et l'inscription éventuelle au catalogue KEV.
4. Situer l'actif : exposition, importance, mesures en place.
5. En déduire une décision, de type SSVC, et la justifier.

Application RSSI

Fixer la règle de priorité par écrit, en combinant exploitation, exposition et importance de l'actif, et la faire approuver. Une règle fondée sur le seul score conduit l'équipe à corriger le mauvais serveur en premier.

Application Analyste en réponse à incident

Pendant une enquête, le catalogue KEV et l'EPSS orientent la recherche du point d'entrée : une faille exploitée, présente sur un actif exposé, est la première hypothèse à tester.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- La faiblesse (CWE) est un type d'erreur ; la vulnérabilité (CVE) son instance dans un produit ; le risque dépend de la menace et du contexte.
- Le CVSS v4.0 a quatre groupes de métriques ; on précise CVSS-B, -BT, -BE ou -BTE, et l'on donne toujours le vecteur.
- L'EPSS estime la probabilité d'exploitation dans les trente jours ; le catalogue KEV constate l'exploitation.
- Le SSVC remplace le score par une décision qui dépend de l'organisation.
- Chez SOLITRANS, l'ordre par score et l'ordre par exploitation et exposition s'inversent.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- expliquer chaque élément d'un vecteur CVSS v4.0 ;
- dire ce que l'EPSS et le catalogue KEV ajoutent au score ;
- justifier un ordre de correction différent de l'ordre des scores.

Exercices

Exercice 9.1. Faiblesse ou vulnérabilité ★☆☆

Classez chaque élément comme faiblesse, vulnérabilité, menace ou risque : (a) l'injection SQL ; (b) l'injection SQL de la page de connexion du portail des transitaires, version 3.4 ; (c) un groupe qui vend des accès à des réseaux d'entreprise ; (d) la perte possible des données de 4 000 clients si le portail est compromis.

Exercice 9.2. Lire un vecteur ★★☆

Expliquez en français le vecteur suivant, métrique par métrique : `CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N`. Cette faille peut-elle servir de point d'entrée depuis Internet ? À quoi sert-elle typiquement

dans une attaque ?

✍ Exercice 9.3. Trois indicateurs ★★☆

Une faille a un score CVSS-B de 5,3, un EPSS de 0,92 et figure au catalogue KEV. Une autre a un score de 9,8, un EPSS de 0,001 et n'y figure pas.

(a) Laquelle corrigez-vous d'abord sur un serveur exposé à Internet ?

(b) Et si les deux étaient sur un serveur interne isolé ?

(c) Que manque-t-il pour décider avec certitude ?

✍ Exercice 9.4. Le contexte de NYANGA ★★★

(a) Expliquez pourquoi l'éditeur a coté SC, SI et SA à « nul » pour VULN-2024-4471, et pourquoi NYANGA aurait dû les coter autrement.

(b) Le 19 décembre 2024, quelle décision SSVC NYANGA aurait-elle dû prendre ? Justifiez chaque branche de l'arbre.

(c) Le jour de l'inscription au catalogue, l'EPSS de la faille dépassait 0,9 (valeur fictive). Ce chiffre ajoutait-il quelque chose à l'inscription ? Discutez.

● Note

Pour aller plus loin.

➢ La spécification CVSS 4.0 [16].

➢ Le site de l'EPSS [15] et le catalogue KEV [13].

➢ Le guide SSVC de la CISA [12].

● Note

Transition. Coter suppose d'avoir trouvé. Comment savoir quelles vulnérabilités on a, sans attaquer ses propres systèmes ? Chapitre 10.

10

IDENTIFIER LES VULNÉRABILITÉS SANS LES EXPLOITER

« Un outil de balayage ne trouve que ce qu'on lui montre,
et il ne montre que ce qu'il a su lire. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise du Chapitre 9

✦ Objectifs du chapitre

- ➢ Construire et tenir l'inventaire des actifs, condition de toute identification.
- ➢ Choisir entre balayage non authentifié, authentifié, agent et analyse de configuration.
- ➢ Reconnaître les faux positifs et les faux négatifs, et en connaître les causes.
- ➢ Encadrer un balayage : autorisation, périmètre, fenêtre, effets de bord.
- ➢ Mesurer la couverture d'un programme d'identification.

Avant de commencer : la liste des cibles

Bafoussam, avril 2025. Mme NDOUMBE cherche pourquoi l'outil de balayage de NYANGA CRÉDIT n'a jamais signalé la faille de la passerelle. L'outil était acheté, configuré et lancé chaque mois. Elle ouvre sa configuration : la liste des adresses à analyser est importée de la base de gestion des configurations, tenue par le DSI. La passerelle n'y figure pas. Elle a été installée en 2023 par un prestataire, dans une zone réseau à part, et personne ne l'a jamais déclarée. L'outil a fait exactement ce qu'on lui demandait.

★ Attention

Violation typique. Mesurer un programme de vulnérabilités au nombre de failles trouvées, sans mesurer la part du parc réellement analysée.

Règle : l'identification commence par l'inventaire et se juge à sa couverture. Un actif absent de l'inventaire, ou analysé sans succès, est un NEK : on ne sait rien de ses failles.

© MaletYon

10.1 L'Inventaire d'Abord

On ne corrige que ce que l'on connaît. L'inventaire des actifs (matériels, systèmes, logiciels et services) est le premier contrôle de tout programme, et le plus souvent défaillant. Il se construit en croisant plusieurs sources, parce qu'aucune n'est complète.

Source	Ce qu'elle voit	Ce qu'elle manque
Base de gestion des configurations	Ce qui a été déclaré	Ce qui a été installé sans déclaration
Annuaire (Active Directory)	Machines Windows du domaine	Équipements réseau, Linux, appareils hors domaine
Serveur DHCP	Appareils qui demandent une adresse	Adresses fixes
Découverte réseau (balayage des plages)	Tout ce qui répond	Ce qui est éteint, filtré ou hors des plages
Console des fournisseurs en nuage	Ressources en nuage	Ce qui est ailleurs

Tableau 10.1. Les sources de l'inventaire

Scénario Opérationnel · Opération SOLITRANS. Les 132 inconnus

Constatations. La base de gestion des configurations déclare 1 380 actifs. La découverte réseau des plages du siège, de Bonabéri et de Kribi, croisée avec l'annuaire et le serveur DHCP, en trouve 1 512. Les 132 actifs non déclarés comprennent 41 caméras et enregistreurs vidéo, 28 terminaux de pesage et de lecture de conteneurs, 19 postes de prestataires, 17 imprimantes, 14 commutateurs et 13 appareils non identifiés.

Analyse (confiance élevée). Un actif sur onze échappait à toute analyse. Les catégories manquantes sont celles qu'installent les prestataires ou les services métier, comme la passerelle de NYANGA.

10.2 Quatre Façons d'Identifier

Méthode	Principe	Force	Faiblesse
Balayage non authentifié	Interroger les services ouverts depuis le réseau, lire bannières et réponses	Voit ce que voit un attaquant	Déduit les versions, faux positifs nombreux
Balayage authentifié	Se connecter avec un compte en lecture et lire les paquets installés	Précis sur les versions et correctifs	Exige un compte ; échecs de connexion silencieux
Agent	Programme installé sur la machine, qui remonte son état	Couvre les portables hors réseau	À déployer et maintenir
Analyse de configuration	Comparer la configuration à une référence (CIS Benchmarks)	Trouve les réglages dangereux, sans CVE	Ne voit pas les failles logicielles

Tableau 10.2. Quatre méthodes d'identification

Aucune de ces méthodes n'exploite la faille. Elles constatent qu'un logiciel vulnérable est présent, ou qu'un réglage est dangereux. Démontrer qu'un attaquant peut s'en servir relève du test d'intrusion, conduit dans un autre cadre (UE MSN-2S3-SEC03). Le guide NIST SP 800-115 [42] décrit les deux familles et leurs précautions.

Note

Les composants logiciels. Une application peut embarquer une bibliothèque vulnérable sans que le système d'exploitation le sache. Les outils d'analyse de composants lisent les fichiers de l'application, ou une liste de ses composants fournie par l'éditeur, pour retrouver ces bibliothèques. Un balayage classique ne les voit pas.

10.3 Faux Positifs, Faux Négatifs

Définition

Faux positif : vulnérabilité signalée alors qu'elle est absente. **Faux négatif** : vulnérabilité présente et non signalée.

Les faux positifs coûtent du temps et de la crédibilité : une équipe système qui corrige trois failles inexistantes cesse de croire le rapport. Les faux négatifs coûtent plus cher, parce qu'ils ne se voient pas.

Cause de faux positif	Cause de faux négatif
Correctif rétroporté : la distribution corrige sans changer le numéro de version	Actif absent de la liste des cibles
Bannière de service modifiée ou générique	Authentification échouée, analyse réduite au non authentifié
Composant présent mais non utilisé	Service filtré par un pare-feu entre l'outil et la cible
Règle de détection trop large	Règle de détection absente pour la faille ou le produit

Tableau 10.3. Les causes d'erreur d'un balayage

Note

Vérifier un constat avant de le transmettre

1. Relire la preuve donnée par l'outil : version lue, réponse du service, paquet installé.
2. Confirmer la version par une autre voie (connexion à la machine, console d'administration).
3. Vérifier les bulletins de la distribution pour un éventuel correctif rétroporté.
4. Confirmer que le composant vulnérable est actif.
5. Coter le constat : confirmé, faux positif, ou non vérifiable.

Scénario Opérationnel · Opération SOLITRANS. Soixante constats vérifiés

Constatations. Après dédoublonnage (une même faille signalée par plusieurs règles, ou sur plusieurs ports d'un même actif), les 3 812 constats bruts deviennent 2 947. Mme EBODE fait vérifier un échantillon de 60 constats tirés au hasard : 46 sont confirmés, 9 sont des faux positifs (dont 7 correctifs rétroportés sur des serveurs Linux), 5 ne sont pas vérifiables faute d'accès à la machine. Par ailleurs, l'authentification a réussi sur 78 % des serveurs ; sur les autres, l'outil s'est contenté d'un balayage non authentifié sans le signaler dans le résumé.
Analyse (confiance moyenne, l'échantillon étant petit). Environ 15 % des constats seraient des faux positifs. Et 22 % des serveurs ont été analysés de façon superficielle : le nombre de failles réelles sur ces serveurs est NEK, sans doute supérieur à ce que dit le rapport.

10.4 Encadrer un Balayage

Un balayage interroge des machines, parfois des milliers de fois. Il peut ralentir un service, saturer un équipement fragile ou déclencher des alertes. Et il touche au droit : analyser

un système sans autorisation peut constituer un accès non autorisé (loi n° 2010/012, art. 65 al. 2, voir Chapitre 8).

Élément	Contenu
Autorisation écrite	Signée par le propriétaire des actifs, et par l'hébergeur ou le prestataire quand l'actif n'appartient pas à l'organisation
Périmètre	Plages d'adresses, exclusions motivées, actifs fragiles
Fenêtre	Jours et heures, compatibles avec l'activité
Profil	Intensité, tests exclus (déni de service), comptes utilisés
Contacts	Personne à joindre en cas d'effet de bord, de part et d'autre
Information	Équipe de supervision prévenue, pour ne pas confondre le balayage avec une attaque

Tableau 10.4. Le cadre d'un balayage

Scénario Opérationnel · Opération SOLITRANS. Le terminal de pesage

Constatations. Le 18 mai 2025 à 10 h 20, pendant le balayage du site de Bonabéri, un terminal de pesage des conteneurs cesse de répondre. La file des camions s'allonge pendant quarante minutes, jusqu'au redémarrage manuel. Le terminal, non déclaré dans la base, n'était pas exclu du périmètre.
Analyse (confiance élevée). Les équipements industriels et portuaires supportent mal les balayages agressifs. Ils doivent être inventoriés, exclus du balayage actif ou analysés avec un profil léger, en dehors des heures d'exploitation.

10.5 Mesurer la Couverture

Lecture auditologique · La couverture de SOLITRANS en mai 2025

Question	Valeur	Cote
Tous les actifs sont inventoriés	1 380 sur 1 512	NON
Tous les actifs inventoriés ont été analysés	1 342 sur 1 380	NON
Les serveurs ont été analysés avec authentification	78 %	NON
Les constats sont vérifiés	Échantillon de 60	NEK
Les actifs fragiles sont protégés des effets de bord	Incident du 18 mai	NON

Lecture. Quatre NON et un NEK : le premier balayage dit beaucoup sur les actifs

analysés et presque rien sur la part du parc qui lui a échappé. Mme EBODE présente au comité le nombre de failles *et* ces cinq lignes. Le premier chantier n'est pas la correction, c'est l'inventaire.

10.6 Ce que l'Identification demande à chaque Métier

Application Analyste en gestion des vulnérabilités

Identifier sans exploiter

1. Construire l'inventaire en croisant au moins trois sources.
2. Préférer le balayage authentifié, et suivre le taux de réussite de l'authentification.
3. Dédoublonner, puis vérifier un échantillon pour estimer les faux positifs.
4. Exclure ou ménager les actifs fragiles, avec l'accord des métiers.
5. Publier la couverture avec le nombre de failles.

Application RSSI

Exiger de chaque prestataire qui installe un équipement sa déclaration à l'inventaire, dans le contrat même. La passerelle de NYANGA et les 132 inconnus de SOLITRANS ont la même origine.

Application Analyste en réponse à incident

L'inventaire et l'historique des balayages servent aussi l'enquête : ils datent l'apparition d'une version vulnérable et montrent depuis quand une faille était visible, ou invisible.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- ➢ L'identification commence par l'inventaire, construit en croisant plusieurs sources.
- ➢ Balayage non authentifié, authentifié, agent et analyse de configuration se complètent ; aucun n'exploite la faille.
- ➢ Les faux positifs se vérifient sur échantillon ; les faux négatifs se combattent par la couverture.
- ➢ Un balayage s'encadre : autorisation écrite, périmètre, fenêtre, profil, contacts.

➢ Chez SOLITRANS, un actif sur onze était inconnu et 22 % des serveurs analysés sans authentification.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

➢ dire pourquoi un actif hors inventaire est un NEK ;

➢ expliquer un correctif rétroporté et ses effets sur un rapport ;

➢ rédiger le cadre d'un balayage.

Exercices

✍ Exercice 10.1. Quelle méthode ? ★☆☆

Choisissez une méthode d'identification pour : (a) les portables des commerciaux, rarement au bureau ; (b) les serveurs Linux du siège ; (c) le portail des transitaires vu d'Internet ; (d) la configuration des commutateurs ; (e) une application métier qui embarque des bibliothèques open source.

✍ Exercice 10.2. Faux positif ou pas ★★☆

L'outil signale sur un serveur Debian une faille d'OpenSSH corrigée dans la version 9.6, alors que le serveur annonce la version 9.2.

(a) Pourquoi ce constat peut-il être un faux positif ?

(b) Comment le vérifier sans exploiter la faille ?

(c) Comment cotez-vous le constat avant et après vérification ?

✍ Exercice 10.3. La couverture ★★☆

À partir de l'encadré « La couverture de SOLITRANS en mai 2025 » :

(a) Calculez le taux de couverture global (actifs analysés sur actifs existants).

(b) Si les 15 % de faux positifs se confirment, combien des 2 947 constats seraient réels ?

(c) Pourquoi ce second chiffre est-il probablement trop bas ?

✍ Exercice 10.4. La passerelle invisible ★★★

(a) Décrivez trois contrôles qui auraient fait entrer la passerelle de NYANGA dans le périmètre du balayage.

(b) Une analyse non authentifiée de la passerelle, depuis Internet, aurait-elle détecté

VULN-2024-4471 ? À quelles conditions ?

(c) Rédigez le cadre (Tableau 10.4) d'un balayage mensuel de la zone réseau de la passerelle, installée et maintenue par un prestataire.

Note

Pour aller plus loin.

- Le NIST SP 800-115 [42], sur les techniques d'évaluation.
- Les CIS Benchmarks [8], pour les références de configuration.

Note

Transition. SOLITRANS connaît désormais près de trois mille failles, et sait qu'elle ne les connaît pas toutes. Lesquelles corriger d'abord, dans quels délais, et comment suivre ? Chapitre 11.

11

GÉRER LES VULNÉRABILITÉS

« Une vulnérabilité corrigée est une vulnérabilité dont on a vérifié la correction. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise des Chapitres 9 et 10

✦ Objectifs du chapitre

- ➢ Décrire le cycle de gestion des vulnérabilités, de l'identification à la vérification.
- ➢ Rédiger une politique de priorité qui combine exploitation, exposition et importance de l'actif, avec des délais.
- ➢ Choisir entre correctif, changement de configuration et mesure compensatoire.
- ➢ Gérer une exception : propriétaire, durée, mesure compensatoire, revue.
- ➢ Construire et lire les indicateurs d'un programme.

Avant de commencer : quarante failles par semaine

Douala, juin 2025. Mme EBODE présente sa politique au comité de direction de SOLITRANS. Elle ne propose pas de corriger plus : l'équipe système de M. FOUDA traite environ quarante failles par semaine, et rien ne permettra de doubler ce rythme avant l'an prochain. Elle propose de corriger dans le bon ordre, avec des délais écrits, et de vérifier ce qui est fait. Le directeur financier demande combien de failles resteront ouvertes à la fin de l'année. Elle répond qu'il en restera beaucoup, et qu'elle saura dire lesquelles, pourquoi, et qui en a accepté le risque.

★ Attention

Violation typique. Déclarer une faille corrigée sur la foi du ticket fermé par l'équipe système, sans nouvelle analyse de l'actif.

Règle : une correction se vérifie par un nouveau balayage, ou par une lecture directe de la version installée. Le ticket fermé est une déclaration ; le balayage qui ne trouve plus la faille est une constatation.

© MaletYon

11.1 Le Cycle de Gestion

Le guide NIST SP 800-40 [44] présente la gestion des correctifs comme une maintenance préventive, planifiée, et non comme une suite d'urgences. La mesure 8.8 de l'ISO/IEC 27002:2022 [27], consacrée à la gestion des vulnérabilités techniques, demande d'obtenir l'information sur les vulnérabilités, d'évaluer l'exposition de l'organisation et de prendre les mesures appropriées (paraphrase).

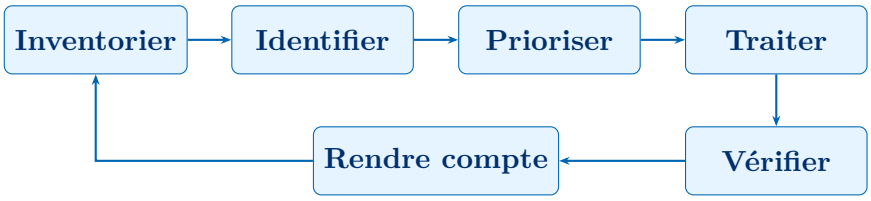


Figure 11.1. Le cycle de gestion des vulnérabilités

Traiter ne veut pas toujours dire corriger. Quatre voies existent.

Voie	Exemple	Condition
Correctif	Mise à jour de l'éditeur	Testé, appliqué dans une fenêtre, retour arrière prévu
Configuration	Désactiver le service vulnérable, changer un réglage	Fonction non utilisée, ou réglage documenté par l'éditeur
Mesure compensatoire	Filtrage réseau, restriction d'accès, règle de pare-feu applicatif	Temporaire, en attendant le correctif
Acceptation	Exception formelle	Propriétaire, durée, revue (section 11.4)

Tableau 11.1. Les quatre voies de traitement

11.2 La Politique de Priorité

Une politique de priorité traduit en règles écrites ce que le Chapitre 9 a montré : l'exploitation et l'exposition comptent davantage que le score seul.

Scénario Opérationnel · Opération SOLITRANS. La politique de juin 2025

Classe	Règle d'entrée	Délai	Décideur d'exception
P1	Inscrite au catalogue KEV, ou EPSS $\geq 0{,}5$, sur un actif exposé à Internet ou critique	7 jours	Directeur général
P2	Inscrite au catalogue KEV sur un actif interne, ou CVSS-B $\geq 9{,}0$ sur un actif exposé	15 jours	RSSI
P3	CVSS-B $\geq 7{,}0$, hors P1 et P2	30 jours	RSSI
P4	Autres constats confirmés	90 jours	Responsable des vulnérabilités

Constatations. Appliquée aux 2 947 constats de mai, la politique place 38 constats en P1, 211 en P2, 904 en P3 et 1 794 en P4. À quarante corrections par semaine, les 249 constats P1 et P2 demandent un peu plus de six semaines, bien au-delà du délai de 15 jours fixé pour les P2.
Analyse (confiance élevée). La politique est tenable pour les P1, pas encore pour le stock initial de P2 : Mme EBODE demande un renfort temporaire de deux semaines, et la fixation du délai à partir de la date d'entrée en vigueur pour le stock existant.

Note

Les délais courent depuis quand ? Le délai d'une faille se compte à partir du moment où l'organisation pouvait la connaître : la publication du correctif, ou la première détection sur son parc, selon la règle choisie. Une politique qui ne le précise pas permet de repousser indéfiniment l'échéance.

11.3 Corriger en Production

Un correctif peut casser une application. C'est la raison la plus souvent donnée pour ne pas l'appliquer, et elle est parfois exacte. La réponse n'est pas de renoncer, mais d'organiser : un environnement de test qui reproduit la production pour les applications critiques, des fenêtres de maintenance connues des métiers, une procédure de retour arrière éprouvée, et un ordre de déploiement par vagues (d'abord quelques machines représentatives, puis le reste).

Note

Déployer un correctif de classe P1

1. Lire le bulletin : versions touchées, prérequis, effets connus.
2. Appliquer une mesure compensatoire immédiate si le correctif demande plus de 24 heures.
3. Tester sur une machine représentative, avec le propriétaire métier.
4. Déployer par vagues, en surveillant les services.
5. Vérifier par un nouveau balayage authentifié de chaque actif.
6. Lever la mesure compensatoire, et clore le constat avec la preuve.

11.4 Les Exceptions

Certaines failles ne peuvent pas être corrigées dans le délai : le correctif n'existe pas, l'éditeur ne maintient plus le produit, ou l'application métier ne fonctionne pas avec la version corrigée. L'exception transforme ce fait en décision.

Définition

Exception : décision écrite par laquelle un responsable habilité accepte, pour une durée limitée, qu'une vulnérabilité reste ouverte au-delà du délai, avec une mesure compensatoire et une date de revue.

Scénario Opérationnel · Opération SOLITRANS. Quatre exceptions

Réf.	Faille et actif	Mesure compensatoire	Durée	Décideur
E-01	P2, logiciel de dédouanement en fin de support	Accès limité à trois postes, réseau isolé	6 mois	RSSI
E-02	P3, terminaux de pesage, aucun correctif	Filtrage strict, aucun accès Internet	12 mois	RSSI
E-03	P1, portail des transitaires, correctif incompatible	Règle de pare-feu applicatif	30 jours	Directeur général
E-04	P3, serveur d'archives	Aucune	Sans limite	Non signée

Analyse (confiance élevée). E-01 à E-03 sont des exceptions. E-04 n'en est pas une : sans mesure, sans durée et sans signature, c'est une faille ouverte que personne

n'assume. Elle redevient un constat en retard.

11.5 Mesurer le Programme

Indicateur	Définition	Piège
Délai de correction	Durée médiane entre détection et correction vérifiée, par classe	La moyenne masque les cas extrêmes
Respect des délais	Part des constats corrigés dans le délai de leur classe	À calculer sur les constats échus
Couverture	Part des actifs existants analysés avec authentification	Souvent omise
KEV ouvertes	Nombre de failles du catalogue encore ouvertes	Le seul indicateur à suivre chaque semaine
Âge du stock	Âge des constats ouverts, par tranche	Le stock vieillit sans bruit

Tableau 11.2. Les indicateurs d'un programme

Lecture auditologique · SOLITRANS, trois trimestres

Indicateur	T3 2025	T4 2025	T1 2026
Couverture authentifiée	71 %	84 %	93 %
Délai médian P1 (jours)	11	6	5
P1 corrigées dans le délai	58 %	81 %	92 %
P2 corrigées dans le délai	34 %	63 %	77 %
KEV ouvertes en fin de trimestre	14	5	2
Exceptions en cours, toutes signées	NON	OUI	OUI

Lecture. Le programme progresse sur toutes les lignes. La couverture passe de 71 à 93 % : une partie des nouvelles failles du T4 vient simplement de ce que l'on regarde mieux, et la hausse apparente du stock ne traduit pas une dégradation. Les deux KEV ouvertes au T1 2026 sont les terminaux de pesage, sous l'exception E-02.

Scénario Opérationnel · Opération NYANGA. Septembre 2025

Constatations. Six mois après l'incident, NYANGA CRÉDIT adopte la méthode de SOLITRANS : inventaire croisé (la passerelle et quatorze autres équipements y entrent), balayage authentifié mensuel, politique en quatre classes, suivi hebdomadaire des KEV. Mme NDOUMBE devient aussi responsable du programme.
Analyse (confiance moyenne). Avec cette politique, VULN-2024-4471 aurait été

classée P1 le 19 décembre 2024, avec une échéance au 26 décembre, soit plus de deux mois avant le premier accès.

11.6 Ce que la Gestion demande à chaque Métier

Application Analyste en gestion des vulnérabilités

Tenir le programme

1. Classer chaque constat confirmé selon la politique écrite.
2. Suivre chaque semaine les failles du catalogue KEV ouvertes.
3. Vérifier chaque correction par un nouveau balayage.
4. Instruire les exceptions et rappeler leurs dates de revue.
5. Publier les indicateurs avec la couverture.

Application RSSI

Faire approuver la politique et les délais par la direction, et signer les exceptions de son niveau. Refuser une exception sans mesure compensatoire ni durée : elle ne protège personne, sauf de la responsabilité.

Application Analyste en réponse à incident

Après un incident, vérifier que la faille exploitée est corrigée partout où elle existe, et pas seulement sur la machine compromise.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Le cycle va de l'inventaire à la vérification ; traiter peut vouloir dire corriger, reconfigurer, compenser ou accepter.
- Une politique écrite classe les failles par exploitation, exposition et importance, avec des délais datés.
- Une exception a un décideur, une mesure compensatoire, une durée et une revue ; sinon, c'est un retard.
- Une correction se vérifie par un nouveau balayage ; un ticket fermé ne suffit pas.
- Les indicateurs se lisent avec la couverture : une hausse des failles peut traduire un meilleur regard.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- ➢ classer une faille dans une politique en quatre classes ;
- ➢ distinguer une exception d'un retard ;
- ➢ interpréter une hausse du nombre de failles quand la couverture augmente.

Exercices

✍ Exercice 11.1. Classer ★☆☆

Avec la politique de SOLITRANS, classez : (a) faille inscrite au catalogue KEV sur le portail des transitaires ; (b) faille de score 9,4 sur un serveur interne, non exploitée ; (c) faille de score 7,2 sur un poste ; (d) faille inscrite au catalogue KEV sur un serveur interne ; (e) faille de score 5,0 sur une imprimante.

✍ Exercice 11.2. Le stock de P2 ★★☆

(a) Vérifiez le calcul de l'encadré « La politique de juin 2025 » : combien de semaines pour absorber les P1 et les P2 à quarante corrections par semaine ?

(b) Combien de corrections par semaine faudrait-il pour traiter les 211 P2 en 15 jours, après les 38 P1 ?

(c) Proposez deux solutions autres que le renfort.

✍ Exercice 11.3. Instruire une exception ★★☆

Le portail des transitaires présente une faille P1 ; le correctif casse le module de facturation, et l'éditeur annonce une version compatible dans six semaines. Rédigez la demande d'exception complète, et dites qui doit la signer.

✍ Exercice 11.4. Lire les indicateurs ★★★

Au T4 2025, le nombre total de failles ouvertes de SOLITRANS augmente de 12 % alors que tous les indicateurs de délai s'améliorent.

(a) Proposez deux explications compatibles avec l'encadré « SOLITRANS, trois trimestres ».

(b) Comment les départager ?

(c) Rédigez la phrase du rapport trimestriel qui présente ce chiffre au comité sans l'alarmer à tort ni le rassurer à tort.

Note

Pour aller plus loin.

- Le NIST SP 800-40 [44].
- L'ISO/IEC 30111 [25] et l'ISO/IEC 29147 [24], pour le traitement et la divulgation du côté des éditeurs.

Note

Transition. Le programme de SOLITRANS empêche les incidents ; l'enquête de NYANGA en explique un. Le Chapitre 12 relie les deux : comment remonter d'une trace à la faille qui l'a permise.

12

DE L'ARTEFACT À LA VULNÉRABILITÉ

« Trouver par où l'attaquant est entré, c'est la moitié de l'enquête. Comprendre pourquoi la porte était ouverte, c'est l'autre moitié. »

Principe du cours

Niveau : *Intermédiaire à expert* • Maîtrise des Chapitres 7 et 11

✦ Objectifs du chapitre

- Remonter d'un artefact au mécanisme qui l'a produit, et de ce mécanisme à une vulnérabilité identifiée.
- Confronter des traces aux indicateurs publiés par un éditeur.
- Examiner un équipement de bordure dont le système n'est pas accessible, et en dire les limites.
- Distinguer cause immédiate, causes contributives et cause profonde.
- Rechercher les variantes d'une faille dans le reste du parc.
- Transformer les enseignements d'une enquête en règles du programme de vulnérabilités.

Avant de commencer : une session sans mot de passe

Yaoundé, 6 avril 2025. Trois semaines d'enquête ont établi la séquence de l'attaque. Il reste un point que M. ABOUBAKAR ne veut pas laisser à l'inférence : la première session du compte `svc_backup`, le 2 mars, s'est ouverte sans aucun échec d'authentification. Soit l'attaquant connaissait le mot de passe, soit il n'en a pas eu besoin. La réponse détermine la cause de l'incident, et elle pèse sur la question encore ouverte de la participation d'un employé.

★ Attention

Violation typique. Désigner la faille la plus connue du moment comme cause de l'incident, parce qu'elle touche le produit en cause, sans confronter les traces à ses indicateurs.

© MaletYon

Règle : une vulnérabilité n'est la cause d'un incident que si les traces portent sa signature, décrite par l'éditeur ou par un tiers compétent, et si les autres explications sont écartées.

12.1 Trois Explications pour une Session

Explication	Traces attendues	Traces observées
E1 : mot de passe connu (fuite, employé, devinette)	Session directe, sans requête inhabituelle avant	Requêtes inhabituelles avant la session
E2 : exploitation de VULN-2024-4471	Requêtes vers le chemin décrit dans le bulletin, puis session sans authentification	Quatre requêtes de ce type, puis la session
E3 : vol de jeton d'une session légitime	Session légitime de `svc_backup` juste avant	Aucune session légitime depuis 9 jours

Tableau 12.1. Trois explications de la session du 2 mars

Le bulletin publié par l'éditeur le 12 décembre 2024 décrit la faille, les versions touchées (jusqu'à 7.2.4) et des **indicateurs de compromission** : la forme particulière des requêtes HTTP envoyées à la passerelle lors de l'exploitation, et leur trace dans son journal. C'est la signature à rechercher.

Scénario Opérationnel · Opération NYANGA. La signature du 2 mars

Constatations.

- L'export de configuration de la passerelle, réalisé le 14 mars (scellé NC-02), indique le micrologiciel 7.2.1, compris dans les versions touchées.
- Le journal de la passerelle enregistre, le 2 mars entre 23 h 46 et 23 h 48 (heures corrigées), quatre requêtes depuis 203.0.113.18 vers le chemin désigné par le bulletin comme indicateur d'exploitation, suivies de la session de `svc_backup`.
- Aucune requête de ce type n'apparaît ailleurs dans les 60 jours du journal.
- Le mot de passe de `svc_backup`, long de 24 caractères, n'a pas changé depuis 2022 et n'apparaît dans aucune fuite connue consultée.

Analyse (confiance élevée). Les traces portent la signature de VULN-2024-4471 et précèdent immédiatement la session. E2 explique la session sans authentification ;

E1 ne l'explique pas sans supposer, en plus, que l'attaquant connaissait un mot de passe qu'il n'a pas eu à saisir ; E3 est écartée.

Lecture auditologique · Les trois explications au 6 avril

Proposition	Cote
E2 : la session du 2 mars résulte de l'exploitation de VULN-2024-4471	OUI
E3 : la session résulte d'un vol de jeton d'une session légitime	NON
E1 : l'attaquant connaissait le mot de passe de `svc_backup`	NEK
Un employé a participé à l'attaque	NEK

Lecture. E1 reste NEK : qu'on n'ait pas eu besoin du mot de passe ne prouve pas qu'on l'ignorait. Mais l'hypothèse perd son utilité : l'entrée s'explique sans elle. La participation d'un employé reste NEK, et elle le restera tant que l'identité des auteurs l'est ; l'enquête ne dispose d'aucune pièce qui la soutienne.

12.2 Examiner un Équipement de Bordure

Les passerelles d'accès, les pare-feu et les routeurs sont des appliances : leur système est fermé, souvent sans accès au disque ni à la mémoire. L'enquêteur dispose de ce que l'équipement veut bien exporter.

Pièce	Ce qu'elle apporte	Limite
Export de configuration	Version, comptes, règles, réglages	Instantané au moment de l'export
Journaux exportés	Sessions, requêtes, erreurs	Rotation, niveau de détail choisi
Outil d'intégrité de l'éditeur	Comparaison des fichiers système avec les fichiers d'origine	Disponible pour certains produits seulement
Image du système, avec l'aide de l'éditeur	Examen complet	Rare, lent, dépend de l'éditeur

Tableau 12.2. Les pièces d'un équipement de bordure

Un attaquant qui contrôle une passerelle peut y avoir laissé un mécanisme de retour qui survit à la mise à jour. Sans outil d'intégrité ni image du système, la proposition « la passerelle ne contient plus de code de l'attaquant » reste NEK. À NYANGA, l'éditeur ne fournissait pas d'outil d'intégrité pour la version 7.2 : la passerelle a été remplacée par un équipement neuf, et l'ancienne conservée sous scellé.

12.3 Cause Immédiate, Causes Contributives, Cause Profonde

Définition

Cause immédiate : l'événement qui a directement permis l'incident. **Cause contributive** : condition qui a aggravé l'incident ou en a facilité une étape. **Cause profonde** : défaut d'organisation qui a laissé subsister la cause immédiate et les causes contributives ; la corriger empêche des incidents semblables.

La méthode des cinq pourquoi aide à descendre de la cause immédiate vers la cause profonde : on demande « pourquoi ? » à chaque réponse, jusqu'à atteindre une décision ou une absence de décision de l'organisation.

Scénario Opérationnel · Opération NYANGA. Cinq pourquoi

1. Pourquoi l'attaquant est-il entré ? Parce que la passerelle présentait VULN-2024-4471.
2. Pourquoi la faille était-elle présente ? Parce que le correctif du 15 décembre n'avait pas été appliqué.
3. Pourquoi n'avait-il pas été appliqué ? Parce que personne ne savait que la passerelle était concernée : elle n'apparaissait dans aucun rapport de balayage.
4. Pourquoi n'apparaissait-elle pas ? Parce qu'elle était absente de la base de gestion des configurations, qui fournissait la liste des cibles.
5. Pourquoi était-elle absente ? Parce qu'aucune règle n'obligeait un prestataire à déclarer les équipements qu'il installe, ni personne à vérifier l'inventaire contre le réseau réel.

Lecture auditologique · L'arbre des causes de NYANGA

Cause	Type	Établie
VULN-2024-4471 non corrigée sur la passerelle	Immédiate	OUI
`svc_backup` membre des administrateurs du domaine	Contributive	OUI
Aucune authentification à deux facteurs sur la passerelle	Contributive	OUI
Identifiants d'administration présents en mémoire du contrôleur	Contributive	OUI
Clé de l'interface de paiement en clair dans `api.ini`	Contributive	OUI
Journaux de la passerelle conservés 60 jours	Contributive (enquête)	OUI
Inventaire non confronté au réseau réel, prestataires non tenus de déclarer	Profonde	OUI

Lecture. Sept causes, toutes établies par des pièces. Corriger la seule cause immédiate (appliquer le correctif) laisserait intactes les six autres : la prochaine faille d'un équipement non déclaré aurait le même effet. La recommandation principale du rapport porte sur la cause profonde.

Note

L'authentification à deux facteurs n'aurait pas suffi. VULN-2024-4471 contourne l'authentification : un second facteur, vérifié par le même mécanisme défaillant, aurait pu être contourné aussi. On la classe en cause contributive parce qu'elle aurait gêné les sessions ultérieures sur d'autres comptes, pas parce qu'elle aurait empêché l'entrée. Le rapport doit le dire, pour ne pas vendre une mesure pour ce qu'elle n'est pas.

12.4 Chercher les Variantes

Une faille exploitée chez soi se cherche ensuite partout où elle peut exister. C'est l'**analyse de variantes** : la même vulnérabilité sur d'autres équipements, la même faiblesse dans d'autres produits, la même cause profonde ailleurs.

Scénario Opérationnel · Opération NYANGA. Septembre 2025

Constatations. L'inventaire croisé de septembre 2025 (Chapitre 11) fait entrer quinze équipements dans la base. Parmi eux, trois équipements de bordure (deux routeurs d'agence et un point d'accès de télémaintenance) présentent des failles

inscrites au catalogue KEV, non corrigées depuis plus de six mois. Une recherche dans les fichiers des serveurs trouve deux autres clés d'interface en clair, pour la messagerie d'alerte et pour un service de change.
Analyse (confiance élevée). La cause profonde produisait ses effets ailleurs : trois autres portes ouvertes, deux autres clés exposées. L'enquête sur un incident en a évité au moins un autre.

12.5 Des Enseignements aux Règles

L'ISO/IEC 27035 [28] et le guide NIST SP 800-61 [9] font des enseignements tirés d'un incident une étape à part entière. Ils ne valent que s'ils deviennent des règles vérifiables.

Enseignement	Règle du programme de NYANGA (septembre 2025)
Un équipement non déclaré n'est pas analysé	Découverte réseau mensuelle de toutes les plages, écarts avec la base traités sous 15 jours
Les équipements de bordure sont la porte d'entrée	Toute faille inscrite au catalogue KEV sur un équipement exposé est classée P1, délai 72 heures
Un prestataire installe sans déclarer	Clause contractuelle de déclaration et d'accès au balayage
Les journaux de la passerelle ont failli disparaître	Conservation de dix ans des données de connexion (loi n° 2010/012, art. 29)
Une clé en clair a permis les virements	Coffre de secrets pour toutes les clés d'interface, recherche trimestrielle de secrets en clair

Tableau 12.3. Des enseignements aux règles

12.6 Ce que la Remontée demande à chaque Métier

Application Analyste en réponse à incident

Remonter à la vulnérabilité

1. Lister toutes les explications du premier accès.
2. Pour chacune, écrire les traces attendues.
3. Confronter les traces aux indicateurs publiés par l'éditeur.
4. Coter chaque explication, et écrire ce qui reste NEK.
5. Construire l'arbre des causes jusqu'à la cause profonde.
6. Lancer la recherche de variantes dans tout le parc.

Application Analyste en gestion des vulnérabilités

Recevoir chaque rapport d'incident comme une mesure de son programme : la faille exploitée était-elle connue, classée, dans le délai ? Chaque réponse « non » appelle une règle nouvelle.

Application Application OPJ/Expert Judiciaire

L'expert établit le mécanisme d'entrée parce qu'il répond à l'article 69 de la loi n° 2010/012 (violation des mesures de sécurité). Il ne juge pas la diligence de la victime, sauf si sa mission le lui demande.

Application RSSI

Présenter à la direction l'arbre des causes complet, et faire décider la correction de la cause profonde. Un correctif appliqué en une heure ne clôt pas l'incident ; une règle d'inventaire tenue chaque mois le clôt.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Une vulnérabilité est la cause d'un incident quand les traces portent sa signature et que les autres explications sont écartées.
- Un équipement de bordure s'examine par ses exports ; ce qu'on ne peut pas lire reste NEK.
- On distingue cause immédiate, causes contributives et cause profonde ; la recommandation principale vise la cause profonde.
- L'analyse de variantes cherche la même faille et la même cause ailleurs.
- Un enseignement ne vaut que transformé en règle vérifiable.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- confronter des traces aux indicateurs d'un bulletin ;
- construire un arbre des causes à trois niveaux ;
- rédiger une règle de programme à partir d'un enseignement.

Exercices

✍ Exercice 12.1. Immédiate, contributive, profonde ★☆☆

Classez : (a) le correctif non appliqué ; (b) l'absence de règle de déclaration des équipements ; (c) la clé en clair dans `api.ini` ; (d) le compte `svc_backup` trop privilégié ; (e) la durée de conservation des journaux.

✍ Exercice 12.2. Une autre signature ★★☆

Supposez que le journal de la passerelle n'ait montré aucune requête vers le chemin du bulletin, mais trois échecs d'authentification de `svc_backup` depuis 203.0.113.18, puis une session réussie.

(a) Comment cotez-vous E1 et E2 ?

(b) Quelle cause immédiate retenez-vous alors, et quelles causes contributives changent ?

(c) Que devient la question de la participation d'un employé ?

✍ Exercice 12.3. Les cinq pourquoi de SOLITRANS ★★☆

Le terminal de pesage de Bonabéri a cessé de répondre pendant un balayage (Chapitre 10). Appliquez la méthode des cinq pourquoi et identifiez la cause profonde. Proposez la règle qui en découle.

✍ Exercice 12.4. La passerelle sous scellé ★★★

(a) Pourquoi a-t-on remplacé la passerelle au lieu de simplement la mettre à jour ?

(b) Quelles questions l'ancienne passerelle, conservée sous scellé, pourrait-elle encore trancher, et avec l'aide de qui ?

(c) Rédigez le paragraphe du rapport d'expertise qui établit la violation des mesures de sécurité au sens de l'article 69, en séparant constatation et analyse.

● Note

Pour aller plus loin.

➢ L'ISO/IEC 27035 [28], sur la gestion des incidents et leurs enseignements.

➢ Le NIST SP 800-61 [9], section sur l'activité post-incident.

● Note

Transition. L'attaquant de NYANGA n'a presque rien effacé. Un attaquant plus soigneux maquille ses dates, vide les journaux, ou travaille dans des systèmes que l'enquêteur ne touche pas : Chapitre 13.

partie V

Défis Avancés

© *MaletYon*

13

ANTI-FORENSIQUE, NUAGE ET CONTENEURS

> « Effacer une trace en laisse une autre.
> Il faut savoir où la chercher. »
>
> — Principe du cours

Niveau : *Expert* • Maîtrise de la partie II

✦ Objectifs du chapitre

- ➢ Reconnaître les principales techniques d'anti-forensique et les traces qu'elles laissent.
- ➢ Détecter une falsification de dates par la confrontation des attributs NTFS et des journaux.
- ➢ Exploiter les traces d'un journal effacé.
- ➢ Conduire une acquisition dans un environnement en nuage, selon le modèle de responsabilité partagée.
- ➢ Préserver les traces d'un conteneur avant sa disparition.
- ➢ Coter NEK ce que l'environnement rend inaccessible.

Avant de commencer : un outil de 2017

Yaoundé, 28 mars 2025. Dans l'acquisition à froid de SRV-FIC01, M. FOTSO trouve l'outil de copie de l'attaquant : `upd.exe`, rangé dans un dossier de mises à jour. L'explorateur affiche une date de création du 4 juin 2017. Si elle est vraie, l'outil était sur le serveur bien avant l'attaque, et peut-être installé par quelqu'un de la maison. M. FOTSO ouvre l'enregistrement MFT du fichier.

★ Attention

Violation typique. Prendre pour acquise une date affichée par l'explorateur ou par un outil, sans la confronter aux autres sources qui datent le même fichier.

© MaletYon

Règle : une date se recoupe. Quand plusieurs sources indépendantes datent un même objet, leur désaccord est une constatation, et souvent la trace d'une manipulation.

13.1 Les Techniques d'Anti-forensique

Définition

Anti-forensique : ensemble des techniques qui visent à empêcher, retarder ou tromper l'investigation : effacer, masquer, falsifier ou rendre illisibles les traces.

Technique	Ce qu'elle fait	Trace qu'elle laisse
Effacement des journaux	Vide le journal de sécurité ou système	Événement 1102 ou 104, trou dans la numérotation, sources externes intactes
Falsification de dates	Réécrit les dates d'un fichier	Désaccord entre `$STANDARD_INFORMATION`, `$FILE_NAME` et `$UsnJrnl`
Effacement sécurisé	Écrase le contenu d'un fichier	Nom et dates dans la MFT et le `$UsnJrnl`, outil d'effacement lui-même
Chiffrement	Rend le contenu illisible	Le conteneur chiffré, l'outil, parfois la clé en mémoire
Exécution en mémoire, outils du système	N'écrit rien sur le disque, utilise `powershell`, `rundll32`	Mémoire, lignes de commande, journaux de script s'ils sont activés
Dissimulation	Cache des fichiers ou des processus	Écarts entre deux méthodes de lecture (`pslist` et `psscan`)

Tableau 13.1. Techniques d'anti-forensique et traces résiduelles

Le tableau montre une constante : chaque technique déplace la trace plus qu'elle ne la supprime. L'enquêteur cherche donc là où l'attaquant ne pense pas ou ne peut pas agir : les journaux centralisés hors de la machine, la mémoire, les structures internes du système de fichiers, les équipements réseau.

13.2 Détecter une Falsification de Dates

Les outils de falsification réécrivent en général les dates de `$STANDARD_INFORMATION`, que tout programme peut modifier. Les dates de `$FILE_NAME` et les entrées du `$UsnJrnl` sont plus difficiles à atteindre. Trois indices orientent l'examen : une date de création antérieure à l'installation du système, des fractions de seconde toutes nulles (les outils écrivent souvent des secondes rondes), et un désaccord entre les attributs.

Scénario Opérationnel · Opération NYANGA. L'outil upd.exe

Source	Date de création	Fractions
`$STANDARD_INFORMATION`	04/06/2017 09:12:00	,0000000
`$FILE_NAME`	13/03/2025 23:58:41	,3318274
`$UsnJrnl`, création du fichier	13/03/2025 23:58:41	
Installation du système (registre)	17/01/2020	

Constatations. La date de `$STANDARD_INFORMATION` précède de deux ans et demi l'installation du système, et ses fractions sont nulles. `$FILE_NAME` et le `$UsnJrnl` concordent sur le 13 mars 2025 à 23 h 58.
Analyse (confiance élevée). La date de 2017 a été falsifiée. L'outil a été déposé le 13 mars à 23 h 58, soit soixante-quatorze minutes avant le début de l'exfiltration. La piste d'un outil ancien, installé par un employé, tombe.

13.3 Un Journal Vidé

Scénario Opérationnel · Opération NYANGA. Le journal de SRV-FIC01

Constatations. Le journal de sécurité de SRV-FIC01 commence par un événement 1102, le 14 mars à 3 h 52, enregistré sous le compte `adm.kamga` : le journal a été vidé, cinq minutes après la fin de l'exfiltration. Les journaux du contrôleur de domaine, eux, conservent les authentifications de `adm.kamga` vers SRV-FIC01 le 13 à 23 h 55 et le 14 à 1 h 09.
Analyse (confiance élevée). L'attaquant a effacé les traces locales de ses sessions, mais pas celles que le contrôleur de domaine garde sur les authentifications. L'effacement lui-même est une constatation, datée et attribuée à un compte.

Note

La centralisation des journaux. Un journal copié en temps réel sur un serveur de collecte, hors de portée des comptes d'administration ordinaires, survit à l'effacement local. C'est la mesure la plus simple contre l'effacement des journaux, et NYANGA ne l'avait pas.

13.4 L'Enquête dans le Nuage

Dans l'informatique en nuage, l'organisation ne possède ni les machines ni le réseau. Le **modèle de responsabilité partagée** répartit la sécurité entre le fournisseur et le client : plus le service est géré par le fournisseur, moins le client a de prise, et moins

l'enquêteur a de traces directement accessibles.

Modèle	Ce que gère le client	Traces accessibles	Traces chez le fournisseur
Infrastructure (IaaS)	Système, applications, données	Disques des machines (instantanés), journaux du système	Hyperviseur, réseau physique
Plateforme (PaaS)	Applications, données	Journaux de l'application et du service	Système sous-jacent
Logiciel (SaaS)	Données, comptes	Journaux d'audit exposés par le service	Presque tout le reste

Tableau 13.2. Traces et responsabilité partagée

L'acquisition y change de forme. On ne débranche pas un serveur : on prend un instantané de ses disques par l'interface du fournisseur, on exporte les journaux d'audit de la console, on copie les journaux du réseau virtuel s'ils sont activés. La mémoire d'une machine virtuelle ne se capture que par un outil exécuté à l'intérieur, ou par un service spécialisé du fournisseur. Les durées de conservation par défaut des journaux d'audit sont souvent courtes, et les données peuvent se trouver dans un autre pays que l'organisation, ce qui fait intervenir l'entraide internationale (Chapitre 8).

Scénario Opérationnel · Opération SOLITRANS. Le portail en février 2026

Constatations. Le 9 février 2026, le portail des transitaires, hébergé chez un fournisseur en nuage sous forme de conteneurs, présente des pages modifiées. L'équipe de M. NJIKE prend un instantané des disques des machines virtuelles et exporte les journaux d'audit de la console, conservés 90 jours. Le conteneur compromis, lui, a déjà été remplacé : le système de reprise automatique l'a détruit et relancé à partir de l'image d'origine quand il a cessé de répondre, à 4 h 10.
Analyse (confiance élevée). Le contenu du conteneur compromis est perdu ; seuls restent les journaux que l'orchestrateur et le fournisseur ont gardés. La reprise automatique, qui sert la disponibilité, a détruit la preuve.

13.5 Les Conteneurs

Un conteneur est éphémère par conception : il naît d'une image, vit quelques minutes ou quelques jours, et disparaît avec ses fichiers et ses journaux s'ils n'ont pas été envoyés ailleurs. L'enquête doit donc préparer la préservation avant l'incident.

Trace	Comment la préserver
Image d'origine	Conserver son empreinte (*digest*) et l'image elle-même dans le registre
Modifications du conteneur	Copier la couche modifiable avant de détruire le conteneur, ou le suspendre au lieu de le redémarrer
Journaux de l'application	Les envoyer en continu vers un collecteur externe
Journaux de l'orchestrateur	Activer et conserver le journal d'audit (créations, suppressions, accès aux secrets)
Réseau	Journaux des flux du réseau virtuel

Tableau 13.3. Préserver les traces d'un conteneur

Lecture auditologique · Ce que l'enquête peut encore savoir, NYANGA et SOLITRANS

Proposition	Cote
`upd.exe` a été déposé sur SRV-FIC01 le 13 mars 2025	OUI
`upd.exe` était présent en 2017	NON
Le journal de SRV-FIC01 a été vidé par le compte `adm.kamga`	OUI
Les sessions de l'attaquant sur SRV-FIC01 sont datées	OUI
Le conteneur du portail de SOLITRANS contenait un outil de l'attaquant	NEK
Le point d'entrée sur le portail de SOLITRANS est identifié	NEK

Lecture. Sur NYANGA, l'anti-forensique a échoué : chaque trace effacée ou falsifiée a été recoupée ailleurs. Sur SOLITRANS, deux NEK tiennent à l'architecture elle-même : ce que la reprise automatique a détruit ne se reconstitue pas.

13.6 Ce que ces Défis demandent à chaque Métier

Application Analyste en réponse à incident

Face à l'anti-forensique

1. Recouper chaque date par au moins deux sources indépendantes.
2. Chercher les journaux hors de la machine (contrôleur, collecteur, réseau).
3. Traiter chaque effacement comme une constatation datée.

4. Dans le nuage, exporter d'abord les journaux d'audit, dont la conservation est courte.
5. Suspendre un conteneur suspect au lieu de le laisser redémarrer.

Application RSSI

Centraliser les journaux hors de portée des comptes d'administration ; négocier avec les fournisseurs en nuage la durée de conservation des journaux d'audit ; régler la reprise automatique des conteneurs pour qu'elle isole avant de détruire.

Application Application OPJ/Expert Judiciaire

Pour les données détenues par un fournisseur à l'étranger, l'expert indique dans son rapport ce qu'il n'a pas pu examiner et pourquoi, et l'OPJ engage sans délai la demande de conservation puis l'entraide.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- L'anti-forensique déplace les traces plus qu'elle ne les supprime ; on les cherche là où l'attaquant n'agit pas.
- Une falsification de dates se détecte par le désaccord entre `$STANDARD_INFORMATION`, `$FILE_NAME` et `$UsnJrnl`.
- Un journal vidé laisse un événement daté et attribué ; les journaux centralisés survivent.
- Dans le nuage, l'acquisition passe par les instantanés et les journaux d'audit, aux durées courtes.
- Un conteneur se préserve avant l'incident ; la reprise automatique peut détruire la preuve.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- démontrer une falsification de dates à partir de trois sources ;
- dire ce qu'un client peut acquérir selon le modèle de service ;
- préparer la préservation d'un environnement de conteneurs.

Exercices

✍ Exercice 13.1. Trace résiduelle ★☆☆

Pour chaque technique, citez une trace résiduelle à chercher : (a) un journal de sécurité vidé ; (b) un fichier écrasé par un outil d'effacement ; (c) un script exécuté en mémoire par `powershell` ; (d) une archive chiffrée.

✍ Exercice 13.2. Vraie ou fausse date ★★☆

Un fichier `rapport.xlsx` présente une création au 12/03/2025 14:05:33,8812094 dans `$STANDARD_INFORMATION` et au 12/03/2025 14:05:33,8812094 dans `$FILE_NAME` ; le `$UsnJrnl` ne contient plus d'entrée aussi ancienne.

(a) La date est-elle falsifiée ?

(b) Pourquoi le `$UsnJrnl` ne permet-il pas de trancher ?

(c) Comment cotez-vous la proposition « le fichier a été créé le 12 mars » ?

✍ Exercice 13.3. Acquérir dans le nuage ★★☆

Une machine virtuelle de SOLITRANS, hébergée en IaaS, est suspectée. Décrivez, dans l'ordre, les acquisitions à faire, et dites pour chacune ce qui serait perdu si on la faisait trop tard.

✍ Exercice 13.4. Préparer les conteneurs ★★★

(a) Rédigez cinq règles de préparation qui auraient permis d'examiner le conteneur compromis du portail de SOLITRANS.

(b) La reprise automatique sert la disponibilité. Proposez un réglage qui concilie disponibilité et préservation.

(c) Reprenez l'encadré « Ce que l'enquête peut encore savoir » et dites lesquelles des deux cotes NEK de SOLITRANS vos règles auraient pu changer.

● Note

Pour aller plus loin.

➢ B. Carrier, *File System Forensic Analysis* [5], sur les attributs NTFS.

➢ L'ISO/IEC 27042 [21], sur l'analyse et l'interprétation.

● Note

Transition. Tous les outils sont en place : acquérir, analyser, dater, remonter à la faille, contourner l'anti-forensique. Le Chapitre 14 les rassemble dans une enquête

complète, du premier appel au dernier scellé.

14

L'ENQUÊTE INTÉGRATRICE

> « Une enquête bien conduite se reconnaît à ce qu'un autre pourrait la refaire à partir du dossier. »
>
> Principe du cours

Niveau : *Expert* • Maîtrise des Chapitres 1 à 13

✦ Objectifs du chapitre

- Conduire une enquête complète en dix étapes, de l'alerte à la clôture.
- Articuler réponse à incident, enquête technique et enquête judiciaire sur une même affaire.
- Tenir le dossier d'enquête de façon qu'il soit reproductible.
- Relier l'enquête au programme de gestion des vulnérabilités.
- Estimer le coût d'un incident et le présenter à une direction.

Avant de commencer : vingt-trois jours

Yaoundé, 6 avril 2025. La mission de SANKOFA EXPERTISE à NYANGA CRÉDIT s'achève après vingt-trois jours. Mme MBARGA réunit son équipe pour le dernier exercice de chaque mission : relire le dossier comme le relirait un expert adverse, page par page, en se demandant pour chaque conclusion d'où elle vient. Elle ne cherche pas les erreurs de l'attaquant, mais les siennes.

★ Attention

Violation typique. Conduire chaque étape correctement, mais sans fil : des acquisitions sans questions, des analyses sans chronologie, une chronologie sans arbre des causes, un rapport sans recommandations vérifiables.

Règle : une enquête suit une méthode écrite, dont chaque étape produit une pièce du dossier et prépare la suivante. Le dossier, pas la mémoire des enquêteurs, porte l'enquête.

© MaletYon

14.1 Une Méthode en Dix Étapes

N°	Étape	Pièce produite	Chapitre
1	Recevoir l'alerte, isoler	Registre des actions ouvert	0
2	Cadrer : mandat, questions, cadre juridique	Lettre de mission, questions écrites	1, 8
3	Formuler les hypothèses	Liste des hypothèses et pièces réfutantes	1
4	Préserver et acquérir	Formulaires de chaîne de possession, scellés	2, 3
5	Examiner disque, mémoire, réseau	Notes d'examen, sorties d'outils	4 à 6
6	Construire la chronologie	Tableau des horloges, chronologie cotée	7
7	Remonter à la vulnérabilité	Matrice des explications, arbre des causes	12
8	Chercher les variantes	Liste des autres instances	12
9	Rendre compte	Rapport, annexes, recommandations	15
10	Clore et transmettre	Restitution ou transfert des scellés, règles nouvelles au programme	11

Tableau 14.1. La méthode du cours en dix étapes

Les étapes se chevauchent : on acquiert encore pendant qu'on examine, et chaque découverte peut rouvrir une hypothèse. La méthode fixe l'ordre des dépendances, pas un calendrier. Elle respecte les classes de processus de l'ISO/IEC 27043 [22] et les phases du NIST SP 800-86 [31], en y ajoutant explicitement les étapes 7 et 8, qui relient l'enquête à la gestion des vulnérabilités.

14.2 Trois Enquêtes, un Dossier

À NYANGA CRÉDIT, la réponse à incident, l'enquête du cabinet et l'enquête judiciaire ont avancé ensemble. Leur coordination tient à quelques règles.

Règle	Application à NYANGA
Un seul registre des actions	Ouvert par la RSSI le 14 mars, repris par le cabinet, versé à la procédure
Les originaux vont à la justice	Scellés NC-01 à NC-07 remis à l'OPJ le 16 et le 22 mars ; le cabinet travaille sur ses copies
Chacun garde son rapport	Le cabinet rend compte à l'établissement, l'expert au procureur
La reprise d'activité attend la préservation	Contrôleur de secours en service après la capture de la mémoire et l'image du disque
Les communications passent par la cellule	Aucune déclaration publique avant validation par la juriste

Tableau 14.2. Coordonner les trois enquêtes

Note

Les obligations de notification. Un incident qui expose des données de clients peut déclencher des obligations de notification envers une autorité de protection des données et envers les personnes concernées, au titre de la loi n° 2024/017 [35]. Un établissement de microfinance peut aussi devoir informer son autorité de supervision [nature et délai à vérifier dans la réglementation applicable]. Le détail relève de l'UE MSN-2S3-JUR01 ; l'enquêteur fournit les faits qui permettent de remplir ces obligations : quelles données, combien de personnes, depuis quand.

14.3 Le Dossier NYANGA

Scénario Opérationnel · Opération NYANGA. Le dossier au 6 avril 2025

Rubrique	Contenu
Mandat et questions	Lettre de mission du 14 mars ; cinq questions (point d'entrée, séquence, données sorties, auteurs, mesures)
Registre des actions	214 entrées, du 14 mars 8 h 15 au 6 avril
Scellés	NC-01 à NC-07, formulaires, procès-verbaux de remise
Notes d'examen	Disque (SRV-CPT01, SRV-AD01, SRV-FIC01), mémoire (SRV-AD01, SRV-FIC01), réseau (NC-04), sorties brutes des outils en annexe
Chronologie	14 lignes cotées, tableau des horloges, temps de présence
Causes	Matrice E1-E2-E3, arbre des sept causes
Variantes	Recherche lancée, programme de septembre
Rapport	Version du 6 avril, relue contradictoirement

Réponses aux cinq questions. Point d'entrée : OUI (VULN-2024-4471). Séquence : OUI, sauf du 3 au 8 mars (NEK). Données sorties : OUI pour le dossier `Clients` par le siège, NEK pour d'autres chemins. Auteurs : NEK. Mesures : sept recommandations.

Lecture auditologique · Les cinq questions de la mission

Décompte. Trois questions établies (point d'entrée, séquence principale, données sorties par le siège), une non tranchée (auteurs), et deux réserves partielles (trou du 3 au 8 mars, autres chemins de sortie).

Lecture. La mission répond à ce que l'établissement doit savoir pour décider : fermer la porte, mesurer la fuite, prévenir les clients. Elle ne répond pas à la question pénale de l'identité, qui dépend de pièces détenues par des tiers à l'étranger.

14.4 Le Coût d'un Incident

La direction demande toujours combien l'incident a coûté. La réponse se construit poste par poste, en distinguant ce qui est constaté (factures, pertes comptabilisées) de ce qui est estimé.

Scénario Opérationnel · Opération NYANGA. Le coût au 30 juin 2025

Poste	M FCFA	Nature
Virements frauduleux	47,3	Constaté
Montants recouvrés par les opérateurs	−12,6	Constaté
Mission d'enquête et d'expertise privée	21,0	Constaté (factures)
Remplacement de la passerelle et mesures immédiates	34,0	Constaté
Arrêt partiel des agences (estimation des pertes d'activité)	28,3	Estimé
Total	**118,0**	
Notification et accompagnement des clients exposés	Non chiffré	NEK
Contentieux éventuels	Non chiffré	NEK

Analyse (confiance élevée sur les postes constatés, moyenne sur l'arrêt des agences). Le coût connu, 118 M FCFA, est une borne basse. Les deux postes NEK peuvent le dépasser. À titre de comparaison, la mise à jour de la passerelle en décembre 2024 aurait demandé une intervention de deux heures du prestataire.

14.5 L'Exercice Intégrateur : SOLITRANS, Février 2026

Le portail des transitaires de SOLITRANS a été compromis en février 2026 (Chapitre 13). Le laboratoire FAV-LAB-10 de NDAP SUKULU en fournit les pièces : journaux d'audit de la console du fournisseur, journaux de l'orchestrateur, journaux de l'application envoyés au collecteur, instantané des disques, historique des balayages du portail, tickets de correction. Le lecteur y applique les dix étapes. Trois questions guident l'exercice :

1. Par quelle faille l'attaquant est-il entré, et cette faille était-elle connue du programme de gestion des vulnérabilités ?
2. Qu'a-t-il modifié, et qu'a-t-il pu lire ?
3. Le programme de SOLITRANS a-t-il échoué, ou l'attaque est-elle passée par une faille hors de sa portée ?

Note

Une question piège. La troisième question n'a pas de réponse évidente. Une faille connue, classée, dont l'exception E-03 était en cours, n'est pas un échec du programme au même titre qu'une faille ignorée ; mais une mesure compensatoire défaillante en est un. L'exercice demande de coter, pas de défendre.

14.6 Ce que l'Enquête demande à chaque Métier

Application Analyste en réponse à incident

Relire son dossier avant de le remettre

1. Chaque conclusion renvoie-t-elle à des pièces cotées ?
2. Chaque pièce a-t-elle sa chaîne de possession ?
3. Chaque outil a-t-il sa version et sa sortie brute en annexe ?
4. Chaque heure a-t-elle son fuseau et sa dérive ?
5. Chaque NEK est-il dit, avec ce qui permettrait de le lever ?

Application RSSI

Présenter à la direction le coût constaté, le coût estimé et ce qui reste inconnu, puis le coût de la mesure qui aurait évité l'incident. La comparaison fait plus pour le budget de la sécurité que toute projection.

Application Analyste en gestion des vulnérabilités

Recevoir le dossier d'enquête et répondre par écrit à une question : le programme aurait-il dû voir cette faille, et pourquoi ne l'a-t-il pas vue ?

Application Application OPJ/Expert Judiciaire

L'expert relit son rapport en se posant la question de l'expert adverse : quelle conclusion pourrais-je attaquer, et sur quelle pièce ?

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Une enquête suit dix étapes, chacune produisant une pièce du dossier ; les étapes 7 et 8 la relient à la gestion des vulnérabilités.
- Réponse à incident, enquête privée et enquête judiciaire partagent un registre et des scellés, pas un rapport.
- Le coût d'un incident se construit poste par poste, constaté ou estimé ; ce qui reste NEK se dit.
- À NYANGA, trois des cinq questions sont tranchées, l'identité des auteurs reste NEK, et le coût connu atteint 118 M FCFA.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- citer les dix étapes et la pièce que chacune produit ;
- organiser la coordination de trois enquêtes sur une affaire ;
- présenter un coût d'incident en distinguant constaté, estimé et inconnu.

Exercices

Exercice 14.1. Ordonner ★☆☆

Remettez dans l'ordre de la méthode : (a) construire la chronologie ; (b) formuler les hypothèses ; (c) isoler ; (d) chercher les variantes ; (e) acquérir ; (f) remonter à la vulnérabilité ; (g) cadrer le mandat ; (h) examiner ; (i) rendre compte ; (j) clore.

Exercice 14.2. Relecture contradictoire ★★☆

Jouez l'expert adverse. Choisissez trois conclusions du dossier NYANGA et, pour chacune, formulez l'objection la plus forte possible, puis la réponse que le dossier permet d'y apporter. Indiquez si l'une d'elles devrait changer de cote.

✍ Exercice 14.3. Le coût ★★☆

(a) Vérifiez le total de l'encadré « Le coût au 30 juin 2025 ».

(b) Quelle part du coût connu est estimée plutôt que constatée ?

(c) Rédigez trois phrases pour présenter ce coût au conseil d'administration.

✍ Exercice 14.4. SOLITRANS, février 2026 ★★★

À partir des pièces du laboratoire FAV-LAB-10, conduisez les dix étapes et répondez aux trois questions de la section 14.5. Pour chaque réponse, donnez une cote et les pièces qui la fondent. Rédigez enfin la note d'une page destinée à M. NJIKE.

● Note

Pour aller plus loin.

- L'ISO/IEC 27043 [22] et l'ISO/IEC 27035 [28].
- Le NIST SP 800-61 [9].

● Note

Transition. Le dossier est complet. Il reste à l'écrire pour ceux qui ne l'ont pas vu se construire, et à le défendre devant ceux qui le contestent : Chapitre 15.

15

LE RAPPORT ET LE TÉMOIGNAGE

« Un rapport que seul son auteur comprend
n'a convaincu personne. »

Principe du cours

Niveau : *Intermédiaire* • Maîtrise du Chapitre 14

✦ Objectifs du chapitre

- Adapter un rapport à son destinataire : direction, autorité judiciaire, équipe technique.
- Structurer un rapport d'expertise de façon qu'il soit vérifiable.
- Écrire chaque conclusion avec sa constatation, son analyse et son niveau de confiance.
- Dire les limites de l'examen sans les cacher ni s'y réfugier.
- Préparer une déposition et répondre à une question hostile.

Avant de commencer : une question simple

Bafoussam, tribunal de grande instance de la Mifi, 15 février 2026. Deux titulaires de portefeuilles de paiement mobile, qui ont reçu une partie des fonds détournés, sont poursuivis pour recel. M. ABOUBAKAR, l'expert requis par le procureur, dépose à la barre. L'avocat de la défense lui pose une question simple : « Monsieur l'expert, pouvez-vous dire au tribunal que mes clients ont piraté NYANGA CRÉDIT ? » La réponse tient en une phrase, et l'expert l'a préparée.

★ Attention

Violation typique. Laisser un rapport, ou une déposition, aller au-delà de ce que les pièces établissent, parce que le destinataire attend une réponse ferme.

Règle : l'expert répond à la question posée, avec ce que les pièces établissent, et dit clairement ce qu'elles n'établissent pas. Une réponse NEK bien formulée sert la justice mieux qu'une certitude fragile.

15.1 Trois Destinataires, Trois Rapports

Destinataire	Ce qu'il doit décider	Forme	Écueil
Direction	Fermer la porte, financer, informer	Note de deux pages, recommandations datées	Trop de technique
Autorité judiciaire	Établir des faits, qualifier	Rapport d'expertise complet, annexes	Sortir de la mission
Équipe technique	Corriger, détecter	Rapport détaillé, indicateurs, règles	Pas de priorités

Tableau 15.1. Trois rapports pour une même enquête

Les trois rapports reposent sur les mêmes constatations. Ils diffèrent par ce qu'ils retiennent et par leur langue. La note à la direction ne contient pas de vecteur CVSS ; le rapport d'expertise ne contient pas de recommandation budgétaire ; le rapport technique contient les deux.

15.2 Le Rapport d'Expertise

L'ISO/IEC 27042 [21] demande que le rapport permette à un tiers compétent de comprendre ce qui a été fait, d'en évaluer la validité et de le refaire (paraphrase). Le plan suivant répond à cette exigence.

	Partie	Contenu
1	Mission	Autorité requérante, fondement (art. 56 de la loi n° 2010/012), questions posées, mot pour mot
2	Pièces reçues	Scellés, état à réception, empreintes vérifiées
3	Opérations	Chaque opération, datée, avec outils, versions et copies utilisées
4	Constatations	Les faits, sans interprétation, avec leur source
5	Discussion	Les interprétations, les autres explications examinées, le niveau de confiance
6	Limites	Ce qui n'a pas pu être examiné, et pourquoi
7	Réponses aux questions	Une réponse par question, cotée
8	Annexes	Sorties brutes, tableaux, chronologie, formulaires

Tableau 15.2. Le plan d'un rapport d'expertise

15.2.1 Écrire une conclusion

Chaque conclusion du rapport suit le même schéma : la constatation, avec sa source ; l'analyse, avec les autres explications examinées ; le niveau de confiance, et ce qui le fonde. Le vocabulaire de la confiance doit être défini dans le rapport et tenu partout.

Niveau	Usage dans ce livre
Élevée	Plusieurs pièces indépendantes concordent, aucune explication concurrente plausible ne subsiste
Moyenne	Les pièces concordent mais l'une est fragile, ou une explication concurrente reste possible
Faible	Une seule pièce, ou des explications concurrentes aussi plausibles

Tableau 15.3. Les niveaux de confiance

Scénario Opérationnel · Opération NYANGA. Une réponse du rapport d'expertise

Question 3 de la mission : « Dire par quel moyen l'accès au système d'information de NYANGA CRÉDIT a été obtenu. »

Constatation. La passerelle d'accès à distance fonctionnait le 2 mars 2025 avec le micrologiciel 7.2.1 (scellé NC-02, export de configuration). Le bulletin de l'éditeur du 12 décembre 2024 désigne cette version comme vulnérable à un contournement de l'authentification. Le journal de la passerelle (NC-02) enregistre, le 2 mars entre 23 h 46 et 23 h 48, quatre requêtes depuis l'adresse 203.0.113.18 conformes aux indicateurs publiés par l'éditeur, suivies de l'ouverture d'une session du compte `svc_backup` sans authentification préalable.
Discussion. Deux autres explications ont été examinées : l'utilisation d'un mot de passe connu, qui n'explique pas la session sans authentification ; le vol d'une session existante, écarté faute de session légitime dans les neuf jours précédents.
Réponse (confiance élevée). L'accès a été obtenu par l'exploitation d'une vulnérabilité de la passerelle permettant de contourner l'authentification.

15.2.2 Dire les limites

La partie consacrée aux limites protège l'expert autant que le lecteur. Elle énumère ce que l'examen n'a pas couvert : la mémoire de SRV-CPT01, jamais capturée ; le système de la passerelle, illisible sans l'éditeur ; la période du 3 au 8 mars, sans trace ; la provenance des journaux de l'interface de paiement. Pour chaque limite, elle dit l'effet sur les conclusions. Une limite non écrite devient, à l'audience, une faille de l'expertise.

15.3 L'Indépendance et la Compétence

L'expert requis tient sa légitimité de deux qualités : son indépendance à l'égard des parties, et sa compétence. La première exclut d'avoir travaillé pour l'une d'elles sur

l'affaire. C'est pourquoi le procureur n'a pas requis Mme MBARGA, mandatée et payée par NYANGA CRÉDIT, mais M. ABOUBAKAR. La seconde se démontre par la formation, l'expérience et la méthode ; pour un laboratoire, l'accréditation selon l'ISO/IEC 17025 [23] atteste de la compétence technique et de la maîtrise des méthodes.

Note

L'enquêteur privé comme témoin. Mme MBARGA peut être entendue comme témoin des opérations qu'elle a réalisées : acquisitions, chaîne de possession, premières constatations. Elle ne se substitue pas à l'expert, et l'expert ne se contente pas de reprendre ses conclusions : il refait ou contrôle ce qui fonde les siennes.

15.4 Déposer à l'Audience

L'audience n'est pas un séminaire technique. Le tribunal, les avocats et les prévenus n'ont pas lu les annexes. L'expert y gagne à préparer trois choses : une chronologie d'une page, lisible à distance ; une définition en une phrase de chaque terme technique qu'il emploiera ; et la liste des questions hostiles probables, avec leur réponse.

Question hostile	Réponse fondée sur le dossier
« Vos outils ne sont-ils pas faillibles ? »	Les conclusions principales reposent sur deux sources indépendantes, lues avec des outils dont les versions et les sorties sont en annexe
« Le disque est resté une nuit sur un bureau. »	L'intégrité est établie par les empreintes ; la conclusion qu'il soutient est confirmée par une autre pièce, à la chaîne complète
« Pouvez-vous exclure une erreur d'horloge ? »	Les dérives ont été mesurées et corrigées ; les écarts restants sont inférieurs à la minute
« Mes clients ont-ils piraté l'établissement ? »	Les pièces ne permettent pas de le dire (voir ci-dessous)

Tableau 15.4. Préparer les questions hostiles

Scénario Opérationnel · Opération NYANGA. La réponse de l'expert

Réponse de M. ABOUBAKAR. « Non, Maître. Les pièces que j'ai examinées établissent comment le système a été pénétré et comment les fonds ont été transférés. Elles ne permettent pas d'identifier les personnes qui ont commis l'intrusion. Elles établissent, par les relevés de l'opérateur, que deux des onze portefeuilles qui ont reçu les fonds sont ouverts au nom de vos clients. Ce que vos clients savaient de l'origine de ces fonds n'est pas une question technique. »

Analyse. L'expert répond à la question, sépare ce qui est établi de ce qui ne l'est pas,

et laisse au tribunal ce qui relève du tribunal. L'avocat n'obtient ni une attribution qu'il pourrait contester, ni un refus de répondre qu'il pourrait exploiter.

Lecture auditologique · Les réponses de l'expertise

Question de la mission	Réponse
Moyen de l'accès	OUI
Séquence des opérations de l'attaquant	OUI (sauf 3 au 8 mars, NEK)
Données copiées	OUI
Destination des fonds	OUI (onze portefeuilles)
Identité des auteurs de l'intrusion	NEK

Lecture. Quatre réponses établies, une non tranchée. Le NEK sur les auteurs n'affaiblit pas l'expertise ; il en marque l'honnêteté. Les poursuites pour recel reposent sur d'autres éléments, que la justice réunit par d'autres moyens.

15.5 Ce que le Rapport demande à chaque Métier

Application Application OPJ/Expert Judiciaire

Rédiger et défendre une expertise

1. Recopier les questions de la mission, mot pour mot.
2. Séparer, pour chaque conclusion, constatation, discussion et réponse.
3. Définir les niveaux de confiance et les tenir.
4. Écrire les limites et leur effet.
5. Préparer la chronologie d'une page et les questions hostiles.

Application Analyste en réponse à incident

Écrire le rapport technique pour qu'il puisse devenir une pièce de procédure : chaque affirmation sourcée, chaque opération datée. Il le deviendra plus souvent qu'on ne le prévoit.

Application RSSI

Lire les limites du rapport avant ses conclusions : elles disent ce que l'organisation doit encore préparer pour la prochaine enquête.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- Une même enquête donne trois rapports, pour la direction, la justice et l'équipe technique.
- Le rapport d'expertise recopie la mission, décrit les opérations, sépare constatations et discussion, écrit ses limites et répond question par question.
- Les niveaux de confiance se définissent et se tiennent.
- L'indépendance exclut d'avoir travaillé pour une partie ; la compétence se démontre.
- À l'audience, l'expert répond à la question posée et laisse au tribunal ce qui lui revient.

● Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- rédiger une réponse d'expertise en trois temps ;
- écrire une section de limites et dire l'effet de chacune ;
- répondre à une question hostile sans dépasser les pièces.

Exercices

✍ Exercice 15.1. Quel rapport ? ★☆☆

Dites dans quel rapport (direction, justice, technique) figure chacun des éléments suivants : (a) le vecteur CVSS de VULN-2024-4471 ; (b) le coût de l'incident ; (c) la sortie brute de `windows.netscan` ; (d) la recommandation sur la conservation des journaux ; (e) les questions de la mission.

✍ Exercice 15.2. Réécrire une conclusion ★★☆

Réécrivez en trois temps (constatation, discussion, réponse cotée) la phrase suivante, tirée d'un brouillon de rapport : « Il est évident que les pirates ont volé le mot de passe de M. KAMGA pour vider les comptes. »

✍ Exercice 15.3. La section des limites ★★☆

Rédigez la section « Limites » du rapport d'expertise de NYANGA. Pour chaque limite, indiquez la ou les conclusions affectées et la manière dont elles le sont.

✍ Exercice 15.4. Trois questions hostiles ★★★

Préparez la réponse de l'expert aux trois questions suivantes, en vous appuyant sur le dossier : (a) « Pourquoi n'avez-vous pas examiné la passerelle elle-même ? » ; (b) « Les journaux de l'interface de paiement vous ont été transmis par courriel par une société privée : comment savoir qu'ils sont authentiques ? » ; (c) « Votre rapport reprend-il simplement celui du cabinet payé par la victime ? »

Note

Pour aller plus loin.

- L'ISO/IEC 27042 [21], sur l'interprétation et la présentation des résultats.
- L'ISO/IEC 17025 [23], pour la compétence des laboratoires.

Note

Transition. Le rapport dit ce que l'enquête sait et ce qu'elle ne sait pas. Peut-on mesurer cette part d'ignorance, la comparer d'une enquête à l'autre, la réduire méthodiquement ? C'est la question de recherche du Chapitre 16.

partie VI

Recherche : Mesurer l'Incertitude d'une Enquête

© *MaletYon*

16

MESURER L'INCERTITUDE D'UNE ENQUÊTE

« Ce que l'on ne sait pas se compte,
comme ce que l'on sait. »

Principe du cours

Niveau : *Recherche* • Maîtrise de l'ensemble du cours

✦ Objectifs du chapitre

- Représenter l'état d'une enquête par un ensemble de propositions cotées OUI, NON ou NEK.
- Calculer et interpréter les mesures μ, U et H.
- Suivre l'évolution de l'incertitude au cours d'une enquête.
- Distinguer un NEK réductible d'un NEK irréductible dans le cadre d'une mission.
- Formuler une question de recherche sur l'incertitude en investigation numérique.

Avant de commencer : « avez-vous avancé ? »

Bafoussam, 29 mars 2025. Le directeur général de NYANGA CRÉDIT demande à Mme MBARGA où en est l'enquête. Elle pourrait répondre par une liste de découvertes. Elle répond par trois nombres : sur les douze propositions que l'enquête doit trancher, quatre sont établies, deux réfutées, six encore ouvertes. Le 14 mars au soir, les douze étaient ouvertes. Le directeur comprend ce que l'enquête sait, et ce qu'il lui reste à apprendre.

★ Attention

Violation typique. Rendre compte de l'avancement d'une enquête par ce qui a été trouvé, sans dire ce qui reste inconnu ni si cet inconnu diminue.

© *MaletYon*

Règle : l'état d'une enquête se décrit par l'ensemble des propositions qu'elle doit trancher, chacune cotée. L'avancement se mesure à la baisse de la part des NEK, pas au nombre de découvertes.

16.1 L'Instrument Trichotomique

Tout au long du cours, chaque conclusion a reçu une cote OUI, NON ou NEK. Cet instrument vient du programme de recherche de l'auditologie [37], qui propose de traiter l'audit des systèmes d'information, et plus largement toute démarche qui conclut sur des preuves, comme une science appliquée de la réduction de l'incertitude. L'article qui formalise l'instrument [36] montre qu'une réponse binaire, oui ou non, force l'auditeur à transformer son ignorance en affirmation, et qu'une troisième réponse, NEK, rend cette ignorance visible et mesurable.

Définition

Soit un ensemble de n propositions, cotées, avec n_O réponses OUI, n_N réponses NON et n_K réponses NEK. On définit :

Taux d'établissement : $\mu = n_O/n$, la part des propositions établies.

Taux d'incertitude : $U = n_K/n$, la part des propositions que les preuves ne permettent pas de trancher.

Entropie : $H = -\sum_c p_c \log_2 p_c$, où p_c est la part de chaque cote, exprimée en bits [43]. Elle mesure la dispersion des réponses : nulle si toutes les cotes sont identiques, maximale ($\log_2 3 \approx 1{,}585$ bit) si elles sont également réparties.

Dans un audit, OUI signifie qu'un contrôle est en place et NON qu'il ne l'est pas ; μ y mesure la conformité. Dans une enquête, OUI et NON sont deux formes de savoir : une proposition réfutée est aussi tranchée qu'une proposition établie. La part de savoir y vaut donc $1 - U$, et U devient la mesure principale.

16.2 Les Douze Propositions de NYANGA

Scénario Opérationnel · Opération NYANGA. Trois instantanés de l'enquête

N°	Proposition	14/03	29/03	06/04
P1	L'attaquant est entré par la passerelle	NEK	OUI	OUI
P2	Par l'exploitation de VULN-2024-4471	NEK	NEK	OUI
P3	La clé de l'interface a été lue sur SRV-CPT01	NEK	OUI	OUI
P4	Les identifiants de `adm.kamga` ont été extraits de la copie du 9 mars	NEK	NEK	NEK
P5	Les données sorties sont le dossier `Clients`	NEK	OUI	OUI
P6	Les virements ont été émis hors du réseau du siège	NEK	OUI	OUI
P7	Un employé a participé	NEK	NEK	NEK
P8	L'attaquant a agi du 3 au 8 mars	NEK	NEK	NEK
P9	Les auteurs sont identifiés	NEK	NEK	NEK
P10	La passerelle contient un code persistant	NEK	NEK	NEK
P11	Les virements sont passés par le lien du siège	NEK	NON	NON
P12	`upd.exe` était présent sur SRV-FIC01 en 2017	NEK	NON	NON

Lecture auditologique · L'incertitude de l'enquête, trois dates

Date	$n_O/n_N/n_K$	μ	U	H (bit)
14/03	0/0/12	0	1	0
29/03	4/2/6	0,333	0,500	1,459
06/04	5/2/5	0,417	0,417	1,483

Calcul pour le 29 mars. $p_O = 4/12$, $p_N = 2/12$, $p_K = 6/12$:

$$H = -\left(\tfrac{1}{3}\log_2\tfrac{1}{3} + \tfrac{1}{6}\log_2\tfrac{1}{6} + \tfrac{1}{2}\log_2\tfrac{1}{2}\right) \approx 0{,}528 + 0{,}431 + 0{,}500 \approx 1{,}459 \text{ bit.}$$

Lecture. U passe de 1 à 0,500 puis à 0,417 : l'enquête avance. H, lui, augmente : il était nul quand tout était inconnu, et la répartition des cotes devient plus mélangée à mesure que l'enquête tranche. H ne mesure donc pas l'ignorance, mais la diversité des réponses. La règle du corpus s'applique : on lit U d'abord, μ ensuite, et H pour contrôler que la répartition n'est pas dégénérée.

$\mu = 0{,}417$ · $U = 0{,}417$ · $H = 1{,}483$ **bit**

16.3 Deux Sortes de NEK

Les cinq NEK du 6 avril ne sont pas de même nature. Certains peuvent être levés par une pièce que l'enquête est en mesure d'obtenir ; d'autres ne le peuvent pas dans le cadre de la mission.

N°	Ce qui lèverait le nek	Nature	Coût ou condition
P4	Aucune pièce : l'extraction a eu lieu hors du système	Irréductible	Hors de portée de toute enquête technique sur le système
P7	Pièces sur les personnes (témoignages, téléphonie)	Réductible hors mission	Enquête judiciaire
P8	Journaux des agences, s'ils existent encore	Réductible	Quelques jours d'examen
P9	Données des hébergeurs de 203.0.113.18, .47 et .62	Réductible hors mission	Entraide internationale, mois
P10	Image du système de la passerelle par l'éditeur	Réductible	Réquisition de l'éditeur, semaines

Tableau 16.1. Les NEK de NYANGA au 6 avril

Cette distinction change la décision. Il est rationnel de lever P8, peu coûteux. Il est inutile de promettre de lever P4. Lever P9 et P7 appartient à d'autres acteurs, et le rapport doit le dire pour que la direction ne l'attende pas de son cabinet.

Note

La valeur d'une pièce. Chaque pièce supplémentaire a un coût (temps, argent, délai) et une valeur : les NEK qu'elle peut lever, et l'importance de ces NEK pour la décision. Choisir les pièces à chercher revient à comparer ces valeurs. Formaliser cette comparaison pour l'investigation numérique est l'une des questions ouvertes du programme de recherche.

16.4 Questions Ouvertes pour la Recherche

L'auditologie a été proposée pour l'audit des systèmes d'information. Son transfert à l'investigation numérique et à l'analyse de vulnérabilités soulève des questions qui peuvent fonder un mémoire de master ou une thèse.

1. **La granularité des propositions.** Les mesures dépendent du découpage de l'enquête en propositions. Comment définir un découpage stable, pour que deux enquêteurs obtiennent des U comparables sur la même affaire ?

2. **La pondération.** Toutes les propositions ne pèsent pas autant pour la décision. Faut-il pondérer U, et selon quel critère qui ne soit pas arbitraire ?
3. **La confiance.** Le cours associe à chaque analyse un niveau de confiance (faible, moyenne, élevée) distinct de la cote. Comment articuler ces deux échelles ?
4. **Le programme de vulnérabilités.** Un actif hors inventaire est un NEK (Chapitre 10). Le U d'un parc, calculé sur la présence de failles, peut-il servir d'indicateur de pilotage, à côté du nombre de failles ?
5. **L'attribution.** L'identité des auteurs reste souvent NEK. Peut-on décrire formellement les conditions qui la rendent réductible ?

Note

Construire un sujet de mémoire sur l'incertitude

1. Choisir un objet : une enquête, un programme de vulnérabilités, un type de pièce.
2. Définir l'ensemble des propositions et la règle de cotation.
3. Recueillir des cas réels anonymisés ou des cas construits, documentés.
4. Mesurer U, μ et H, et leur évolution.
5. Confronter les mesures à un critère extérieur (décision prise, erreur constatée a posteriori).
6. Discuter les limites de la mesure, et proposer une amélioration.

16.5 Ce que la Mesure demande à chaque Métier

Application Analyste en réponse à incident

Ouvrir chaque mission par la liste des propositions à trancher, la coter chaque semaine et rendre compte de l'avancement par U. La liste elle-même oblige à dire, dès le départ, ce que l'on cherche.

Application Application OPJ/Expert Judiciaire

Le tableau des propositions cotées, annexé au rapport, donne au tribunal une vue d'ensemble honnête : ce qui est établi, ce qui est réfuté, ce qui ne peut pas l'être.

Application Analyste en gestion des vulnérabilités

Publier, à côté du nombre de failles, la part du parc dont on ne sait rien. C'est le U du programme.

Application RSSI

Demander à chaque enquête et à chaque programme ce qu'ils ont trouvé, puis ce qu'ils ignorent encore et ce qu'il en coûterait de le savoir.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- L'état d'une enquête se décrit par des propositions cotées OUI, NON ou NEK.
- μ est la part des OUI, U la part des NEK, H l'entropie de la répartition ; dans une enquête, U est la mesure principale.
- À NYANGA, U passe de 1 à 0,417 en trois semaines, tandis que H augmente : H mesure la diversité, pas l'ignorance.
- Un NEK est réductible ou non dans le cadre d'une mission ; la distinction guide le choix des pièces à chercher.
- Le transfert de l'auditologie à l'investigation ouvre des questions de recherche sur la granularité, la pondération et la confiance.

Note

Points de contrôle. Vous avez compris ce chapitre si vous savez :

- calculer μ, U et H pour un ensemble de cotes ;
- expliquer pourquoi H peut augmenter pendant qu'une enquête avance ;
- classer un NEK comme réductible ou irréductible.

Exercices

Exercice 16.1. Calculer ★☆☆

Calculez μ, U et H pour les répartitions suivantes de dix propositions : (a) 10/0/0 ; (b) 5/5/0 ; (c) 4/3/3 ; (d) 0/0/10.

Exercice 16.2. Le 6 avril ★★☆

(a) Vérifiez le calcul de H au 6 avril.

(b) Si l'examen des journaux des agences établit l'activité du 3 au 8 mars (P8 passe à OUI), que deviennent μ, U et H ?

(c) Et si l'éditeur établit l'absence de code persistant dans la passerelle (P10 passe à NON) ?

✍ Exercice 16.3. Le U d'un parc ★★☆

Reprenez la couverture de SOLITRANS en mai 2025 (Chapitre 10) : 1 512 actifs, dont 170 non analysés et 22 % des serveurs analysés sans authentification. Proposez une manière de calculer un U du parc sur la question « l'actif présente-t-il une faille de classe P1 ? », et discutez-en les limites.

✍ Exercice 16.4. Un sujet de recherche ★★★

Choisissez l'une des cinq questions ouvertes de la section 16.4 et rédigez une proposition de sujet de mémoire d'une page : question, hypothèse, données, méthode de mesure, critère de validation, limites attendues.

● Note

Pour aller plus loin.

- T. E. Minka Mi Nguidjoï, « Vers l'auditologie » [37].
- T. E. Minka Mi Nguidjoï, sur l'instrument trichotomique [36].
- C. E. Shannon, « A Mathematical Theory of Communication » [43].

● Note

Fin du cours. La nuit du 14 mars a commencé par vingt-trois virements et une question : par où sont-ils entrés ? Elle s'achève sur une règle d'inventaire, cinq NEK assumés et une passerelle sous scellé. Entre les deux, l'enquête a préservé, acquis, analysé, daté, remonté à la faille et rendu compte, en disant à chaque étape ce qu'elle savait et ce qu'elle ignorait.

A

GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les définitions données dans les chapitres. Le numéro renvoie au chapitre où le terme est défini et illustré.

Acquisition à chaud Recueil sur une machine allumée (mémoire, volume déverrouillé), qui laisse une empreinte documentée de l'outil (Ch. 3).

Acquisition à froid Copie d'un support après extinction, derrière un bloqueur d'écriture (Ch. 3).

Analyse Interprétation d'une ou de plusieurs constatations, assortie d'un niveau de confiance (Ch. 0).

Analyse de variantes Recherche, dans tout le parc, de la même vulnérabilité, de la même faiblesse ou de la même cause profonde qu'un incident a révélées (Ch. 12).

Anti-forensique Techniques visant à empêcher, retarder ou tromper l'investigation (Ch. 13).

Artefact Trace qu'un système laisse en fonctionnant normalement : entrée de journal, clé de registre, raccourci (Ch. 4).

Autorité de numérotation (CNA) Organisme habilité à attribuer des identifiants CVE (Ch. 9).

Balise Connexion régulière d'un programme malveillant vers son serveur de commande (Ch. 6).

Bloqueur d'écriture Dispositif qui laisse passer les lectures vers un support et refuse les écritures (Ch. 3).

Cause contributive Condition qui a aggravé un incident ou facilité l'une de ses étapes (Ch. 12).

Cause immédiate Événement qui a directement permis l'incident (Ch. 12).

Cause profonde Défaut d'organisation qui a laissé subsister la cause immédiate et les causes contributives (Ch. 12).

Chaîne de possession Documentation continue de chaque détenteur, transfert, lieu et opération d'une pièce (Ch. 2).

Constatation Fait vérifiable, rattaché à une source identifiée (Ch. 0).

Conversation Échange entre une paire d'adresses et de ports, unité d'analyse d'une capture réseau (Ch. 6).

Cote OUI, NON, NEK Réponse à une proposition fermée : établie, contredite, ou non tranchable avec les preuves disponibles (Ch. 0, 16).

CVE Identifiant unique d'une vulnérabilité publiée (Ch. 9).

CVSS Système de notation de la gravité des vulnérabilités, de 0 à 10 ; version 4.0 avec groupes Base, Menace, Environnement, Supplémentaire (Ch. 9).

CWE Catalogue des types de faiblesses logicielles (Ch. 9).

Empreinte cryptographique Valeur de taille fixe calculée par une fonction de hachage, qui change si un seul bit de la donnée change (Ch. 2).

Entropie (H) Mesure, en bits, de la dispersion des cotes d'un ensemble de propositions (Ch. 16).

EPSS Probabilité estimée qu'une CVE soit exploitée dans les trente jours (Ch. 9).

Exception Décision écrite acceptant, pour une durée limitée et avec une mesure compensatoire, qu'une vulnérabilité reste ouverte (Ch. 11).

Faiblesse Type d'erreur de conception ou de programmation susceptible de créer des vulnérabilités (Ch. 9).

Faux négatif Vulnérabilité présente et non signalée (Ch. 10).

Faux positif Vulnérabilité signalée et absente (Ch. 10).

Force probante Poids qu'un décideur accorde à une pièce recevable (Ch. 2).

Indicateur de compromission Trace caractéristique d'une attaque ou de l'exploitation d'une faille, publiée pour en permettre la détection (Ch. 12).

Investigation numérique Démarche méthodique qui identifie, recueille, préserve, examine et analyse des traces numériques pour répondre à des questions de fait (Ch. 1).

KEV Catalogue des vulnérabilités dont l'exploitation est constatée, tenu par la CISA (Ch. 9).

MFT Table principale de NTFS, qui décrit chaque fichier par un enregistrement (Ch. 4).

Menace Source potentielle d'atteinte (Ch. 9).

Modèle de responsabilité partagée Répartition de la sécurité entre le fournisseur et le client d'un service en nuage (Ch. 13).

Pivot Élément commun qui relie des événements dans une chronologie : adresse, compte, empreinte, heure (Ch. 7).

Preuve numérique Trace recueillie, préservée et examinée de façon à soutenir ou réfuter une proposition de fait devant un décideur (Ch. 1).

Recevabilité Aptitude d'une pièce à être versée au débat (Ch. 2).

Répétabilité Propriété d'un examen qui donne le même résultat, refait par la même personne avec les mêmes outils (Ch. 1).

Reproductibilité Propriété d'un examen qui donne un résultat compatible, refait par une autre personne avec d'autres outils (Ch. 1).

Risque Combinaison de la vraisemblance qu'une menace exploite une vulnérabilité et de la gravité de l'atteinte (Ch. 9).

SSVC Méthode de décision de la CISA, qui conduit à suivre, suivre de près, traiter ou agir (Ch. 9).

Système de fichiers Organisation des données d'un volume en fichiers et répertoires (Ch. 4).

Table de partitions Structure qui découpe un disque en volumes (MBR, GPT) (Ch. 4).

Taux d'établissement (μ) Part des propositions cotées OUI (Ch. 16).

Taux d'incertitude (U) Part des propositions cotées NEK (Ch. 16).

Temps de présence Durée entre la première action établie de l'attaquant et la détection ; borne inférieure (Ch. 7).

Trace numérique Donnée qui garde la marque d'une action ou d'un état passé (Ch. 1).

Vulnérabilité Défaut d'une version précise d'un produit, exploitable pour porter atteinte à la sécurité (Ch. 9).

B

RÉFÉRENTIEL DES OUTILS

Les outils cités dans le cours sont rangés par usage. La plupart sont libres ou gratuits. L'annexe n'est pas une liste d'achats : un outil ne vaut que par la méthode de celui qui l'emploie, sa version notée et sa validation sur une pièce de référence (Chapitre 8, ISO/IEC 27041).

★ Attention

Règle de l'autorisation écrite. Aucun outil d'acquisition, d'analyse ou de balayage ne s'emploie sur un système sans l'autorisation écrite de celui qui en a le droit, et, le cas échéant, de l'hébergeur ou du prestataire. Sans autorisation, l'usage peut constituer un accès non autorisé au sens de l'article 65, alinéa 2, de la loi n° 2010/012.

Acquisition

Outil	Usage	Chapitre
Bloqueur d'écriture matériel	Acquisition à froid sans écriture sur la source	3
FTK Imager	Images de disques (brut, E01), captures mémoire, calcul d'empreintes	3
`dd`, `dc3dd`, `ewfacquire`	Images brutes ou E01 sous Linux	3
WinPmem, DumpIt	Capture mémoire sous Windows	3
LiME, AVML	Capture mémoire sous Linux	3
`sha256sum`	Calcul et vérification d'empreintes	2

Analyse

Outil	Usage	Chapitre
The Sleuth Kit, Autopsy	Systèmes de fichiers, fichiers supprimés, artefacts	4
Volatility 3	Analyse de captures mémoire	5
Wireshark, tshark	Analyse de captures réseau	6
Zeek	Journaux par protocole à partir d'une capture	6
log2timeline, Plaso	Super-chronologies	7
Visionneuses d'événements Windows	Lecture des journaux EVTX	4

Vulnérabilités

Outil ou ressource	Usage	Chapitre
Scanners de vulnérabilités (libres ou commerciaux)	Balayage authentifié ou non	10
Calculateur CVSS du FIRST	Score à partir d'un vecteur	9
EPSS (FIRST)	Probabilité d'exploitation, interface de consultation	9
Catalogue KEV (CISA)	Liste des failles exploitées	9, 11
NVD, CVE, CWE	Descriptions et références des failles	9
CIS Benchmarks	Références de configuration	10

Dans NDAP SUKULU

Les dix laboratoires du cours n'exigent aucune installation : leurs pièces (images réduites, captures, journaux, tableurs de balayage) se lisent avec les outils du bureau d'analyse de la plateforme ou, pour la version en ligne, avec un tableur et un éditeur de texte. Chaque laboratoire fournit son manifeste d'empreintes SHA-256, à vérifier avant tout examen.

C

MODÈLES DE DOCUMENTS

Les modèles suivants reprennent les documents utilisés dans le cours. Ils se recopient tels quels dans un tableur ou un traitement de texte, et s'adaptent à l'organisation.

M1. Registre des actions

N°	Date, heure	Auteur	Action	Résultat, empreinte
001				
002				

Chapitres 0 et 14.

M2. Formulaire de chaîne de possession

1. Identifiant de la pièce et numéro de scellé.
2. Description : nature, marque, modèle, numéro de série, capacité.
3. Provenance : système, emplacement, propriétaire.
4. Recueil : date, heure, lieu, personne, méthode, outil et version.
5. Empreintes : algorithme, valeur, heure, témoin.
6. Conditionnement : enveloppe, sac, scellé, photographie.
7. Transferts : remettant, destinataire, date, heure, motif, état du scellé, signatures.
8. Examens : personne, date, opération, copie utilisée.
9. Conservation : lieu, conditions.
10. Sort final : restitution, destruction, archivage, autorisation.

Chapitre 2.

M3. Lettre de mission d'enquête

- Mandant et enquêteur ; date ; fondement (contrat, réquisition).
- Questions de l'enquête, numérotées.
- Périmètre : systèmes, comptes, période.

© *MaletYon*

- Autorisations : signataires, hébergeurs et prestataires concernés.
- Règles de conservation des pièces et de remise à l'autorité judiciaire.
- Livrables et destinataires.

Chapitres 1 et 8.

M4. Matrice des hypothèses concurrentes

Pièce	H1	H2	H3	H4

C : compatible ; I : incompatible ; N : neutre. On retient l'hypothèse qui a le moins d'incompatibilités (Chapitre 1).

M5. Tableau des horloges

Source	Fuseau	Dérive	Précision	Synchronisée

Chapitre 7.

M6. Fiche de constat de vulnérabilité

- Identifiant (CVE), faiblesse (CWE), produit et version.
- Actif : nom, propriétaire, exposition, importance.
- Preuve du constat : méthode (authentifiée ou non), élément lu.
- Vérification : confirmé, faux positif, non vérifiable.
- Vecteur CVSS et score, avec la mention B, BT, BE ou BTE.
- EPSS du jour ; inscription au catalogue KEV et date.
- Classe de priorité, échéance, responsable.
- Correction : voie choisie, date, preuve de vérification.

Chapitres 9 à 11.

M7. Demande d'exception

- Faille, classe, actif.
- Motif, avec sa preuve.
- Mesure compensatoire, sa date de mise en place et sa vérification.
- Durée et date de revue.
- Propriétaire du risque et décideur, conformes à la politique.

Chapitre 11.

M8. Plan d'un rapport d'expertise

Mission (questions mot pour mot) ; pièces reçues ; opérations ; constatations ; discussion ; limites ; réponses aux questions, cotées ; annexes (Chapitre 15).

M9. Tableau des propositions cotées

N°	Proposition	Date 1	Date 2	Date 3
P1				

Avec, à chaque date, μ, U et H (Chapitre 16).

D

TEXTES ET NORMES DE RÉFÉRENCE

Cette annexe donne, pour chaque texte cité, son degré de vérification. Trois degrés sont utilisés : *texte officiel lu* (article cité entre guillemets d'après le texte officiel) ; *paraphrasé* (norme sous licence, dont le contenu est résumé sans citation) ; *à vérifier* (information dont l'auteur n'a pas pu contrôler la source à la date de rédaction).

Droit camerounais

Texte	Articles utilisés	Degré
Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité	26 al. 4, 29 al. 1 à 3, 30 al. 1, 52, 53, 54, 55, 56, 65 al. 2, 69, 72, 91 al. 3	Texte officiel lu
Loi n° 2010/012	26 al. 3, 57, 58, 66, 68, 71	Texte officiel lu, cités par résumé
Loi n° 2024/017 du 23 décembre 2024 (données personnelles)	Mentionnée seulement	Renvoi à l'UE JUR01
Code de procédure pénale	Preuve, expertise	À vérifier
Réglementation de la supervision des établissements de microfinance	Notification d'incident	À vérifier

Extraits de la loi n° 2010/012 non reproduits dans les chapitres

Jurisprudence & Droit applicable

Article 66, alinéa 1 : *« Est puni d'un emprisonnement de deux (02) à cinq (05) ans et d'une amende de 1.000.000 (un million) à 2.000.000 (deux millions) F CFA ou de l'une de ces deux peines seulement, celui qui entraîne la perturbation ou l'interruption du fonctionnement d'un réseau de communications électroniques ou d'un équipement terminal, en introduisant, transmettant, endommageant, effaçant, détériorant, modifiant, supprimant ou rendant inaccessibles les données. »*

© MaletYon

Article 68, alinéa 1 : *« Est puni d'un emprisonnement de cinq (05) à dix (10) ans et d'une amende de 10.000.000 (dix millions) à 50.000.000 (cinquante millions) F CFA ou de l'une de ces deux peines seulement, celui qui accède ou se maintient, frauduleusement, dans tout ou partie d'un réseau de communications électroniques ou d'un système d'information en transmettant, endommageant, provoquant une perturbation grave ou une interruption du fonctionnement dudit système ou dudit réseau. »*

Article 71 : *« Est puni d'un emprisonnement de deux (02) à cinq (05) ans et d'une amende de 1.000.000 (un million) à 25.000.000 (vingt cinq millions) F CFA, celui qui introduit sans droit, des données dans un système d'information ou dans un réseau de communications électroniques en vue de supprimer ou de modifier les données qui en sont contenues. »*

Conventions internationales

Texte	Objet	Degré
Convention de Budapest (Conseil de l'Europe, 2001)	Cybercriminalité, conservation rapide, entraide	Statut du Cameroun à vérifier
Convention de Malabo (Union africaine, 2014)	Cybersécurité et données personnelles ; en vigueur en 2023	Statut du Cameroun à vérifier

Normes et référentiels

Texte	Objet	Degré
ISO/IEC 27037:2012	Identification, recueil, acquisition, préservation	Paraphrasé
ISO/IEC 27041:2015	Adéquation des méthodes	Paraphrasé
ISO/IEC 27042:2015	Analyse et interprétation	Paraphrasé
ISO/IEC 27043:2015	Principes et processus d'investigation	Paraphrasé
ISO/IEC 27035	Gestion des incidents	Paraphrasé
ISO/IEC 27002:2022, mesure 8.8	Gestion des vulnérabilités techniques	Paraphrasé
ISO/IEC 17025:2017	Compétence des laboratoires	Paraphrasé
ISO/IEC 29147, 30111	Divulgation et traitement des vulnérabilités	Paraphrasé
NIST SP 800-86, 800-61 r2, 800-115, 800-40 r4	Forensique, incidents, évaluation, correctifs	Publications libres, paraphrasées
RFC 3227	Ordre de volatilité	Publication libre
CVSS v4.0 et v3.1 (FIRST)	Notation de la gravité	Spécification libre
EPSS (FIRST), KEV et SSVC (CISA)	Probabilité, exploitation, décision	Ressources libres

E

BIBLIOGRAPHIE COMMENTÉE

Les références complètes figurent dans la bibliographie en fin d'ouvrage. Cette annexe indique, partie par partie, par où commencer.

Partie I. Fondements

E. Casey [7] pose les notions de trace et de preuve numérique avec de nombreux exemples judiciaires. Le guide NIST SP 800-86 [31], court et gratuit, est la meilleure entrée dans les phases d'une enquête. R. Heuer [17] reste la référence sur les biais de l'analyste et l'analyse des hypothèses concurrentes. L'ISO/IEC 27037 [19] et l'ISO/IEC 27043 [22] donnent le cadre normatif.

Partie II. Méthode

Pour le disque, B. Carrier [5] explique les systèmes de fichiers de l'intérieur ; on le lit avec Autopsy ouvert. Pour la mémoire, M. H. Ligh et ses coauteurs [32] couvrent Windows, Linux et macOS ; la documentation de Volatility 3 [48] met à jour les commandes. Pour le réseau, R. Bejtlich [3] pense la supervision, C. Sanders [41] apprend à lire les paquets. La RFC 3227 [4] tient en quelques pages et se relit avant chaque intervention.

Partie III. Cadre normatif et juridique

La loi n° 2010/012 [34] se lit dans son texte officiel, chapitre de procédure d'abord. Les Conventions de Budapest [10] et de Malabo [11] éclairent l'entraide.

Partie IV. Vulnérabilités

Les spécifications du CVSS 4.0 [16], la documentation de l'EPSS [15], le catalogue KEV [13] et le guide SSVC [12] sont gratuits et courts. Le NIST SP 800-40 [44] traite la gestion des correctifs comme une maintenance planifiée ; le NIST SP 800-115 [42] distingue évaluation et test d'intrusion.

Partie V. Défis avancés

L'ISO/IEC 27042 [21] pour l'interprétation et le rapport ; l'ISO/IEC 27035 [28] et le NIST SP 800-61 [9] pour les enseignements tirés d'un incident.

Partie VI. Recherche

Les deux articles fondateurs du programme de l'auditologie sont déposés sur HAL : « Vers l'auditologie » [37] et l'article sur l'instrument trichotomique [36]. Les articles

suivants du programme sont en préparation. C. E. Shannon [43] reste la source de la mesure d'entropie.

F

CONTACTS ET RESSOURCES

Au Cameroun

Organisme	Rôle pour le cours
Agence nationale des technologies de l'information et de la communication (ANTIC)	Agents habilités à enquêter (loi n° 2010/012, art. 52) ; audits de sécurité ; équipe nationale de réponse aux incidents
Parquet et officiers de police judiciaire	Plainte, réquisitions, scellés, entraide
Experts près les cours d'appel	Expertise judiciaire sur réquisition (art. 56)

Ressources internationales

Ressource	Adresse
Programme CVE	https://www.cve.org/
Catalogue CWE	https://cwe.mitre.org/
Base NVD	https://nvd.nist.gov/
CVSS et EPSS (FIRST)	https://www.first.org/cvss/, https://www.first.org/epss/
Catalogue KEV (CISA)	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Matrice ATT&CK	https://attack.mitre.org/
Volatility 3	https://github.com/volatilityfoundation/volatility3
The Sleuth Kit et Autopsy	https://www.sleuthkit.org/

Le cours

Dépôt du cours : https://github.com/MaletYon/cours-fav. NDAP SUKULU en ligne : https://maletyon.github.io/cours-fav/ndap-sukulu/. Compte de démonstration : matricule `ETU001`, mot de passe `eTU001`. Contact : maletyon@proton.me.

© *MaletYon*

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] J. Arkko, M. Cotton et L. Vegoda, « IPv4 Address Blocks Reserved for Documentation, » IETF, RFC 5737, 2010.

[2] Association of Chief Police Officers, *ACPO Good Practice Guide for Digital Evidence*, ACPO, Royaume-Uni, 2012.

[3] R. Bejtlich, *The Practice of Network Security Monitoring*. No Starch Press, 2013.

[4] D. Brezinski et T. Killalea, « Guidelines for Evidence Collection and Archiving, » Internet Engineering Task Force, RFC 3227, 2002.

[5] B. Carrier, *File System Forensic Analysis*. Addison-Wesley Professional, 2005.

[6] B. Carrier, *The Sleuth Kit and Autopsy*, https://www.sleuthkit.org/, Consulté en 2026, 2024.

[7] E. Casey, *Digital Evidence and Computer Crime*. Academic Press, 2004.

[8] Center for Internet Security. « CIS Benchmarks. » Guides de configuration par produit, profils de niveau 1 et 2, visité le 6 nov. 2026. adresse : https://www.cisecurity.org/cis-benchmarks

[9] P. Cichonski, T. Millar, T. Grance et K. Scarfone, « Computer Security Incident Handling Guide, » National Institute of Standards et Technology, NIST Special Publication 800-61 Rev. 2, 2012.

[10] Conseil de l'Europe, *Convention sur la cybercriminalité (Convention de Budapest, STE n° 185)*, Conseil de l'Europe, Budapest, 2001.

[11] *Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel*, Adoptée à Malabo ; entrée en vigueur en 2023. État de signature et de ratification par le Cameroun à vérifier, 27 juin 2014.

[12] Cybersecurity and Infrastructure Security Agency, « Stakeholder-Specific Vulnerability Categorization (SSVC) Guide, » CISA, rapp. tech., 2022.

[13] Cybersecurity and Infrastructure Security Agency, *Known Exploited Vulnerabilities Catalog*, CISA, https://www.cisa.gov/known-exploited-vulnerabilities-catalog, 2024.

[14] FIRST, *Common Vulnerability Scoring System version 3.1 : Specification Document*, Forum of Incident Response and Security Teams, 2019.

[15] FIRST, *Exploit Prediction Scoring System (EPSS)*, Forum of Incident Response and Security Teams, https://www.first.org/epss/, 2023.

[16] Forum of Incident Response and Security Teams, *Common Vulnerability Scoring System, Version 4.0: Specification Document*, FIRST, 2023.

[17] J. Heuer Richards J., *Psychology of Intelligence Analysis*. Washington, DC : Center for the Study of Intelligence, Central Intelligence Agency, 1999.

[18] E. M. Hutchins, M. J. Cloppert et R. M. Amin, « Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains, » Lockheed Martin Corporation, rapp. tech., 2011.

[19] ISO/IEC, *ISO/IEC 27037:2012 – Information technology – Security techniques – Guidelines for identification, collection, acquisition and preservation of digital evidence*, Genève : ISO, 2012.

[20] ISO/IEC, *Information technology. Security techniques. Guidance on assuring suitability and adequacy of incident investigative method*, ISO/IEC 27041:2015, 2015.

[21] ISO/IEC, *Information technology. Security techniques. Guidelines for the analysis and interpretation of digital evidence*, ISO/IEC 27042:2015, 2015.

[22] ISO/IEC, *Information technology. Security techniques. Incident investigation principles and processes*, ISO/IEC 27043:2015, 2015.

[23] ISO/IEC, *General requirements for the competence of testing and calibration laboratories*, ISO/IEC 17025:2017, 2017.

[24] ISO/IEC, *ISO/IEC 29147:2018 — Information technology — Security techniques — Vulnerability disclosure*, International Organization for Standardization, Genève, 2018.

[25] ISO/IEC, *ISO/IEC 30111:2019 — Information technology — Security techniques — Vulnerability handling processes*, International Organization for Standardization, Genève, 2019.

[26] ISO/IEC, *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*, Genève : ISO, 2022.

[27] ISO/IEC, *ISO/IEC 27002:2022 – Information security, cybersecurity and privacy protection – Information security controls*, Genève : ISO, 2022.

[28] ISO/IEC, *ISO/IEC 27035 · Information technology · Information security incident management*, International Organization for Standardization, Genève, 2023.

[29] Joint Task Force, « Security and Privacy Controls for Information Systems and Organizations, » National Institute of Standards et Technology, NIST Special Publication 800-53 Rev. 5, 2020.

[30] Joint Task Force, « Assessing Security and Privacy Controls in Information Systems and Organizations, » National Institute of Standards et Technology, Special Publication 800-53A, Revision 5, 2022.

[31] K. Kent, S. Chevalier, T. Grance et H. Dang, « Guide to Integrating Forensic Techniques into Incident Response, » National Institute of Standards et Technology, NIST Special Publication 800-86, 2006.

[32] M. H. Ligh, A. Case, J. Levy et A. Walters, *The Art of Memory Forensics: Detecting Malware and Threats in Windows, Linux, and Mac Memory*. Wiley, 2014.

[33] E. Locard, *L'enquête criminelle et les méthodes scientifiques*. Paris : Ernest Flammarion, 1920.

[34] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité au Cameroun*, 21 déc. 2010.

[35] *Loi n° 2024/017 du 23 décembre 2024 régissant la protection des données à caractère personnel au Cameroun*, 23 déc. 2024.

[36] T. E. Minka Mi Nguidjoï. « Modelling epistemic uncertainty in information systems audit: A trichotomous response instrument and its information-theoretic properties. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701270. adresse : https://hal.science/hal-05701270

[37] T. E. Minka Mi Nguidjoï. « Vers l'auditologie : un agenda de recherche en science du design pour une science appliquée de la réduction de l'incertitude dans l'audit des systèmes d'information. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701007. adresse : https://hal.science/hal-05701007

[38] National Institute of Standards and Technology, *Guidelines on Mobile Device Forensics*, NIST Special Publication 800-101 Rev. 1, 2014.

[39] National Institute of Standards and Technology, *National Vulnerability Database (NVD)*, https://nvd.nist.gov/, Consulté en 2026, 2024.

[40] OWASP, *OWASP Top 10:2021 : The Ten Most Critical Web Application Security Risks*, OWASP Foundation, 2021.

[41] C. Sanders, *Practical Packet Analysis*, 3e éd. No Starch Press, 2017.

[42] K. Scarfone, M. Souppaya, A. Cody et A. Orebaugh, « Technical Guide to Information Security Testing and Assessment, » National Institute of Standards et Technology, NIST Special Publication 800-115, 2008.

[43] C. E. Shannon, « A Mathematical Theory of Communication, » *Bell System Technical Journal*, t. 27, no 3, p. 379-423, 1948.

[44] M. Souppaya et K. Scarfone, « Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology, » National Institute of Standards et Technology, NIST Special Publication 800-40 Rev. 4, 2022.

[45] The MITRE Corporation, *Common Vulnerabilities and Exposures (CVE) Program*, https://www.cve.org/, Consulté en 2026, 2024.

[46] The MITRE Corporation, *Common Weakness Enumeration (CWE)*, https://cwe.mitre.org/, Consulté en 2026, 2024.

[47] The MITRE Corporation, *MITRE ATT&CK : Adversarial Tactics, Techniques, and Common Knowledge*, https://attack.mitre.org/, Consulté en 2026, 2024.

[48] Volatility Foundation, *Volatility 3: The Volatile Memory Extraction Framework*, https://github.com/volatilityfoundation/volatility3, Consulté en 2026, 2024.

INDEX

Acquisition à chaud, 41
Acquisition à froid, 40
Analyse, 5
analyse de variantes, 125
Anti-forensique, 132
artefact, 51
autorité de numérotation, 98

Balise, 70
bloqueur d'écriture, 41

Cause contributive, 124
Cause immédiate, 124
Cause profonde, 124
Chaîne de possession, 30
Constatation, 5
conversations, 68
Cote OUI, NON, NEK, 5
CVSS, 98

Entropie, 158
EPSS, 100
Exception, 116

Faiblesse, 98
Faux négatif, 107
Faux positif, 107
Fonction de hachage cryptographique, 29
Force probante, 28

indicateurs de compromission, 122
Investigation numérique, 16

Menace, 98
modèle de responsabilité partagée, 133

pivot, 76
Preuve numérique, 16

Recevabilité, 28
Risque, 98

système de fichiers, 50

table de partitions, 50
table MFT, 50
Taux d'incertitude, 158
Taux d'établissement, 158
Temps de présence, 78
Trace numérique, 16

Vulnérabilité, 98

À propos de ce cours

Une enquête numérique part d'une trace et remonte vers une cause. Une analyse de vulnérabilités part d'une faiblesse connue et cherche à la fermer avant qu'elle ne laisse une trace. Ce cours enseigne les deux, et la manière dont l'une nourrit l'autre.

Il progresse en six parties, précédées d'un prologue : les fondements de l'investigation et de la preuve, la méthode (acquisition, disque, mémoire, réseau, chronologie), le cadre normatif et juridique, les vulnérabilités (identifier, coter, corriger), les défis avancés et la recherche sur l'incertitude d'une enquête.

Il s'adresse aux étudiants du Master Professionnel en Sécurité des Systèmes Numériques et aux professionnels qui exercent comme analystes forensiques, analystes en réponse à incident, analystes en gestion des vulnérabilités ou RSSI.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information